안전한 미래를 여는 식의약 규제혁신

국민 안심이 기준입니다

디지털의료기기 전자적 침해행위 보안지침 가이드라인

(민원인안내서)

2025. 11.

식품의약품안전처
디지털의료제품TF

지침서·안내서 제·개정 점검표

명칭	디지털의료기기 전자적 침해행위 보안지침 가이드라인 (민원인안내서)

아래에 해당하는 사항에 체크하여 주시기 바랍니다.

등록대상 여부	□ 이미 등록된 지침서·안내서 중 동일·유사한 내용의 지침서·안내서가 있습니까?	□ 예 ■ 아니오
	☞ 상기 질문에 '예'라고 답하신 경우 기존의 지침서·안내서의 개정을 우선적으로 고려하시기 바랍니다. 그럼에도 불구하고 동 지침서·안내서의 제정이 필요한 경우 그 사유를 아래에 기재해 주시기 바랍니다. (사유 :)	
	□ 법령(법·시행령·시행규칙) 또는 행정규칙(고시·훈령·예규)의 내용을 단순 편집 또는 나열한 것입니까?	□ 예 ■ 아니오
	□ 단순한 사실을 대외적으로 알리는 공고의 내용입니까?	□ 예 ■ 아니오
	□ 일회성 지시·명령에 해당하는 내용입니까?	□ 예 ■ 아니오
	□ 외국 규정을 번역하거나 설명하는 내용입니까?	□ 예 ■ 아니오
	□ 신규 직원 교육을 위해 법령 또는 행정규칙을 알기 쉽게 정리한 자료입니까?	□ 예 ■ 아니오
	☞ 상기 사항 중 어느 하나라도 '예'에 해당되는 경우에 지침서·안내서 등록 대상이 아닙니다. 지침서·안내서 제·개정 절차를 적용하실 필요는 없습니다.	
지침서·안내서 구분	□ 행정사무의 통일을 기하기 위하여 내부적으로 행정사무의 세부기준이나 절차를 제시하는 것입니까? (공무원용)	□ 예(☞지침서) ■ 아니오
	□ 민원인들의 이해를 돕기 위하여 법령 또는 행정규칙을 알기 쉽게 설명하거나 특정 민원업무에 대한 행정기관의 대외적인 입장을 기술하는 것입니까? (민원인용)	■ 예(☞안내서) □ 아니오
기타 확인 사항	□ 상위 법령을 일탈하여 새로운 규제를 신설·강화하거나 민원인을 구속하는 내용이 있습니까?	□ 예 ■ 아니오
	☞ 상기 질문에 '예'라고 답하신 경우 상위법령 일탈 내용을 삭제하시고 지침서·안내서 제·개정 절차를 진행하시기 바랍니다.	

상기 사항에 대하여 확인하였음.

2025 년 11월 13일

담당자 신 근 수

확 인(부서장) 손 미 정

이 안내서는 디지털의료기기 전자적 침해행위 보안지침에 대한 기업의 준비사항, 기준 등에 대하여 알기 쉽게 설명하거나 식품의약품안전처의 입장을 기술한 것입니다.

본 안내서는 대외적으로 법적 효력을 가지는 것이 아니므로 본문의 기술방식('~하여야 한다' 등)에도 불구하고 민원인 여러분께서 반드시 준수하셔야 하는 사항이 아님을 알려드립니다. 또한, 본 안내서는 2025년 11월 현재의 과학적·기술적 사실 및 유효한 법규를 토대로 작성되었으므로 이후 최신 개정 법규 내용 및 구체적인 사실관계 등에 따라 달리 적용될 수 있음을 알려드립니다.

※ "민원인 안내서"란 민원인들의 이해를 돕기 위하여 법령 또는 행정규칙을 알기 쉽게 설명하거나 특정 민원업무에 대한 행정기관의 대외적인 입장을 기술하는 것 (식품의약품안전처 지침서 등의 관리에 관한 규정 제2조)

※ 본 안내서에 대한 의견이나 문의사항이 있을 경우 **식품의약품안전처 의료기기안전국 디지털의료제품TF**에 문의하시기 바랍니다.

전화번호: 043-719-3773~3779
팩스번호: 043-719-3780

제·개정 이력

연번	제·개정번호	발행일자	주요내용
1	안내서-1458-01	2025.11.13.	제정

목 차

Ⅰ. 개 요 ····· 1

1. 배경 및 목적 ····· 1

2. 용어 정의 ····· 3

3. 관련 규정 ····· 7

4. 주요 구성 및 활용 방향 ····· 14

Ⅱ. 보안지침 실무 적용 가이드 ····· 18

1. 보안지침 개요 ····· 18

2. 보안지침 조항별 실무 가이드 ····· 33

Ⅲ. 서식 및 추가 자료 ····· 185

[붙임1] 디지털의료기기 전자적 침해행위 보안지침 절차서 샘플 ····· 185

[붙임2] 디지털의료기기 허가 인증 심사 첨부 자료 ····· 194

[붙임3] 디지털의료기기 제조 및 품질관리 기준(GMP) 심사 대응 체크리스트 ····· 195

Ⅳ. 부록 ····· 198

참고 법령, 지침 및 표준 목록 ····· 198

Ⅰ 개 요

1. 배경 및 목적

최근 디지털 기술의 급속적인 발전으로 인해 의료기기는 더 이상 단순한 하드웨어 중심의 장비가 아니라, 네트워크, 소프트웨어, 인공지능 등의 기술이 결합된 고도화된 융합형 디지털의료기기로 빠르게 진화하고 있다. 이러한 기술적 발전은 환자 맞춤형 진단 및 치료, 데이터 기반 질병 예측 등 다양한 혁신을 가능하게 하였으나, 동시에 사이버보안 위협에 대한 노출 가능성 또한 증가시키고 있다.

특히, 디지털의료기기는 사람의 생명 및 건강과 직접적으로 연관되는 제품인 만큼, 사이버보안 위협으로 인한 기능 장애, 오작동, 데이터 위·변조, 시스템 마비 등의 상황은 심각한 환자 안전 문제로 이어질 수 있으며, 국가 보건·안보의 관점에서도 보호가 필요하다.

이에 따라 정부는 「디지털의료제품법」(법률 제20331호) 제14조에 따라 디지털의료기기를 전자적 침해행위로부터 보호하기 위한 물리적·기술적 관리체계 구축에 필요한 사항을 규정하는 보안지침을 고시하였다. 여기서 '전자적 침해행위'란 해킹, 악성코드 등 기존에 통용되던 사이버보안 위협에 대응하는 법률적 개념으로 해당 지침은 디지털의료기기제조업자등이 디지털의료기기의 개발, 제조, 유지관리, 운영 전 과정에 걸쳐 적용해야 하는 보안 요구사항을 구체화하고 있으며, 디지털의료기기 제조 및 품질관리 기준(GMP) 심사, 우수관리체계 인증, 임상시험, 임상적 성능시험, 인·허가 등의 제도와도 맞물려 있다.

그러나 실제 디지털의료기기제조업자등과 해당 실무자들이 보안지침을 이해하고 그대로 이행하기에는 다음과 같은 어려움이 존재하고 있다.

1) 지침 조항이 포괄적·기술적으로 작성되어 있어 실무에 바로 적용하기 어려움

2) 『의료기기의 사이버보안 허가·심사 가이드라인』과의 관계가 명확히 정리되어 있지 않음

3) 지침 이행을 위한 절차서, 보고서, 기록지 등 실질적 문서화 방향에 대한 안내 부족

이에 본 가이드라인은 다음과 같은 목적을 보유하여 디지털의료기기 제조업자등과 관련 실무자들에게 안내하고자 한다.

1) 디지털의료기기제조업자등이 전자적 침해행위 보안지침의 요구사항을 정확히 이해하고 실무에 적용할 수 있도록 조항별 해설과 대응 방안을 제공

2) 『의료기기의 사이버보안 허가·심사 가이드라인』과의 정합성을 병기하여, 하나의 문서로 다수의 규정 대응이 가능하도록 지원

3) 디지털의료기기 GMP 심사 대응, 우수관리체계 인증, 임상시험, 임상적 성능시험, 인·허가 대응 등에 필요한 실무적 수준의 안내 제공

4) 실무에서 바로 활용 가능한 가이드, 산출물 등 서식들을 포함하여 보안지침 이행을 위한 문서화 품질과 일관성을 제고

이 가이드는 디지털의료기기제조업자등과 관련 실무자들이 보안지침을 실효성 있게 이행함으로써, 디지털의료기기의 안전성·신뢰성을 확보하고 국민 건강 보호에 기여하는 것을 궁극적인 목적으로 한다.

해당 가이드는 고시에서 기술하고 있는 내용은 실무 차원의 이해를 돕기 위한 목적으로 작성되었으며, 기업 실무자들은 각 기업 및 제품의 상황에 맞게 판단하여 적용 수준을 결정하면 된다.

2. 용어 정의

가. “데이터 중독 공격(Data Poisoning Attack)” 이란 인공지능을 활용한 디지털의료기기를 훈련하는 과정에서 훈련 데이터셋에 악의적인 데이터를 주입하여 인공지능 모델이 부정확하거나 왜곡된 학습을 하도록 유도하는 공격을 말한다.

나. “데이터 회피 공격(Data Evasion Attack)” 이란 인공지능을 활용한 디지털의료기기에 공격자(적대자)가 입력 데이터에 미세 변형을 가해 모델 출력을 오도하는 공격을 말한다.

다. “디지털의료기기제조업자” 란 디지털의료기기를 설계, 개발, 출시, 지원 등의 업무를 담당하는 제조업의 허가를 받은자를 말한다.

라. “레거시 디지털의료기기(Legacy digital medical device)” 이란 현재의 사이버보안 위협에 대해 합리적으로 보호할 수 없는 의료기기를 말한다. *(IMDRF - Principles and Practices for Medical Device Cybersecurity)*

마. “무결성(Integrity)” 이란 데이터가 생성, 전송 또는 저장된 이후 무단으로 변경되지 않은 속성을 말한다. *(ISO/IEC 29167-19:2016)*

바. “버퍼 초과 오류(Buffer overflow)” 란 디지털의료기기가 실행되는 컴퓨터 등에 동작하는 메모리에 할당된 버퍼의 양을 초과하는 데이터를 입력하여 해킹 등의 공격으로 인해 해커가 원하는 코드를 실행하여 공격하는 방법을 말한다.

사. “보안 설계(Secure design)” 란 디지털의료기기가 설계되는 초기 단계에서부터 보안을 고려하여 시스템 구조를 설계하는 것을 말한다.

아. “보안 코딩(Secure coding)” 이란 디지털의료기기 개발 과정에서 소스코드의

보안을 강화하기 위해 입력값 검증, 에러 처리, 자원 관리 등의 일련의 기법과 규칙을 준수하여 개발하는 것을 말한다.

자. “보안 테스트(Security testing)”란 권한이 없는 사람이나 시스템이 테스트 항목과 관련 데이터 및 정보를 사용, 읽기 또는 수정할 수 없고 권한이 있는 사람이나 시스템이 이에 대한 접근을 거부당하지 않도록 보호되는 정도를 평가하기 위해 수행되는 테스트 유형을 말한다.

차. “수명 종료(End of life)”란 디지털의료기기제조업자등에서 정한 사용 연수를 초과한 제품을 더 이상 판매하지 않고 사용자에게 통지하는 절차를 포함한 공식적인 수명 종료(단종) 과정을 진행함으로써 시작되는 디지털의료기기의 생명 주기 단계를 말한다. *(IMDRF – Principles and Practices for Medical Device Cybersecurity)*

카. “세션(Session)”이란 네트워크 환경에서 사용자 간 또는 컴퓨터 간의 대화를 위한 논리적인 연결을 말한다.

타. “소프트웨어 구성 요소 명세서(Software bill of materials)”란 하나 이상의 식별된 컴포넌트 간의 관계 및 기타 관련 정보의 목록을 의미한다.

파. “안티 바이러스 소프트웨어(Anti-virus Software)”란 컴퓨터 바이러스 등의 악성코드를 탐지하고 방어하기 위한 소프트웨어를 말한다.

하. “암호 키(Encryption key)”란 암호화적 변환(즉, 암호화, 복호화, 암호학적 검사 함수 계산, 서명 계산, 서명 검증 등)의 작동을 조절하는 기호의 열을 말한다.

거. “업데이트(Update)”란 디지털의료기기에 대한 수정형, 예방형, 적응형 또는 진보형 수정 사항을 말한다. *(IMDRF – Principles and Practices for Medical Device Cybersecurity)*

참고 1: ISO/IEC 14764:2006에 설명된 소프트웨어 유지 관리 활동에서 파생된 개념

참고 2: 업데이트에는 패치 및 구성 변경 사항이 포함될 수 있다.

참고 3: 적응형과 진보형 수정 사항은 소프트웨어의 개선 사항이다. 이러한 수정사항은 의료기기의 설계 사양에 포함되지 않았던 수정사항이다.

너. "오픈소스 소프트웨어(Opensource software)"란 오픈소스 소프트웨어 라이선스에 따라 소스코드가 공개되어 누구나 자유롭게 사용하고 수정하거나 재배포할 수 있는 소프트웨어를 말한다.

더. "위험 관리(Risk management)"란 위험을 분석하고 평가, 통제 및 감시하는 업무에 관리 정책과 절차 및 실무를 체계적으로 적용하는 것을 말한다. *(KS P ISO 14971:2019)*

러. "위험 통제(Risk control)"란 규정된 수준 이하로 감소시키거나 유지하도록 하는 결정이 내려지고 조치가 수행되는 프로세스를 말한다. *(KS P ISO 14971:2019)*

머. "위험 평가(Risk evaluation)"란 위험의 허용 가능성을 결정하기 위해 산정된 위험을 주어진 위험 허용 기준과 비교하는 프로세스를 말한다. *(KS P ISO 14971:2019)*

버. "위협 모델링(Threat modeling)"이란 시스템에 피해를 입힐 수 있는 파괴, 공개, 데이터의 수정 또는 서비스 거부 형태의 모든 상황 또는 사건을 노출시키는 탐색적인 과정을 말한다. *(ISO/IEC/IEEE 24765-2017에서 적용) (IMDRF – Principles and Practices for Medical Device Cybersecurity)*

서. "유효성(Validity)"이란 시스템, 데이터 또는 프로세스가 그 목적에 맞게 제대로 작동하는지를 확인하는 속성을 말한다.

어. "의료서비스제공자"란 환자에게 진단 또는 치료를 목적으로 의료서비스를 제공하는 의료인 및 디지털의료기기제조업자등을 말한다.

저. “이동식 저장매체”란 컴퓨터의 저장 장치 환경에서 자료를 옮길 수 있도록 휴대성을 제공하는 이동식 매체를 말한다.

처. “잔여 위험(Residual risk)”이란 위험 통제 조치가 구축된 이후에 남아 있는 위험을 말한다. *(KS P ISO 14971:2019)*

커. “전자적 침해행위”란 해킹, 컴퓨터 바이러스, 악성코드, 메일폭탄, 서비스 거부 및 고출력 전자기파 등에 의하여 디지털의료기기 및 운영 환경을 공격하는 행위를 말한다.

터. “제3자 소프트웨어(Third-party software)”란 관련 당사자와 독립적인 것으로 인정되는 개인 또는 단체가 제공하는 소프트웨어를 말한다.

퍼. “지원 종료(End of support)”란 디지털의료기기제조업자가 모든 서비스 지원 활동을 종료하고 서비스 지원이 해당 시점을 넘어 연장되지 않아 시작되는 디지털의료기기의 생명 주기 단계를 말한다. *(IMDRF – Principles and Practices for Medical Device Cybersecurity)*

허. “컴포넌트(Component)”란 시스템의 물리적 또는 논리적 부분을 형성하고 특정한 기능과 인터페이스를 가지며 시스템의 다른 부분과 독립적으로 존재하는 것으로 취급되는 시스템 자원의 모음을 말한다.

고. “테스트 도구(Testing tools)”란 취약성 테스트, 성능 테스트 등의 테스트를 수행하기 위해 사용되는 다양한 도구들을 말한다.

노. “해시 알고리즘(Hash algorithm)”이란 다양한 길이를 가진 데이터를 고정된 길이를 가진 데이터로 변환하는데 사용되는 함수를 말한다.

도. “해시값(Hash value)”이란 임의적인 길이의 데이터에서 고정된 길이의 랜덤 값을 생성하는 계산 방법인 해시 알고리즘으로 계산된 값을 말한다.

3. 관련 규정

※ 디지털의료제품법 관련 규정은 아래 내용을 참고하고, 국가법령정보센터 누리집(https://www.law.go.kr)에서 개정된 최신 규정을 확인하시기 바랍니다.

○ 「디지털의료제품법」 제13조, 제14조, 제16조, 제24조, 제32조

제13조(디지털의료기기제조업자 및 디지털의료기기수입업자의 준수사항) 디지털의료기기제조업자 및 디지털의료기기수입업자(이하 "디지털의료기기제조업자등"이라 한다)는 총리령으로 정하는 바에 따라 다음 각 호의 사항을 준수하여야 한다.

① 디지털의료기기의 오작동, 기능의 미비 등 제품의 결함이나 오류로 인하여 발생하는 문제를 지속적으로 수집·관리 또는 개선

② ***전자적 침해행위(해킹, 컴퓨터 바이러스, 논리·메일폭탄, 서비스 거부 또는 고출력 전자기파 등의 방법으로 디지털의료기기의 안전성과 유효성, 성능 등에 영향을 미치는 행위를 말한다. 이하 같다)로부터의 취약점에 대한 지속적인 보완***

③ 그 밖에 디지털의료기기의 안전관리 및 소비자 보호를 위하여 총리령으로 정하는 사항

제14조(전자적 침해행위로부터의 보호조치) ① 식품의약품안전처장은 디지털의료기기를 전자적 침해행위로부터 안전하게 보호하기 위하여 디지털의료기기의 취약점을 지속적으로 감시하고 전자적 침해행위에 대응하는 물리적·기술적 관리체계에 관한 지침(이하 "보안지침"이라 한다)을 마련하여야 한다.

② 디지털의료기기제조업자등(제26조에 따라 디지털의료기기소프트웨어의 유지·관리업무를 위탁받은 자를 포함한다. 이하 이 조에서 같다)은 보안지침을 준수하여야 한다.

③ 식품의약품안전처장은 전자적 침해행위의 예방 및 확산 방지를 위하여 디지털의료기기제조업자등에게 기술 지원 등 필요한 조치를 할 수 있다.

제17조(우수 관리체계 인증) ① 식품의약품안전처장은 디지털의료기기의 안전성 확보 및 품질 유지를 위하여 디지털의료기기제조업자등을 대상으로 우수 관리체계 인증(이하 "우수 관리체계 인증"이라 한다)을 할 수 있다.

② 우수 관리체계 인증 기준은 다음 각 호의 사항을 포함하여야 한다.

1. 디지털의료기기의 개발, 시험, 유지·관리 등 품질관리
2. 소비자에 대한 정보 제공, 부작용 발생 시 대응체계 등 안전관리
3. ***전자적 침해행위의 예방 및 대응체계***
4. 그 밖에 식품의약품안전처장이 정하는 사항

③ 인증의 유효기간은 인증을 받은 날로부터 3년으로 한다.

④ 제2항에 따른 우수 관리체계 인증 기준의 세부내용은 식품의약품안전처장이 정한다.

제24조(디지털의료기기소프트웨어 품질관리기준 적합판정) ① 식품의약품안전처장은 ***전자적 침해행위***가 없는 상태에서 디지털의료기기소프트웨어의 결함이나 오류, 오작동 등으로 인하여 발생할 수 있는 사고를 예방하기 위하여 디지털의료기기소프트웨어 품질관리기준(이하 "품질관리기준"이라 한다)을 정할 수 있다.
② 디지털의료기기제조업자등은 제조 또는 수입하여 판매하려는 디지털의료기기소프트웨어에 대하여 품질관리기준에 적합하다는 식품의약품안전처장의 판정(이하 "적합판정"이라 한다)을 받아야 한다.
③ 디지털의료기기제조업자등이 적합판정 받은 사항을 변경하려는 경우에는 변경적합판정을 받아야 한다. 다만, 총리령으로 정하는 경미한 사항을 변경하려는 경우에는 그러하지 아니하다.
④ 제2항 또는 제3항에 따라 적합판정 또는 변경적합판정을 받으려는 디지털의료기기 제조업자등은 총리령으로 정하는 바에 따라 품질관리에 관한 자료를 제출하여야 한다.
⑤ 적합판정의 유효기간은 적합판정을 받은 날로부터 3년으로 한다.
제32조(디지털융합의약품의 부분을 구성하는 디지털의료기기에 대한 전자적 침해행위로부터의 보호 조치 등의 적용) 디지털융합의약품의 부분을 구성하는 디지털의료기기에 대하여는 제14조에 따른 ***전자적 침해행위로부터의 보호 조치***, 제15조에 따른 실사용 평가, 제24조 및 제25조에 따른 디지털의료기기소프트웨어 품질관리기준 적합판정 및 적합판정 확인·조사를 적용한다.

○ 「디지털의료제품법 시행규칙」 제14조, 제19조, 제49조

제14조(임상시험계획 승인 등) ① 법 제9조제1항 전단에 따라 임상시험계획의 승인을 받으려는 자는 별지 제9호서식의 디지털의료기기 임상시험계획 승인신청서에 다음 각 호의 서류 및 자료를 첨부하여 식품의약품안전처장에게 제출해야 한다.
1. 임상시험계획서
2. 임상시험용 디지털의료기기가 별표 3에 따른 시설과 제조 및 품질관리체계에서 적합하게 제조되고 있음을 증명하는 자료(독립형 디지털의료기기소프트웨어는 제외한다)
3. 임상시험용 디지털의료기기의 안전성을 검토하기 위한 다음 각 목에 따른 자료
가. 작용원리에 관한 자료
나. 디지털의료기기소프트웨어 검증 및 유효성에 관한 자료
다. 전자적 침해행위로부터의 보호 조치에 관한 자료
라. 제품의 성능 및 안전을 확인하기 위한 시험규격 및 그 설정 근거와 실측값에 관한 자료로서 식품의약품안전처장이 정하여 고시하는 자료(소프트웨어 내장 디지털의료기기만 해당한다)
4. 디지털의료기기의 부분을 구성하는 디지털의료·건강지원기기에 대해서는 법 제34조제2항에 따른 성능인증에 관한 자료(디지털의료기기와 디지털의료·건강

지원기기가 조합된 경우만 해당한다)
5. 법 제31조제2항에 따라 디지털융합의약품의 부분을 구성하는 디지털의료기기로 임상시험을 실시하는 경우에는 디지털융합의약품을 구성하는 의약품과 디지털의료기기의 조합적 특성에 관한 자료
② 법 제9조제1항 후단에 따라 승인을 받은 임상시험계획을 변경하려는 자는 별지 제10호서식의 디지털의료기기 임상시험계획 변경승인신청서에 다음 각 호의 서류 및 자료를 첨부하여 식품의약품안전처장에게 제출해야 한다. 다만, 제2호부터 제5호까지의 자료는 식품의약품안전처장이 고시하는 바에 따라 제출하지 않을 수 있다.
1. 임상시험변경계획서
2. 임상시험용 디지털의료기기가 별표 3에 따른 시설과 제조 및 품질관리체계에서 적합하게 제조되고 있음을 증명하는 자료(독립형 디지털의료기기소프트웨어는 제외한다)
3. 임상시험용 디지털의료기기의 안전성을 검토하기 위한 다음 각 목에 따른 자료
가. 작용원리에 관한 자료
나. 디지털의료기기소프트웨어 검증 및 유효성에 관한 자료
다. 전자적 침해행위로부터의 보호 조치에 관한 자료
라. 제품의 성능 및 안전을 확인하기 위한 시험규격 및 그 설정 근거와 실측값에 관한 자료로서 식품의약품안전처장이 정하여 고시하는 자료(소프트웨어 내장 디지털의료기기만 해당한다)
4. 디지털의료기기의 부분을 구성하는 디지털의료·건강지원기기에 대해서는 법 제34조제2항에 따른 성능인증에 관한 자료(디지털의료기기와 디지털의료·건강지원기기가 조합된 경우만 해당한다)
5. 법 제31조제2항에 따라 디지털융합의약품의 부분을 구성하는 디지털의료기기로 임상시험을 실시하는 경우에는 디지털융합의약품을 구성하는 의약품과 디지털의료기기의 조합적 특성에 관한 자료
③ 법 제9조제2항제2호에서 "총리령으로 정하는 임상시험"이란 다음 각 호의 임상시험을 말한다. 다만, 디지털융합의약품의 부분을 구성하는 디지털의료기기로 임상시험을 하려는 경우로서 이미 허가 또는 인증받은 디지털의료기기와 사용목적, 작용원리 등이 동등하지 않은 경우는 제외한다.
1. 의료기기, 의약품 또는 디지털의료·건강지원기기로부터 생성되었거나 수집·가공된 데이터를 사용하고 임상시험용 디지털의료기기를 임상시험 대상자에게 직접적으로 사용하지 않는 임상시험(이하 "데이터 임상시험"이라 한다)
2. 제7조제2항 또는 제9조제2항에 따라 제출한 변경관리 계획의 범위에서 실사용 평가를 위한 목적으로 실시하는 임상시험
3. 법 제17조제3항에 따라 우수 관리체계 인증을 받은 디지털의료기기제조업자 또는 디지털의료기기수입업자가 1등급 또는 2등급에 해당하는 독립형 디지털의료기기

소프트웨어에 대하여 실시하는 임상시험
4. 법 제34조제2항에 따라 성능인증을 받은 디지털의료·건강지원기기를 법 제2조제2호 각 목의 어느 하나에 해당하는 목적으로 사용하는 임상시험(「의료법」 제5조에 따라 면허를 받은 의료인이 연구 목적으로 실시하는 경우만 해당한다)
5. 제11조제5호 및 제6호에 따라 디지털의료기기 제조업허가 등의 제외 대상인 디지털의료기기에 대한 안전성 및 유효성을 평가하기 위하여 실시하는 임상시험
6. 그 밖에 시판 중인 디지털의료기기를 사용하는 임상시험으로서 안전성과 직접적으로 관련되지 않는다고 식품의약품안전처장이 정하는 임상시험
④ 법 제9조제3항 전단에서 "총리령으로 정하는 기준"이란 별표 3에 따른 시설과 제조 및 품질관리체계의 기준을 말한다.
⑤ 제1항제1호에 따른 임상시험계획서에 포함되어야 할 사항은 별표 5와 같다.
⑥ 제1항 및 제2항에도 불구하고 법 제39조에 따라 임상시험계획 등에 대하여 사전 검토를 받은 자가 제49조제3항에 따른 사전 검토 결과 통지서를 제출하는 경우에는 제1항 각 호 및 제2항 각 호의 자료 중 사전 검토 결과 적합하다는 판정을 받은 사항에 대한 자료는 제출하지 않을 수 있다.
⑦ 식품의약품안전처장은 제1항에 따라 제출된 임상시험계획 승인신청서를 검토하여 적합하다고 인정하는 경우에는 해당 신청인에게 별지 제13호서식의 디지털의료기기 임상시험계획 승인서를 발급하고, 제2항에 따라 임상시험계획 변경을 승인하는 경우에는 승인서의 변경 및 처분사항란에 변경사항을 적어야 한다.
⑧ 제1항부터 제7항까지에서 규정한 사항 외에 임상시험계획의 승인, 면제되는 자료의 범위, 승인요건·기준 및 절차 등에 관하여 필요한 세부 사항은 식품의약품안전처장이 정하여 고시한다.
제19조(임상적 성능시험계획의 승인 등) ① 법 제10조제1항에 따라 임상적 성능시험계획의 승인을 받으려는 자는 별지 제18호서식의 디지털의료기기 임상적 성능시험계획 승인신청서[「체외진단의료기기법」 제8조제2항에 따른 임상적 성능시험 심사위원회(이하 이 조에서 "임상적 성능시험 심사위원회"라 한다)에서 별도로 정한 서식이 있는 경우에는 그 서식을 말한다]에 다음 각 호의 서류를 첨부하여 식품의약품안전처장 또는 임상적 성능시험 심사위원회에 제출해야 한다. 다만, 제2호부터 제5호까지의 자료는 식품의약품안전처장에게 임상적 성능시험계획의 승인을 받으려는 경우에만 첨부한다.
1. 임상적 성능시험 계획서
2. 임상적 성능시험용 디지털의료기기가 별표 3에 따른 시설과 제조 및 품질관리체계에서 적합하게 제조되고 있음을 증명하는 자료(독립형 디지털의료기기소프트웨어는 제외한다)
3. 임상적 성능시험용 디지털의료기기의 안전성을 검토하기 위한 다음 각 목에 따른 자료

가. 작용원리에 관한 자료
나. 디지털의료기기소프트웨어 검증 및 유효성에 관한 자료
다. 전자적 침해행위로부터의 보호 조치에 관한 자료
라. 제품의 성능 및 안전을 확인하기 위한 시험규격 및 그 설정 근거와 실측값에 관한 자료로서 식품의약품안전처장이 정하여 고시하는 자료(소프트웨어 내장 디지털의료기기만 해당한다)
4. 디지털의료기기의 부분을 구성하는 디지털의료·건강지원기기에 대해서는 법 제34조제2항에 따른 성능인증에 관한 자료(디지털의료기기와 디지털의료·건강지원기기가 조합된 경우만 해당한다)
5. 법 제31조제2항에 따라 디지털융합의약품의 부분을 구성하는 디지털의료기기로 임상시험을 실시하는 경우에는 디지털융합의약품을 구성하는 의약품과 디지털의료기기의 조합적 특성에 관한 자료
② 법 제10조제1항에 따라 승인을 받은 임상적 성능시험계획을 변경하려는 자는 별지 제19호서식의 디지털의료기기 임상적 성능시험계획 변경승인신청서(임상적 성능시험 심사위원회에서 별도로 정한 서식이 있는 경우에는 그 서식을 말한다)에 다음 각 호의 서류를 첨부하여 식품의약품안전처장 또는 임상적 성능시험 심사위원회에 제출해야 한다. 다만, 제2호부터 제5호까지의 자료는 식품의약품안전처장이 고시하는 바에 따라 제출하지 않을 수 있다.
1. 임상적 성능시험 변경계획서
2. 임상적 성능시험용 디지털의료기기가 별표 3에 따른 시설과 제조 및 품질관리 체계에서 적합하게 제조되고 있음을 증명하는 자료(독립형 디지털의료기기소프트웨어는 제외한다)
3. 임상적 성능시험용 디지털의료기기의 안전성을 검토하기 위한 다음 각 목에 따른 자료
가. 작용원리에 관한 자료
나. 디지털의료기기소프트웨어 검증 및 유효성에 관한 자료
다. 전자적 침해행위로부터의 보호 조치에 관한 자료
라. 제품의 성능 및 안전을 확인하기 위한 시험규격 및 그 설정 근거와 실측값에 관한 자료로서 식품의약품안전처장이 정하여 고시하는 자료(소프트웨어 내장 디지털의료기기만 해당한다)
4. 디지털의료기기의 부분을 구성하는 디지털의료·건강지원기기에 대해서는 법 제34조제2항에 따른 성능인증에 관한 자료(디지털의료기기와 디지털의료·건강지원기기가 조합된 경우만 해당한다)
5. 법 제31조제2항에 따라 디지털융합의약품의 부분을 구성하는 디지털의료기기로 임상시험을 실시하는 경우에는 디지털융합의약품을 구성하는 의약품과 디지털의료기기의 조합적 특성에 관한 자료

③ 법 제10조제2항 전단에서 "총리령으로 정하는 기준"이란 별표 3에 따른 시설과 제조 및 품질관리체계를 말한다.
④ 제1항제1호에 따른 임상적 성능시험 계획서에 포함되어야 할 사항은 별표 7과 같다.
⑤ 식품의약품안전처장 또는 임상적 성능시험 심사위원회는 법 제10조제1항에 따른 임상적 성능시험계획의 승인을 위해 필요하다고 인정하는 경우에는 디지털의료기기 관련 기관, 단체 또는 전문가 등에게 의견이나 자료의 제출 등 필요한 협조를 요청할 수 있다.
⑥ 제1항 및 제2항에도 불구하고 법 제39조에 따라 임상적 성능시험계획 등에 대하여 사전 검토를 받은 자가 제49조제3항에 따른 사전 검토 결과 통지서를 제출하는 경우에는 제1항 각 호 및 제2항 각 호의 자료 중 사전 검토 결과 적합 판정을 받은 사항에 대한 자료는 제출하지 않을 수 있다.
⑦ 식품의약품안전처장 또는 임상적 성능시험 심사위원회는 제1항에 따라 제출된 임상적 성능시험계획 승인신청서를 검토하여 적합하다고 인정하는 경우에는 해당 신청인에게 별지 제22호서식의 디지털의료기기 임상적 성능시험계획 승인서(임상적 성능시험 심사위원회에서 별도로 정한 서식이 있는 경우에는 그 서식을 말한다)를 발급하고, 임상적 성능시험계획 변경을 승인하는 경우에는 승인서의 변경 및 처분 사항란에 변경사항을 적어야 한다.
⑧ 제1항부터 제7항까지에서 규정한 사항 외에 임상적 성능시험계획의 승인, 면제되는 자료의 범위, 승인요건·기준 및 절차 등에 관하여 필요한 세부 사항은 식품의약품안전처장이 정하여 고시한다.

제49조(사전 검토의 대상 등) ① 법 제39조제1항(디지털의료제품법 제39조, 허가·신고 등의 사전 검토)에 따른 사전 검토의 대상 및 범위는 다음 각 호와 같다.
1. 디지털의료제품의 분류 및 등급에 관한 자료
2. 변경관리 계획서
3. 임상시험계획 또는 임상적 성능시험계획에 관한 자료
4. 임상시험기관 또는 임상적 성능시험기관 외의 기관 실시 승인에 관한 자료
5. 임상시험 등 평가에 관한 자료
6. 전자적 침해행위로부터의 보호 조치에 관한 자료
7. 디지털의료기기소프트웨어 검증 및 유효성에 관한 자료
8. 전문가용 디지털의료기기소프트웨어에 관한 자료
9. 디지털의료제품의 구성요소에 대한 성능평가에 관한 자료
10. 사용적합성에 관한 자료
11. 디지털의료제품의 성능 및 안전을 확인하기 위한 시험규격 및 그 설정 근거와 실측값에 관한 자료
12. 그 밖에 디지털의료제품에 대한 허가·인증·신고·승인·평가 등에 필요한

자료로서 식품의약품안전처장이 인정하는 자료

② 법 제39조제1항에 따라 이 조 제1항 각 호의 자료에 관하여 사전 검토를 요청하려는 자는 별지 제43호서식의 디지털의료제품 사전 검토 요청서에 해당 자료를 첨부하여 식품의약품안전처장에게 제출해야 한다.

③ 식품의약품안전처장은 제2항에 따른 사전 검토 요청서와 해당 자료를 검토하고 별지 제44호서식의 디지털의료제품 사전 검토 결과 통지서를 발급해야 한다.

④ 제1항부터 제3항까지에서 규정한 사항 외에 사전 검토의 대상·범위, 절차 및 방법 등에 관한 세부 사항은 식품의약품안전처장이 정하여 고시한다.

4. 주요 구성 및 활용 방향

○ 디지털의료기기 전자적 침해행위 보안지침 구성

「디지털의료기기 전자적 침해행위 보안지침」은 「디지털의료제품법」 개정 (법률 제20331호, 2024. 2. 20. 타법개정, 2025. 2. 21. 시행) 및「디지털의료제품법 시행규칙」에 따라 디지털의료기기에 대한 전자적 침해행위를 대응하기 위해 필요한 사항을 규정하기 위함으로 크게 다음과 같이 내용이 구성되어 있다.

가. 보안활동 및 문서화(제2조)

디지털의료기기의 취약점을 지속적으로 감시하고 전자적 침해행위에 대응하기 위한 보안활동 및 문서화에 대한 세부 내용을 마련함

나. 물리적 보안체계(제3조~제5조)

보안 통신, 권한 및 인증 등 물리적 보안체계에 관한 규정을 마련함

다. 기술적 보안체계(제6조~제12조)

파일 및 입력 유효성, 데이터 보안, 암호화 키 관리 등 기술적 보안체계에 관한 규정을 마련함

라. 위험 관리(제13조~제16조)

제품 개발 전주기에 걸쳐 위험 관리 활동에 대한 세부 내용을 마련함

마. 전자적 침해행위의 대응(제17조~제19조)

전자적 침해행위에 대응하기 위한 계획 수립과 방안에 대하여 세부 내용을 마련함

바. 취약점 감시 및 대응(제20조~제22조)

디지털의료기기의 취약점을 감시하고 대응하기 위한 세부 내용을 마련



❍ 디지털의료기기 전자적 침해행위 보안지침 활용 방향

「디지털의료기기 전자적 침해행위 보안지침」은 제품에 대한 보안 요구사항 기준을 정의한 것이 아니라 디지털의료기기 제조·운영 전 과정에서의 보안 요구사항을 종합적으로 규정한 관리 지침으로서, 디지털의료기기 제조업자등의 내부 보안체계를 문서화하고 이를 관련 허가·심사 제도(디지털의료기기 제조 및 품질관리 심사, 우수 관리체계 인증 심사, 임상시험, 임상적 성능시험, 인증·신고 등)에 활용할 수 있도록 설계되어 있다. 본 보안지침은 크게 아래의 실질적인 목적으로서 활용이 가능하다.

◆ **(디지털의료기기 제조 및 품질관리 심사)** 디지털의료기기제조업자의 품질경영시스템 내에서 '보안'이 어떻게 실무에 적용되었으며 실현 가능한 수준인지를 입증하기 위한 수단으로서 보안지침을 고려하여 보안 업무를 수행하기 위한 **절차서를 필요**로 함

* 디지털의료기기 제조 및 품질관리(GMP) 심사 제출 서류 중 '디지털의료기기소프트웨어' 분류에 한하여 '제품표준서 및 전자적 침해행위 보안 관련 절차서' 제출을 의무화하고 있음

◆ **(우수 관리체계 인증 심사)** 디지털의료기기제조업자등이 우수한 품질관리체계(품질관리, 안전관리, 전자적 침해행위 대응체계, AI/ML 제어조치)를 보유하여 우수하다고 판단될 경우 부여하는 인증 제도로서, 인증 유효 기간(3년) 동안 제품 허가 시 제출자료 특례(GMP 적합 판정 간주, 소프트웨어 검증 및 유효성, 전자적 침해행위 보호조치, 사용 적합성 평가)를 제공하며 이를 위해 인증 심사 시, 보안지침에 대한 자료 일체(보안 업무에 대한 절차서 및 보안활동이 수행되었음을 입증하는 자료)를 필요로 함

* 우수 관리체계 인증 심사 제출 서류 중 **'전자적 침해행위로부터의 보호 조치에 관한 자료'** 제출을 **의무화**하고 있음

[디지털의료제품 허가·인증·신고·심사 및 평가 등에 관한 규정]

제25조(첨부서류의 면제 등)

① 시행규칙 제7조제4항 및 시행규칙 제25조제1항단서 및 같은 조 제4항에 따라 첨부서류를 제출하지 않을 수 있는 세부 범위는 다음과 같다.

1. 법 제16조에 따라 우수 관리체계 인증을 받은 자가 **2등급에 해당하는 독립형 디지털의료기기 소프트웨어**에 대하여 인증을 받으려는 경우로서 시행규칙 제31조제4항에 따른 우수 관리체계 인증서를 제출하는 경우에는 제24조제1항제3호(디지털의료기기소프트웨어 검증 및 유효성에 관한 자료), 제5호(전자적 침해행위로부터의 보호 조치에 관한 자료) 및 제6호(사용적합성에 관한 자료)에 따른 자료

◆ **(임상시험, 임상적 성능시험)** 임상시험 또는 임상적 성능시험 계획 승인을 위해 제출해야 하는 서류 중 기술적 특성에 관한 자료를 제출해야 하며 제출 시, 보안지침에 대한 자료 일체(보안 업무에 대한 절차서 및 보안활동이 수행되었음을 입증하는 자료)를 필요로 함

* 임상시험 또는 임상적 성능시험 계획 승인을 위한 제출 서류 중 '전자적 침해행위로부터의 보호 조치에 관한 자료' 제출을 의무화하고 있음

◆ **(허가 · 심사)** 디지털의료기기 제조허가의 첨부서류에 '전자적 침해행위로부터의 보호 조치에 관한 자료' 가 명시되어 있음

■ 디지털의료제품법 시행규칙 [별표2]

[디지털의료기기 제조허가의 첨부서류(제7조제1항제3호 관련)]

1. 디지털의료기기(독립형 디지털의료기기소프트웨어의 경우는 제외한다): 다음의 자료
   가. 사용목적 및 작용원리에 관한 자료
   나. 국내외 현황 및 개발경위 등에 관한 자료
   다. 디지털의료기기소프트웨어 검증 및 유효성에 관한 자료
   라. 임상시험 등 평가에 관한 자료
   마. 전자적 침해행위로부터의 보호 조치에 관한 자료
   바. 사용 적합성에 관한 자료
   사. 전문가용 디지털의료기기소프트웨어에 관한 자료(전문가용 디지털의료기기소프트웨어로 표시하려는 경우만 해당한다)
   아. 제품의 성능 및 안전을 확인하기 위한 시험규격 및 설정 근거와 실측값에 관한 자료로서 식품의약품안전처장이 정하여 고시하는 자료
2. 독립형 디지털의료기기소프트웨어의 경우: 제1호가목부터 사목까지의 자료

또한, 디지털의료제품 허가·인증·신고·심사 및 평가 등에 관한 규정(시행 2025.4.15., 식약처 고시 제2025-25호) 제26조(첨부서류의 요건)제1항제5호에 세부 사항을 다루고 있으며, 물리적 보안 체계 및 기술적 보안 체계에서 제시하는 **조항(제3조~제12조)에** 대해 디지털의료기기 허가·심사 시 검토 항목으로 정의하고 있음 (의료기기 사이버보안 업무설명회, 17차 자료, 2025.7.17.)

그 외, 인증 시 제출하는 서류에서 독립형 디지털의료기기소프트웨어 및 소프트웨어 내장 의료기기에 대해 **'전자적 침해행위로부터의 보호 조치에 관한 자료'**를 명시하고 있음

○ 디지털의료기기 전자적 침해행위 보안지침의 의무/권고 사항 파악

- 본 보안지침의 조항에서 기술한 문구 중 **"~하여야 한다"** 는 반드시 따라야 하는 **의무 사항**이며, **"~할 수 있다"** 는 반드시 따라야 하는 사항은 아니지만 상황에 따라 할 수 있지만 하지 않아도 문제가 발생하지 않는 **권고 사항**이다.

II 보안지침 실무 적용 가이드

1. 보안지침 개요

❑ 디지털의료기기 전자적 침해행위 보안지침 개요

○ 「디지털의료제품법」 제14조에 따라 디지털의료기기를 전자적 침해행위로부터 안전하게 보호할 수 있도록 디지털의료기기제조업자등이 이에 대응하기 위한 세부사항을 규정함

❑ IMDRF 및 『의료기기의 사이버보안 허가·심사 가이드라인』과의 관계

○ 본 보안지침은 IMDRF, FDA 가이드라인 및 관련 표준 등 총 49종의 자료를 참고하여 마련하였으며, 특히 IMDRF 의료기기 사이버보안 원칙 및 실무*(2020)과 국내 『의료기기의 사이버보안 허가·심사 가이드라인[2]』에서 제공하는 보안 요구사항과의 관계 또한 부합하고 있음을 제시한다.

* 특히, '의료기기 사이버보안 원칙 및 실무' 가이드라인은 'Principles and Practices for Medical Device Cybersecurity (IMDRF/CYBER WG/N60)[14]' 라는 IMDRF 공식 가이드라인으로 사이버보안, 무선 통신, 네트워크 연결 등 현재 의료기기 환경에서의 환자 안전에 영향을 주는 위험을 완화하기 위한 목적으로, 의료기기 설계 시 고려할 엄선된 설계 원칙으로 시큐어 통신, 데이터 보호, 기기 무결성, 사용자 인증, 소프트웨어 유지관리, 물리적 접근, 신뢰성 및 가용성을 제시하고 있다.

< IMDRF(International Medical Device Regulators Forum) 국제의료기기규제당국자포럼>

- 의료기기 국제조화를 위해 구성된 선진 10개국 규제 당국 간 협의체로 2011년도에 설립

※ 회원국(12개국) : 한국, 호주, 브라질, 캐나다, 중국, 유럽연합(EU), 일본, 러시아, 싱가포르, 미국, 스위스, 영국

IMDRF 사이버보안 요구사항[14]		의료기기의 사이버보안 허가·심사 가이드라인 보안 요구사항[2]	전자적 침해행위 보안지침 (제3장 및 제4장)	
보안통신	*The manufacturer should consider how the device would interface with other devices or networks. Interfaces may include hardwired connections and/or wireless communications. Examples of interface methods include Wi-Fi, Ethernet, Bluetooth, USB, etc.* 제조자는 의료기기가 다른 기기나 네트워크와 어떻게 접속(유·무선 통신 등)하여야 할지를 고려하여야 한다. ※ 예: Wi-Fi, 이더넷, 블루투스, USB 등	[RA-04] 네트워크 및 보안 구성 설정	제4조 보안통신	유・무선 네트워크 사용 시, 디지털 의료기기 및 그 운영 환경의 네트워크 보안 설정
		[RA-05] 불필요한 기능 비활성화	제7조 보안 모니터링 및 대응	불필요한 서비스(인터페이스) 등 비활성화, 보안 모니터링 기능 구현 등 대응 방안
	The manufacturer should consider design features that validate all inputs (not just external) and take into account communication with devices and environments that only support less secure communication (e.g., a device connected to a home network or a legacy device). 제조자는 내·외부의 모든 입력에 대한 유효성을 확인하는 설계 특성을 고려하여야 하며, 보안이 취약한 통신(예. 가정용 네트워크 혹은 기존 기기)만을 지원하는 기기 및 환경에서 이루어지는 통신도 고려한다.	[UC-02] 모바일 코드 사용 통제	제7조 파일 및 입력 유효성	디지털의료기기에서 작동 가능한 실행 파일 업로드 방지

IMDRF 사이버보안 요구사항[14]		의료기기의 사이버보안 허가·심사 가이드라인 보안 요구사항[2]	전자적 침해행위 보안지침 (제3장 및 제4장)	
보안통신	*The manufacturer should consider how data transfer to and from the device is secured to prevent unauthorized access, modification, or replay. For example, manufacturers should determine: how the communications between devices/systems will authenticate each other; if encryption is required; how unauthorized replay of previously transmitted commands or data will be prevented; and if terminating communication sessions after a pre-defined time is appropriate.* 제조자는 비인가 접근/변경/반복을 방지하기 위한 의료기기의 보안이 보장된(secured) 데이터 송·수신 방법을 고려하여야 한다. ※ 예: 기기/시스템 간 통신 시 상호인증방법, 암호화 필요 여부, 과거에 전송된 명령어 및 데이터의 비인가 반복에 대한 방지, 사전에 정의된 통신 종료 시점의 적절성 여부 등	[SI-05] 입력값 검증	제7조 파일 및 입력 유효성	입력 데이터 검증, 버퍼 초과 오류 검증 등 입력 정보의 유효성 검증
		[UC-03] 세션 잠금	제5조 권한 및 인증	세션 종료, 중복 로그인 방지 등 로그인 세션 및 쿠키 설정
		[SI-01] 통신에 대한 무결성 보장	제4조 보안 통신	보안을 고려한 내·외부 통신망(통신 구간 암호화, 암호화 프로토콜 사용 등)구성 방안
			제8조 데이터 보안	시스템 간 데이터 송·수신 시, 데이터 암호화 또는 보안 통신

IMDRF 사이버보안 요구사항[14]		의료기기의 사이버보안 허가·심사 가이드라인 보안 요구사항[2]	전자적 침해행위 보안지침 (제3장 및 제4장)	
데이터 보호	*The manufacturer should consider if safety-related data that is stored on or transferred to/from the device requires some level of protection such as encryption. For example, passwords should be stored as cryptographically secure hashes.* 제조자는 안전(safety)과 관련된 데이터가 저장되거나 기기와 송·수신될 때 암호화와 같은 일정 수준의 보호가 요구되는지 고려하여야 한다. ※ 예: 비밀번호(passwords)는 암호화된 보안(secure)이 확보된 해시(hash)로 저장되어야 함	[DC-01] 정보에 대한 기밀성 보장	제4조 보안통신	유·무선 네트워크 사용 시, 디지털 의료기기 및 그 운영 환경의 네트워크 보안 설정
			제6조 기술적 보안	디지털의료기기제조업자등은 개인정보 또는 개인정보가 포함된 데이터 취득 또는 보관 시, 개인정보 보호를 위한 조치를 하여야 함
			제8조 데이터보안	시스템 간 데이터 송·수신 시, 데이터 암호화 또는 보안 통신
		[DC-02] 보건의료정보 비식별화	제6조 기술적보안	디지털의료기기제조업자등은 개인정보 또는 개인정보가 포함된 데이터 취득 또는 보관 시, 개인정보 보호를 위한 조치를 하여야 함
			제8조 데이터 보안	시스템 간 데이터 송수신 시, 데이터 암호화 또는 보안 통신
		[DC-03] 안전한 암호화 사용	제4조 보안통신	유·무선 네트워크 사용 시, 디지털 의료기기 및 그 운영 환경의 네트워크 보안 설정

IMDRF 사이버보안 요구사항[14]		의료기기의 사이버보안 허가·심사 가이드라인 보안 요구사항[2]	전자적 침해행위 보안지침 (제3장 및 제4장)	
데이터 보호	*The manufacturer should consider if safety-related data that is stored on or transferred to/from the device requires some level of protection such as encryption. For example, passwords should be stored as cryptographically secure hashes.* 제조자는 안전(safety)과 관련된 데이터가 저장되거나 기기와 송·수신될 때 암호화와 같은 일정 수준의 보호가 요구되는지 고려하여야 한다. ※ 예: 비밀번호(passwords)는 암호화된 보안(secure)이 확보된 해시(hash)로 저장되어야 함	[DC-03] 안전한 암호화 사용	제6조 기술적 보안	디지털의료기기제조업자등은 개인정보 또는 개인정보가 포함된 데이터 취득 또는 보관 시, 개인정보 보호를 위한 조치를 하여야 함
			제8조 데이터보안	국내·외 암호화 알고리즘 사용 시, 널리 권고되는 암호화 및 해시 알고리즘 사용
	The manufacturer should consider if confidentiality risk control measures are required to protect message control/sequfields in communication protocols or to prevent the compromise of cryptographic keying materials. 제조자는 기밀성에 대한 위험 통제 수단이 요구될 때, 통신 프로토콜의 컨트롤(control)/시퀀싱(sequencing) 필드의 메시지를 보호하거나 암호화의 키 관련 자료가 손상되는 것을 방지하도록 고려하여야 한다.	[DC-03] 안전한 암호화 사용	제8조 데이터보안	국내·외 암호화 알고리즘 사용 시, 널리 권고되는 암호화 및 해시 알고리즘 사용
			제9조 암호화 키 관리	암호화 키와 암호화된 데이터와의 분리 조치 방안, 암호화 키 유효 기간 설정 등 암호화 키 보안 조치

IMDRF 사이버보안 요구사항[14]		의료기기의 사이버보안 허가·심사 가이드라인 보안 요구사항[2]	전자적 침해행위 보안지침 (제3장 및 제4장)	
기기 무결성	*The manufacturer should evaluate the system-level architecture to determine if design features are necessary to ensure data non-repudiation (e.g., supporting an audit logging function).* 제조자는 데이터 부인 방지(non-repudiation)를 보장하기 위한 설계 특성이 필요한지를 결정하기 위해 시스템 레벨에서의 아키텍쳐를 평가하여야 한다. ※ 예: 감사 로그 기록 기능 제공	[UC-04] 감사기록 생성	제11조 보안 모니터링 및 대응	로그 및 백업/복구 등 관리 방안
		[UC-05] 감사 처리 실패 대응		로그 및 백업/복구 등 관리 방안
		[UC-06] 타임스탬프		로그 및 백업/복구 등 관리 방안
		[UC-07] 부인방지		로그 및 백업/복구 등 관리 방안
		[TRE-01] 감사로그에 대한 비인가된 접근 제한		로그 및 백업/복구 등 관리 방안
	The manufacturer should consider risks to the integrity of the device such as unauthorized modifications to the device software. 제조자는 기기 소프트웨어의 비인가된 변경과 같은 기기의 무결성에 대한 위험을 고려해야 한다.	[SI-03] 보안 기능 검증	제10조 유지관리	디지털의료기기 자체 또는 연관 소프트웨어의 비인가된 변경에 대한 무결성 검증 방안
			제11조 보안 모니터링 및 대응	로그 및 백업/복구 등 관리 방안

IMDRF 사이버보안 요구사항[14]		의료기기의 사이버보안 허가·심사 가이드라인 보안 요구사항[2]	전자적 침해행위 보안지침 (제3장 및 제4장)	
기기 무결성	*The manufacturer should consider risks to the integrity of the device such as unauthorized modifications to the device software.* 제조자는 기기 소프트웨어의 비인가된 변경과 같은 기기의 무결성에 대한 위험을 고려해야 한다.	[SI-04] 소프트웨어 및 정보에 대한 무결성 점검	제10조 유지관리	디지털의료기기 자체 또는 연관 소프트웨어(운영체제, 제3자 소프트웨어, 오픈소스 등) 업데이트 파일에 대한 안전성 및 무결성 검증
		[SI-11] 부트 프로세스 무결성 검증		디지털의료기기 자체 또는 연관 소프트웨어의 비인가된 변경에 대한 무결성 검증 방안
	The manufacturer should consider controls such as anti-malware to prevent viruses, spyware, ransomware, and other forms of malicious code of being executed on the device. 제조자는 바이러스, 스파이웨어, 랜섬웨어 등 기기에서 실행될 수 있는 악성코드를 막기 위해 안티 멀웨어 프로그램과 같은 통제조치를 고려하여야 한다.	[SI-02] 악성코드로부터 보호	제11조 보안 모니터링 및 대응	컴퓨터 등 최신 버전의 안티바이러스 소프트웨어 설치 여부
사용자 인증	*The manufacturer should consider user access controls that validate who can use the device or allows granting of privileges to different user roles or allow users access in an emergency. Additionally, the same credentials should not be shared across devices and customers. Examples of authentication or access authorization include passwords, hardware keys, or biometrics, or a signal of intent that cannot be produced by another device.*	[IA-01] 사용자 식별 및 인증	제5조 권한 및 인증	사용자 접근 통제 강화 및 계정별 권한 설정

IMDRF 사이버보안 요구사항[14]		의료기기의 사이버보안 허가·심사 가이드라인 보안 요구사항[2]	전자적 침해행위 보안지침 (제3장 및 제4장)	
사용자 인증	*제조자는 기기의 사용이 입증된 사용자이거나, 다른 역할의 사용자에게 사용권한을 부여를 허용하거나, 응급상황에서 접근을 허용하는 사용자 접근통제에 대해 고려하여야 한다. 추가적으로 동일한 자격증명은 기기와 고객들에게 공유되지 않아야 한다.* *※ 접근통제의 예: 비밀번호, 하드웨어 키, 생체인증 등*	[IA-02] 계정관리	제5조 권한 및 인증	사용자 접근 통제 강화 및 계정별 권한 설정
		[IA-03] 식별정보 관리	제5조 권한 및 인증	사용자 접근 통제 강화 및 계정별 권한 설정
		[IA-04] 인증정보 관리	제5조 권한 및 인증	사용자 접근 통제 강화 및 계정별 권한 설정
		[IA-05] 비밀번호 강도 설정	제5조 권한 및 인증	사용자 접근 통제 강화 및 계정별 권한 설정
			제8조 데이터 보안	국내·외 암호화 알고리즘 사용 시, 널리 권고되는 암호화 및 해시 알고리즘 사용
		[IA-06] 인증정보에 대한 피드백	제5조 권한 및 인증	사용자 접근 통제 강화 및 계정별 권한 설정
		[IA-07] 연속적인 로그인 시도 실패 시 로그인 제한	제5조 권한 및 인증	사용자 접근 통제 강화 및 계정별 권한 설정
		[UC-01] 권한 부여	제5조 권한 및 인증	사용자 접근 통제 강화 및 계정별 권한 설정

IMDRF 사이버보안 요구사항[14]		의료기기의 사이버보안 허가·심사 가이드라인 보안 요구사항[2]	전자적 침해행위 보안지침 (제3장 및 제4장)	
	The manufacturer should establish and communicate a process for implementation and deployment of regular updates. 제조자는 주기적인 업데이트의 구현과 배포를 위한 수행 절차를 수립하고 통보하여야 한다.	[SI-08] 업데이트	제10조 유지관리	디지털의료기기 자체 또는 연관 소프트웨어(운영체제, 제3자 소프트웨어, 오픈소스 등) 업데이트 파일에 대한 안전성 및 무결성 검증
소프트웨어 유지보수	*The manufacturer should consider how operating system software, third-party software, or open source software will be updated or controlled. The manufacturer should also plan how to respond to software updates or outdated operating environments outside of their control (e.g. medical device software running on an unsecure operating system version).* 제조자는 운영체제(OS) 소프트웨어, 제3자 소프트웨어, 오픈소스 소프트웨어가 업데이트나 통제될 경우에 대해 고려하여야 한다. 또한 제조자는 외부의 통제에 의한 소프트웨어의 업데이트나 운영환경 만료에 대한 대응 계획을 수립하여야 한다. ※ 예: 보안이 보장되지 않은(unsecure) 운영체제 버전에서 운영되는 의료기기 소프트웨어	[SI-08] 업데이트	제10조 유지관리	디지털의료기기 자체 또는 연관 소프트웨어(운영체제, 제3자 소프트웨어, 오픈소스 등) 업데이트 파일에 대한 안전성 및 무결성 검증

IMDRF 사이버보안 요구사항[14]		의료기기의 사이버보안 허가·심사 가이드라인 보안 요구사항[2]	전자적 침해행위 보안지침 (제3장 및 제4장)	
소프트웨어 유지보수	*The manufacturer should consider how the device will be updated to secure it against newly discovered cybersecurity vulnerabilities. For example, consideration could be given to whether updates will require user intervention or be initiated by the device and how the update can be validated to ensure it has no adverse effect on the safety and performance of the device.* 제조자는 새로운 사이버보안 취약성에 대응할 의료기기 업데이트 방안을 고려하여야 한다. ※ 예: 업데이트 시 사용자 개입/자동 업데이트 여부, 기기의 안전(safety)과 성능에 영향을 보장할 수 있는 업데이트 유효성 검증	[SI-08] 업데이트	제10조 유지관리	디지털의료기기 자체 또는 연관 소프트웨어(운영체제, 제3자 소프트웨어, 오픈소스 등) 업데이트 파일에 대한 안전성 및 무결성 검증
	The manufacturer should consider what connections will be required to conduct updates and the authenticity of the connection or update through the use of code signing or other similar methods. 제조자는 업데이트의 수행하기 위해 어떤 연결이 필요한지와 코드 서명 및 기타 비슷한 수단을 통한 연결이나 업데이트의 진본성을 고려하여야 한다.	SI-09 업데이트에 대한 진본성 및 무결성 검증	제10조 유지관리	- 디지털의료기기 자체 또는 연관 소프트웨어(운영체제, 제3자 소프트웨어, 오픈소스 등) 업데이트 파일에 대한 안전성 및 무결성 검증 - 디지털의료기기 업데이트 실패에 대한 대응(복구 기능 제공 등) 방안

IMDRF 사이버보안 요구사항[14]		의료기기의 사이버보안 허가·심사 가이드라인 보안 요구사항[2]	전자적 침해행위 보안지침 (제3장 및 제4장)	
물리적 접근	*The manufacturer should consider controls to prevent an unauthorized person from accessing the device. For example, controls could include physical locks or physically restricting access to ports, or not allowing access with a physical cable without requiring authentication.* 제조자는 비인가된 개인이 의료기기에 접근하는 것을 방지하기 위한 통제수단을 고려하여야 한다. ※ 예: 물리적 잠금 혹은 포트(port) 접근의 물리적 제한, 인증이 필요 없는 물리적 케이블의 접근제한 등	[IA-08] 시스템 사용 알림 메시지	제5조 권한 및 인증	사용자 접근 통제 강화 및 계정별 권한 설정
		[IA-08] 시스템 사용 알림 메시지	제3조 물리적보안	디지털의료기기를 운영하는 물리적 보안 환경을 분석하고 각종 물리적 위협으로부터 보호할 수 있도록 대책을 마련하여야 함
		[SI-10] 물리적 변조 방지	제4조 보안 통신	유·무선 네트워크 사용 시, 디지털 의료기기 및 그 운영 환경의 네트워크 보안 설정
신뢰성 및 가용성	*The manufacturer should consider design features that will allow the device to detect, resist, respond and recover from cybersecurity attacks in order to maintain its essential performance.* 제조자는 의료기기가 필수 성능을 유지하기 위해 사이버보안 공격을 탐지, 저항, 대응 및 복구하도록 허용하는 설계 특성을 고려하여야 한다.	[UC-04] 감사기록 생성	제11조 보안 모니터링 및 대응	로그 및 백업/복구 등 관리 방안
		[SI-06] 오류 시 사전 결정된 상태로 출력	제11조 보안 모니터링 및 대응	불필요한 서비스(인터페이스) 등 비활성화, 보안 모니터링 기능 구현 등 대응 방안
		[SI-07] 오류 처리	제5조 권한 및 인증	사용자 접근 통제 강화 및 계정별 권한 설정

IMDRF 사이버보안 요구사항[14]		의료기기의 사이버보안 허가·심사 가이드라인 보안 요구사항[2]	전자적 침해행위 보안지침 (제3장 및 제4장)	
신뢰성 및 가용성	*The manufacturer should consider design features that will allow the device to detect, resist, respond and recover from cybersecurity attacks in order to maintain its essential performance.* 제조자는 의료기기가 필수 성능을 유지하기 위해 사이버보안 공격을 탐지, 저항, 대응 및 복구하도록 허용하는 설계 특성을 고려하여야 한다.	[SI-07] 오류 처리	제11조 보안 모니터링 및 대응	불필요한 서비스(인터페이스) 등 비활성화, 보안 모니터링 기능 구현 등 대응 방안
		[TRE-01] 감사로그에 대한 비인가된 접근 제한	제11조 보안 모니터링 및 대응	로그 및 백업/복구 등 관리 방안
		[RA-01] 서비스 거부(Denial of Service,DoS)방지	제11조 보안 모니터링 및 대응	불필요한 서비스(인터페이스) 등 비활성화, 보안 모니터링 기능 구현 등 대응 방안
		[RA-02] 의료기기 백업		소스코드 및 주요 운영 데이터 백업 및 복구 방안
		[RA-03] 의료기기 복구 및 재구성		소스코드 및 주요 운영 데이터 백업 및 복구 방안
-	-	-	제12조 인공지능 보안	인공지능 기술 적용 디지털의료기기의 인공지능 보안방안 마련(데이터 공격 및 위변조 방어 등)

❑ 보안 활동의 주체

○ 보안 활동의 주체는 크게 3가지로, 디지털의료기기제조업자등, 의료서비스제공자, 사용자로 구분할 수 있다.

- **(디지털의료기기제조업자등)** 디지털의료기기의 제조 또는 수입을 사업으로 하는 모든 주체로서, 디지털의료기기를 설계, 개발, 출시, 지원 등의 업무를 담당하는 디지털의료기기제조업체(MDM, Medical Device Manufactures) 뿐만 아니라 디지털의료기기소프트웨어의 유지·관리업무를 위탁받은 자(조직)을 포함한다.
- **(의료서비스제공자)** 환자에게 진단 또는 치료를 목적으로 의료서비스를 제공하는 의료인 및 조직을 의미하며, 디지털의료기기를 통해 의료서비스를 제공하는 자(조직)를 의미한다.
- **(사용자)** 디지털의료기기를 이용하는 사용자(예: 환자, 간병인 등)로서 제품을 안전하게 사용할 수 있어야 한다.

❑ 보안 대책 대상

○ 보안 지침은 디지털의료기기 및 그 운영 환경에서 전자적 침해행위로부터 안전하게 보호하도록 요구하고 있으며 디지털의료기기 자체의 보안(설계·개발·유지보수 등)에만 국한되지 않고 실제 디지털의료기기가 운영되는 환경에서도 보안 위험을 고려하여 조치하도록 규정하고 있다.

- **(디지털의료기기)** 보안지침에서 요구하는 물리적 보안 대책, 기술적 보안 대책 등을 디지털의료기기에서 직접 제공한다.
- **(운영환경)** 보안지침에서 요구하는 물리적 보안 대책, 기술적 보안 대책 등을 디지털의료기기의 의도된 목적에 따라 의도된 환경에서 안전하게 사용될 수 있도록 운영환경의 보안설정 및 구성을 통해 제공한다.

<디지털의료기기와 운영환경에서의 보안대책>

- 디지털의료기기에서의 보안 대책 예시

· (디지털의료기기 하드웨어) 보안 나사(비표준 헤드 유형) 등

· (디지털의료기기 소프트웨어) 암호화 통신, 데이터 보안, 암호화 키 보안, 인공지능 보안 등

- 운영환경에서의 보안 대책 예시

· (물리적 환경) 디지털의료기기가 설치 및 운영되는 물리적 환경의 보안설정 및 구성(출입문, 잠금장치, 출입카드, 생체 인식 시스템, CCTV 등)을 통해 물리적 보안 대책 제공

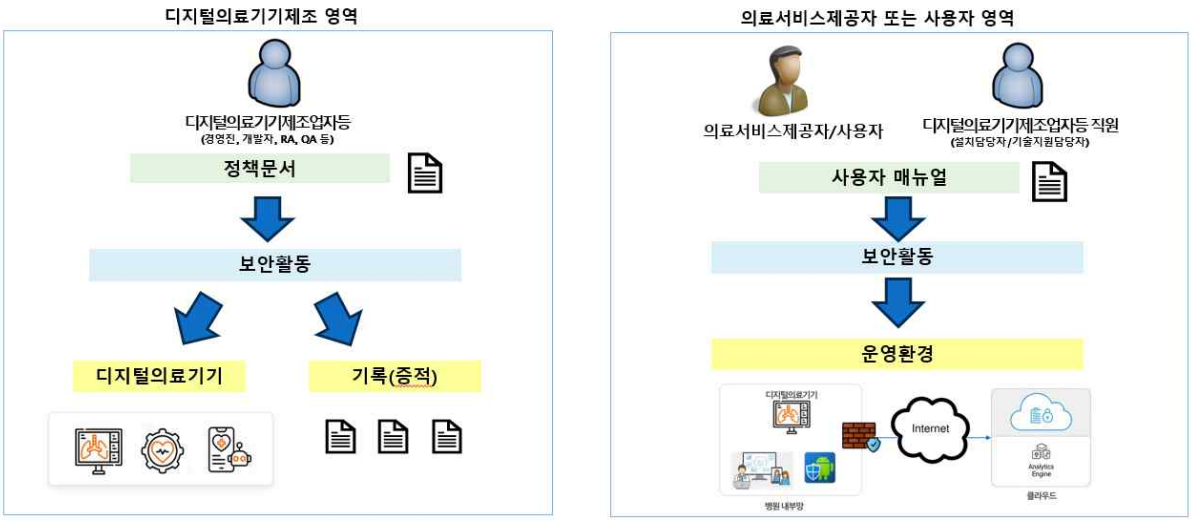
· (하드웨어) 디지털의료기기가 설치 및 운영되는 하드웨어에서 물리적·기술적 보안 대책 제공

· (연동되는 기기 및 소프트웨어) 디지털의료기기와 연동되어 운영되는 기기 및 소프트웨어에서 기술적 보안 대책 제공

❑ 보안 활동 수행 방법

❍ 보안 활동을 수행하기 위한 방법은 디지털의료기기제조영역과 의료서비스제공자 또는 사용자 영역으로 구분할 수 있다.

<보안 활동 수행 방법(예시)>



- 디지털의료기기제조업자등은 보안 업무 수행을 위해 정책 문서를 작성하고 이에 따라 보안 활동을 수행해야 한다. 수행 결과는 기록으로 남기고 디지털의료기기에 적용(패치, 업데이트 등)되어야 한다.

- 의료서비스제공자 또는 사용자는 전자적 침해행위로부터의 보호를 위한 주의사항을 확인할 수 있는 ‘사용자 매뉴얼’을 기반으로 정의된 보안

활동을 수행하여야 하며, 디지털의료기기제조업자등의 설치 담당자 및 기술지원 담당자 또한 사용자 매뉴얼, 별도의 기술문서 등을 기반으로 보안 활동을 수행하여야 한다.

○ 본 가이드라인은 보안 활동의 영역, 활동 주체, 활동에 필요한 입력/출력(결과)물을 구분하여 설명하고자 하며, 각 조항에서 언급한 보안 활동의 영역과 활동 주체, 활동에 필요한 사항들을 충분히 확인하여 실무에 적용하는 것을 권고한다.

- 또한, 의료기기 제품 수명 전주기(Total Product Life Cycle, TPLC)의 모든 단계에 걸쳐 보안 위협 및 취약점과 관련된 위험을 고려해야 하므로 시판 전(Pre-market)과 시판 후(Post-market) 보안활동으로 구분된다.

구분		시판 전 (Pre-market)	시판 후 (Post-market)
정의		디지털의료기기가 시장에 출시되어 사용되기 전까지의 모든 활동 단계(설계, 개발, 시험, 허가/인증 등)	디지털의료기기가 시장에 출시되어 실제로 의료 현장이나 소비자(사용자)에게 사용되기 시작한 이후의 모든 활동 단계 (설치, 운영, 유지관리, 보안 모니터링 및 대응)
보안활동 영역		디지털의료기기제조영역	의료서비스제공자 또는 사용자 영역
보안활동 주체		디지털의료기기제조업자등의 경영진, 개발 및 제조 담당자 등 실무자	의료서비스제공자 또는 사용자 및 디지털의료기기제조업자등의 직원 *(설치 담당자, 기술지원 담당자)*
보안활동 수행 결과	문서	**(정책문서)** 보안업무에 대한 정책문서(절차서, 지침서 및 기준서 등) 수립 및 작성	**(사용자 매뉴얼)** 의료서비스제공자 또는 사용자가 전자적 침해행위로부터의 보호를 위한 주의사항을 확인할 수 있는 사용자 매뉴얼
	기록	정책문서에 따라 보안활동이 수행되었음을 입증하는 자료 *(설계문서, 보고서, 위험관리 문서, 보안 테스트 문서 등)*	시판 후 정책문서에 따라 보안활동이 수행되었음을 입증하는 자료 *(납품확인서, 보고서, 안내문 등)*
	디지털 의료 기기	디지털의료기기 개발 및 제조	침해행위 발생 또는 보안 모니터링을 통해 확인된 취약점을 해결하기 위한 디지털의료기기 패치, 업데이트 등

2. 보안지침 조항별 실무 가이드

제1조(목적)

이 지침은 「디지털의료제품법」 제14조 및 제32조에 따라 디지털의료기기를 전자적 침해행위로부터 안전하게 보호하기 위하여 디지털의료기기의 취약점을 지속적으로 감시하고 전자적 침해행위에 대응하는 물리적 · 기술적 관리체계 구축에 필요한 사항을 규정함을 목적으로 한다.

❑ 보안지침의 목적

○ 본 보안지침은 디지털의료기기제조업자등이 제조 또는 수입한 디지털의료기기를 전자적 침해행위로부터 안전하게 보호하기 위한 일련의 검증, 보안 활동을 수행함으로써 전자적 침해행위에 대응하기 위해 필요한 사항들을 규정함을 목적으로 한다.

제2조(보안 활동의 문서화)

「디지털의료제품법」 제14조제2항에 따른 디지털의료기기제조업자등(이하 “디지털의료기기제조업자등”이라 한다)은 디지털의료기기(디지털의료기기를 구성하는 액세서리, 전자 인터페이스 및 구성품을 포함한다. 이하 같다)를 전자적 침해행위로부터 안전하게 보호하기 위하여 동 지침을 고려하여 다음 각 호의 보안 업무를 수행하고, 이를 문서화하여야 한다.

1. 물리적 · 기술적 보안 체계 수립
2. 전자적 침해행위 대응
3. 위험 관리, 개발 및 검증, 레거시 관리 등 보안 활동
4. 침해사고 대응 및 취약점 감시

❑ 보안 체계 수립 및 보안 업무 수행

○ 디지털의료기기제조업자등은 물리적·기술적 보안 체계 수립, 전자적 침해행위에 대한 디지털의료기기 대상 실무적 대응 및 보안 활동, 침해사고 대응 및 취약점 감시 관리 활동 등을 수행하고, 이를 문서화하여야 한다.

- 디지털의료기기제조업자등은 디지털의료기기를 전자적 침해행위로부터 안전하게 보호하기 위하여 보안 업무에 필요한 세부적인 방법, 절차, 주기 등에 대한 절차를 수립하여 문서화하고 이를 관리하여야 한다.
- 디지털의료기기제조업자등은 절차서, 지침서 및 기준서 등과 같은 품질 문서를 기반으로 보안 업무를 수행하고, 수행 이력을 문서로 남길 수 있는 문서 양식을 마련하여야 한다.

❑ 보안 업무 담당자의 활동

○ 보안 업무를 수행하는 담당자는 물리적·기술적 보안 체계 수립과 더불어 전자적 침해행위에 대한 실무적 대응, 보안 활동, 침해사고 대응 및 취약점 감시 관리 활동 등을 수행하여야 한다.

- **(보안 체계 수립)** 디지털의료기기가 운영될 환경을 사전에 파악하여 물리적 보안 구성, 기술적 보안 구성 등에 대해 분석하고 물리적·기술적 요건을 자체적으로 구성하여 적절한 보안 환경이 조성되었는지를 판단하여 대응할 수 있는 체계를 수립하여야 한다.
- **(전자적 침해행위 대응)** 디지털의료기기 자체 또는 그 운영 환경에서의 전자적 침해행위가 발생했을 경우 이에 대한 인지, 신고, 조치와 같은 대응 방안과 제품 사용의 연속성을 보장하기 위한 계획 등을 대비하기 위한 방안을 마련하여야 한다.
- **(보안 활동)** 제품 수명 전주기에 걸친 위험 관리 활동과 보안을 고려한 개발 및 검증 활동, 레거시 관리 활동, 소프트웨어 구성요소 명세서 관리 활동 등을 계획하고 수행에 대한 책임을 보장하여야 한다.
- **(침해사고 대응 관리)** 디지털의료기기 자체 또는 그 운영 환경에서의 침해행위 대응을 위한 신고, 조치, 대응팀 구성, 훈련 방안 등의 대응 계획과 침해행위에 대한 신고 및 조치 방안을 마련하여야 한다.
- **(취약점 감시 관리)** 디지털의료기기의 취약점 감시를 위한 정기적인 보안 모니터링 위한 정기적인 모니터링, 로그 분석 등의 감시 활동과 관련 사항에 대한 절차 마련, 취약점 공개 및 조치 방안을 마련하여야 한다.

< 제2조(보안활동의 문서화) 관련 **주요 점검 사항**>

[주요 확인사항]

- 디지털의료기기제조업자등은 디지털의료기기를 전자적 침해행위로부터 안전하게 보호하기 위하여 보안 업무를 수행하고 관련 내용을 정책문서(보안지침을 준수하기 위한 업무/절차 등을 정의한 문서)에 포함하고 있는가?
- 보안 활동이 포함된 정책문서에 물리적·기술적 보안 체계 수립, 전자적 침해행위 대응, 위험 관리, 개발 및 검증, 레거시 디지털의료기기 관리, 침해사고 대응 관리, 취약점 감시 관리 등이 포함되어 있는가?
- 보안 활동이 포함된 정책문서에 대해 경영진의 승인을 받고, 임직원 및 업무 관련자 등에게 이해하기 쉬운 형태로 제공하고 있는가?

[세부 설명]

- 물리적·기술적 보안 체계 수립에 대한 내용의 문서화
- 전자적 침해행위 대응에 대한 문서화
- 위험 관리에 대한 문서화
- 개발 및 검증에 대한 문서화
- 레거시 디지털의료기기 관리에 대한 문서화
- 침해사고 대응 및 취약점 감시에 대한 문서화

[증적 예시]

- 전자적 침해행위 보안 절차서
- 위험 관리 계획서, 위험 관리 절차서, 위험 관리 보고서, FMEA 테이블 등 위험 관리 파일
- 보안 설계 및 개발 절차서
- 시험 및 검사 절차서
- 보안 검증 및 유효성 확인 절차서 및 보고서
- 침해행위 관리 절차서, 침해행위 발생 기록지, 침해행위 대응 보고서
- 취약점 관리 절차서, 취약점 대응 관리 대장
- 소프트웨어 구성 요소 명세서(SBOM) 관리 절차서, SBOM 표준 문서 등

※ 침해사고, 취약점 등이 발생하지 않았다고 하더라도 절차서에 따라 보안활동을 수행할 수 있도록 '기록' 양식(템플릿)을 보유하고 있어야 한다.

제3조(물리적 보안)

① 디지털의료기기제조업자등은 디지털의료기기와 그 운영 환경에서의 설치, 작동, 네트워크, 제품 관련 장비 및 자료 보호 등을 위한 물리적 보안 구성을 고려하여야 한다.

② 디지털의료기기제조업자등은 디지털의료기기를 운영하는 물리적 보안 환경을 분석하고 각종 물리적 위협으로부터 보호할 수 있도록 대책을 마련하여야 한다.

③ 디지털의료기기를 운영하는 환경이 비인가자 접근 통제, 출입 기록 관리 등의 접근 통제가 정의된 인가 절차 등에 따라 이루어지는지 확인해야 하며, 주요 시설(전산실 등)에 위치할 경우 이에 대한 물리적 보안 조치를 하여야 한다.

[의료기기의 사이버보안 허가·심사 가이드라인 관련 요구사항]

- SI-10 물리적 변조 방지

❑ 물리적 보안 구성 고려

○ 디지털의료기기제조업자등은 사전에 파악한 자사 제품과 그 운영환경에 대한 설치 및 운영 환경, 네트워크, 제품 관련 장비 및 자료 보호 등을 위한 물리적 보안 구성을 고려하여야 한다.

물리적 보안 구성이란, 디지털의료기기제조업자등이 자사 제품이 판매되어 실제 납품될 환경(예 : 병원, 의료원, 재활센터 등)에서 **물리적인 보안**을 준수할 수 있도록 **구성 체계를 준비하여 이를 납품될 환경에 적용**하는 것을 의미함
이는 디지털의료기기제조업자등이 납품 후 사용, 유지보수 등에 대한 제품 상에서의 보안만 다루는 것이 아니라 제품을 실제 사용해야 하는 환경에서도 보안 조치를 강구하기 위함임

※ 제품 사용자가 병원 등이 아닌 일반 가정 환경, 모바일 환경일 경우 최소한의 물리적 보안 구성을 고려할 수 있으며 보안 구성 항목에 대해 사용자 매뉴얼, 도움말 등을 통해 전달할 수 있음

❑ 물리적 보안 환경 분석 및 대책 마련

○ 제품의 운영 환경에 대한 물리적 보안 환경 분석 자료(설치, 운영, 네트워크 및 장비 보호를 위한 환경 평가 기준 등)를 분석하여 이에 맞게 보안을 마련하여야 한다.

- 의료기기 하드웨어를 포함하는 소프트웨어 내장 디지털의료기기에서 다음과 같이 물리적 보안을 제공할 수 있다.

세부 내용	의료기기 하드웨어를 포함하는 소프트웨어 내장 디지털의료기기

√ 위험 관리 활동을 통해 물리적 변조 방지 기능 제공 여부 판단
· (구성) 의료기기 하드웨어를 포함하는 소프트웨어 내장 디지털의료기기
· (외부 인터페이스) 의료기기 하드웨어에 외부 인터페이스가 존재하는 경우
· (보안 침해 수준)
- 외부 인터페이스를 통해 중요 정보(개인정보 등)에 대한 유출이 가능한 경우
- 외부 인터페이스를 통해 디지털의료기기의 위·변조 행위로 인하여 성능저하 또는 오작동 시 직·간접 피해 수준이 중상 이상일 경우

보안 활동	의료기기 하드웨어를 포함하는 소프트웨어 내장 디지털의료기기

구분		설명
제1항 및 제2항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 물리적 보안환경에서 발생할 수 있는 각종 물리적 위협으로부터 보호할 수 있도록 디지털의료기기(의료기기 하드웨어)를 제공해야 함

예시	물리적 시건 장치

√ 잠금장치, 캡슐화, 보안나사(비표준 헤드 유형) 등의 물리적 변조 방지 기능 제공

√ 잠금장치, 캡슐화, 보안나사(비표준 헤드 유형) 등의 물리적 변조 방지 기능 제공
* 보안나사 : 일반적인 십자(Phillips)나 일자(Slotted) 드라이버로는 풀 수 없도록 고안된 특수한 머리 디자인은 가진 나사로, 토르크스(Torx), 헥스(Hex), 스네이크 아이(Snake Eye) 등 특수 드라이버가 필요



- 디지털의료기기를 각종 물리적 위협으로부터 보호할 수 있도록 운영 환경의 물리적 보안을 구성하여 운영하여야 한다.

세부 내용 **운영환경의 보안설정 및 구성**

√ 사용자 매뉴얼에 디지털의료기기가 설치 및 운영되는 물리적 환경(제한구역, 통제구역, 일반구역, 가정/모바일 등)에 맞도록 물리적 보안 구성을 명시

√ 물리적 환경의 예

구분	물리적 환경	설명	예시
병원 내 사용	제한구역	승인된 인원만 출입 가능하며, 주요 시설이 포함된 구역으로 출입 통제 시스템에 의해 엄격하게 운영	병원 내 전산실, 서버실 등
	통제구역	제한구역보다 덜 엄격하나 조건을 충족해야 출입이 가능한 구역	병원 내 진료실 등
	일반구역	비교적 자유롭게 출입이 가능한 구역	병원 내 입원실 등
병원 외 사용	일반 사용자 환경	병원 외에서 사용 가능한 의료기기(개인용 의료기기 등)로 제 3자의 접근이 용이한 환경	가정 환경, 모바일 등

보안 활동 **운영환경의 보안설정 및 구성**

구분		설명
제1항 및 제2항 기준	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자 (디지털의료기기제조업자등의 설치 담당자, 기술지원 담당자)
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** 디지털의료기기의 물리적 보안 구성을 고려한 운영환경, 작동, 네트워크, 제품 관련 장비 및 자료 보호 등의 내용을 포함해야 함

예시 **사용자 매뉴얼**

√ 디지털의료기기의 의도된 목적에 따라 안전하게 사용될 수 있도록 물리적 보안 구성 명시

√ 물리적 보안구성에 따라 운영되지 않을 경우 전자적 침해 등이 발생할 수 있다는 경고 등을 명시

<운영환경의 물리적 보안 구성 예시>

√ 주요 시설(전산실, 서버실 등 제한구역) 배치

√ 별도의 물리적 랙 배치

√ 디지털의료기기의 외부 인터페이스를 보안테이프, 포트락 등으로 봉인



- 디지털의료기기가 설치되는 물리적 환경의 요건을 점검할 수 있도록 체크리스트 등을 제공하여 물리적 보안을 구성할 수 있도록 하여야 한다.

보안 활동	**운영환경의 보안설정 및 구성**	
구분		**설명**
제1항 및 제2항 기준	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자 (디지털의료기기제조업자등의 설치 담당자, 기술지원 담당자)
	보안활동 수행 입력 (input)	**(물리적 보안구성 체크리스트)** 디지털의료기기가 설치되는 물리적 환경의 요건을 점검할 수 있도록 체크리스트 등 제공

예시 **물리적 보안구성 체크리스트**

번호	점검 영역	점검 항목	확인 결과 (O/X)
1	접근 통제 및 출입 관리	주요 시설(전산실 등) 출입 통제 시스템 (카드 리더기, 생체 인식 등) 구축 여부	
2		출입자 기록 관리 여부	
3		방문자 관리 절차 확보 여부	
4		디지털의료기기 주변 비인가자에 대한 물리적 접근 제한 조치(잠금장치, 경고 표지 등) 여부	
5		디지털의료기기 자체 물리적 잠금장치(캐비닛 잠금, 시건장치가 적용된 서버 랙(RACK), 포트 봉인 등) 구현 여부	
6		디지털의료기기 설치 구역 내 CCTV 등 감시 시스템 운영 여부 등	
7	장비 및 자료 보호	디지털의료기기 물리적 손상(충격, 낙하) 방지를 위한 안전한 장소 보관 및 환경 조건 유지 여부	
8		전원 및 네트워크 케이블 물리적 손상/무단 분리 보호 여부	
9		관련 중요 자료(사용자 매뉴얼 등) 물리적 안전 보관 및 접근 통제 여부	
10	비상 계획 및 대응	화재 감지/진압 시스템(소화기, 스프링클러) 설치 여부	
11		자연재해(지진, 홍수 등)로부터 디지털의료기기 보호 대책 마련 여부	
12		정전 대비 무정전 전원 공급 장치(UPS) 설치 여부	
…	…	…	

❑ 운영 환경 접근 통제 및 물리적 보안 조치

○ 디지털의료기기제조업자등과 의료서비스제공자는 제품 운영 환경에 대해 비인가자의 접근 통제가 존재하여야 하는 필요성을 인지하고, 물리적 보안 조치를 하여야 한다.

- 디지털의료기기제조업자등은 가능한 경우 운영 환경에서 접근 통제가 이루어지도록 의료기관(의료서비스제공자 등)과 협의하여야 한다.
- 의료서비스제공자는 출입 기록을 관리하고 관리 대상 문서(예 : 출입 기록 대장, 출입 관리 대장 등)에 대한 검토 주기 및 갱신 기준에 대해 정의하여 관리할 수 있어야 한다.

<의료서비스제공자의 권고 사항>

의료서비스제공자는 물리적 보안(제3조) 기준에 따라 필수로 수행해야 할 의무적 조항은 없으나 병원 내 제한구역/통제구역에 대한 접근 통제, 출입 기록 관리 등을 디지털의료기기제조업자등이 직접적으로 수행할 수 없으므로 디지털의료기기가 안전하게 사용될 수 있도록 물리적 보안 구성에 협조할 수 있어야 한다.

세부 내용 **운영환경의 보안설정 및 구성**

√ 의료서비스제공자가 디지털의료기기가 설치 및 운영되는 물리적 환경(제한구역/통제구역)에 보안 조치를 수행할 수 있도록 관련 보안활동을 권고해야 한다.

· 의료서비스제공자가 병원 내 제한구역/통제구역에 대한 접근 통제를 수행할 수 있도록 절차를 명시하고, 관련 보안 활동을 권고

· 의료서비스제공자가 병원 내 제한구역/통제구역에 대한 출입 기록 관리를 수행할 수 있도록 절차를 명시하고, 관련 보안 활동을 권고

· 의료서비스제공자가 병원 내 제한구역(전산실 등)에 대한 물리적 보안 조치를 수행할 수 있도록 절차를 명시하고, 관련 보안 활동을 권고

보안 활동		운영환경의 보안설정 및 구성
구분		설명
제3항 기준	보안활동 영역	의료서비스제공자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** 의료서비스제공자가 병원 내 제한구역/통제구역에 대한 접근 통제, 출입 기록 관리, 물리적 보안 조치를 수행할 수 있도록 절차를 명시하고 관련 보안 활동을 권고해야 함
	적용 예외 사항	병원 내 제한구역/통제구역이 아닌 일반구역, 병원 외 일반 사용자 환경에 설치 및 운영될 경우 본 항목은 '해당사항 없음'으로 처리함

예시	사용자 매뉴얼

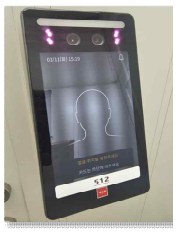
√ 디지털의료기기가 운영되는 제한구역/통제구역은 출입 절차에 따라 출입이 허가된 자만 출입하고 비인가자 접근을 통제하도록 인가 절차 등 권고 내용 명시

√ 의료서비스제공자가 제한구역/통제구역에 대한 출입 기록을 주기적(예-월 1회 이상)으로 검토하도록 권고 내용 명시

√ 의료서비스제공자가 제한구역(전산실 등)에 대한 물리적 보안 조치(예-출입통제시스템, 영상감시시스템, 경비시스템 등) 등 권고 내용 명시



<출입통제시스템>





<영상감시시스템>





<경비시스템>

제4조(보안 통신)

디지털의료기기제조업자등은 다음 각 호의 사항을 고려하여 디지털의료기기 및 그 운영 환경의 보안 통신 방안을 마련하여야 한다.

1. 유 · 무선 네트워크 사용 시, 디지털의료기기 및 그 운영 환경의 네트워크 보안 설정
2. 이동식 저장매체(USB 등)에 대한 물리적 제한
3. 보안을 고려한 내 · 외부 통신망(통신 구간 암호화, 암호화 프로토콜 사용 등) 구성 방안

[의료기기의 사이버보안 허가·심사 가이드라인 관련 요구사항]

- RA-04 네트워크 및 보안 구성 설정
- SI-01 통신에 대한 무결성 보장
- DC-01 정보에 대한 기밀성 보장
- DC-03 안전한 암호화 사용

❑ 네트워크 보안 설정

○ 디지털의료기기가 유·무선 네트워크 환경에 연결되는 경우 네트워크를 통한 침해행위를 방지할 수 있도록 보안 설정이 반드시 필요하며 네트워크 서비스를 제공하는 기기(예 : 무선 AP 등)에 대해서도 보안 설정이 필요하다.

- 디지털의료기기제조업자등은 디지털의료기기 및 그 운영환경의 네트워크 보안 설정을 사용자 매뉴얼에 명시하여 실 사용자(의료서비스제공자 및 일반 사용자)가 수행할 수 있도록 안내하여야 한다.

※ 심사를 진행하는 경우, 신청서에 기재되어 있는 신청제품의 통신구성도에 사용하는 통신 기술과 통신 대상 및 목적과 일관성이 있어야 한다.

세부 내용

√ 디지털의료기기제조업자등은 디지털의료기기 및 그 운영환경에 대한 유·무선 네트워크 환경과 보안설정을 관련 문서(사용자 매뉴얼, 기술문서 등)에 명시하여야 함

· 디지털의료기기의 통신 기능 유무, 적용되는 통신 기술(USB, RS-232, LAN, Wi-Fi, 블루투스, RF 통신 등 사용하는 통신 기술을 모두 기재)

· 공용 네트워크망 사용 여부

· 사용 환경(병원 폐쇄망 내에서 사용, 가정 환경에서 사용 등)

구분	종류	설명
사용 환경	병원 내 사용	병원 내에서만 사용되는 의료기기로 사이버보안 침해를 위한 제3자의 접근이 어렵고, 보안이 갖춰진 병원 폐쇄망 내에서 사용됨
	병원 외 사용	병원 외에서 사용이 가능한 의료기기(개인용 의료기기 등)로 제3자의 접근이 용이함
	공용 네트워크 망 사용	시공간의 제약 없이 언제, 어디서나 공용 네트워크망(인터넷 등)에 접속하여 기기 및 시스템과의 통신이 가능함

보안 활동 **운영환경의 보안설정 및 구성**

구분		설명
제4조 전체	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자 (디지털의료기기제조업자등의 설치 담당자)
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** - 통신 기능 유무, 적용되는 통신 기술, 사용환경, 공용 네트워크망 사용 여부를 명시해야 함 - 설치 담당자 또는 의료서비스제공자가 디지털의료기기 및 운영환경의 보안 통신을 설정할 수 있도록 사용자 매뉴얼에 관련 절차를 명시해야 함

예시 **사용자 매뉴얼**

√ 통신 기능 유무, 적용되는 통신 기술(USB, RS-232, LAN, Wi-Fi, 블루투스, RF 통신 등 사용하는 통신 기술을 모두 기재), 사용환경(병원 폐쇄망 내에서 사용, 가정 환경에서 사용 등), 공용 네트워크망 사용 여부를 명시

√ (유선 연결 포트) 반드시 필요한 포트만 활성화하고 그 외 포트는 비활성화하는 조치를 수행하도록 사용자 매뉴얼 등에 명시

√ (Wi-Fi 통신) 실사용 장소(가정, 병원 등)에서의 무선 AP에 대한 네트워크 보안 설정을 적용하도록 사용자 매뉴얼 등에 명시

√ (블루투스 통신) 취약한 PIN 사용 금지, 반복 링크 키 사용 금지, 알 수 없는 장치 연결 거부, 미사용 시 블루투스 기능 비활성화 등의 보안 조치를 적용하도록 사용자 매뉴얼 등에 명시

- 유·무선 통신 기술의 사용에 따른 정보의 위·변조, 오작동 또는 디지털의료기기에 승인되지 않은 접근 등을 방지하기 위한 대책을 포함하여야 한다.

세부 내용	디지털의료기기

√ 유선 연결 포트(Ethernet)
· 유선 연결 포트가 반드시 필요한 포트만 활성화하고 그 외 포트는 비활성화
√ Wi-Fi 통신
· WPA2-AES, WPA3 등 안전한 암호화 방식을 지원해야 함
· Wi-Fi 비밀키는 특수문자를 포함한 임의의 문자를 사용하여 최대한의 길이를 사용해야 함
· Wi-Fi 실사용 장소(가정, 병원 등)에서의 무선 AP에 대한 네트워크 보안 설정을 적용
√ 블루투스 통신
· 디지털의료기기는 BLE 4.0/4.1을 포함하여 낮은 버전의 기기는 보안모드 1의 보안레벨 3(암호화된 인증 페어링)을 적용하고, BLE 4.2 기기 및 서비스는 보안모드 1의 보안레벨 4(암호화된 저전력 보안연결 인증)을 적용
· 취약한 PIN 사용 금지, 반복 링크 키 사용 금지, 알 수 없는 장치 연결 거부, 미사용 시 블루투스 기능 비활성화 등의 보안 조치 적용

보안 활동		디지털의료기기
구분		**설명**
제1항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 유·무선 통신 기술의 사용에 따른 정보의 위·변조, 오작동 또는 의료기기에 승인되지 않은 접근 등을 방지하기 위한 기능을 제공해야 함

예시	디지털의료기기

√ (Wi-Fi 통신) 디지털의료기기에서 WPA2-AES, WPA3 등 안전한 암호화 방식 지원
√ (Wi-Fi 통신) 디지털의료기기의 Wi-Fi 비밀키는 특수문자를 포함한 임의의 문자를 사용하여 최대한의 길이로 설정
√ (블루투스 통신) 디지털의료기기는 BLE 4.0/4.1을 포함하여 낮은 버전의 기기는 보안모드 1의 보안레벨 3(암호화된 인증 페어링)을 적용하고, BLE 4.2 기기 및 서비스는 보안모드 1의 보안레벨 4(암호화된 저전력 보안연결 인증)을 적용

- 보안 설정은 최초 적용 후, 정기적으로 점검 및 갱신하여 관리하도록 관련 문서(사용자 매뉴얼, 기술문서 등)에 명시하여야 한다.

○ 물리적 포트를 통한 연결 또는 이동식 저장매체(예: USB, External SSD 등)에 대한 사용 시, 통제 수단을 고려하여야 한다.

- 디지털의료기기 업데이트 목적, 데이터 전송 등을 제외한 일반적 운영환경에서 이동식 저장 매체에 대한 사용을 제한하는 방안이 마련되어야 한다.

세부 내용	**디지털의료기기**
√ 디지털의료기기의 일반적인 운영환경에서 이동식 저장매체 사용을 제한해야 함 · 업데이트 목적, 데이터 전송 등을 제외한 이동식 저장매체에 대한 사용을 제한하도록 설정되어야 함	

보안 활동		**디지털의료기기**
구분		**설명**
제2항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 이동식 저장매체에 대한 사용을 제한하도록 설정되어야 함

예시	**디지털의료기기**
√ 이동식 저장 매체 연결 시 자동 unmount 등	

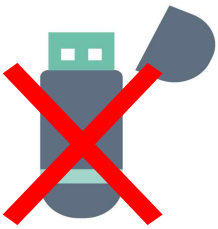
- 미사용 포트(USB 등)에 대해 물리적 조치를 진행하여야 한다.

세부 내용	**운영환경의 보안설정 및 구성**
√ 디지털의료기기의 USB 포트에 대해 물리적으로 제한해야 함 · 사용자 매뉴얼에 미사용 USB 포트에 대한 물리적 제한 내용을 명시 · 디지털의료기기제조업자등의 설치 담당자가 직접 설치하는 경우 미사용 USB 포트에 대해 물리적으로 조치를 수행	

보안 활동		운영환경의 보안설정 및 구성
구분		설명
제2항 기준	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자 (디지털의료기기제조업자등의 설치 담당자)
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** 설치 담당자 또는 의료서비스제공자가 디지털의료기기의 미사용 USB 포트에 대한 물리적 조치를 취할 수 있도록 사용자 매뉴얼에 관련 절차를 명시해야 함

예시	사용자 매뉴얼
√ 미사용 USB 포트에 대한 물리적 제한 내용(보안테이프 부착, USB 포트락 키 설치, 시건장치가 있는 랙에 보관, 비인가된 접근이 불가능한 제한구역에 보관 등) 명시 √ 디지털의료기기제조업자등의 설치 담당자가 직접 설치하는 경우 미사용 USB 포트에 대해 물리적인 조치 수행	

· 미사용 USB 포트 조치 예시



<USB 포트 제한 명시>



<USB 포트락>



<보안테이프>

○ 디지털의료기기 및 그 운영환경은 보안을 고려하여 통신 구간 암호화 방안을 마련하고 제공하여야 한다.

- 법적 준거성을 만족할 수 있도록 통신 구간 암호화를 제공하여야 한다.

※ 제6조(기술적 보안)의 ③ 내용을 참조한다.

- TLS(Transport Layer Security), SSL(Secure Sockets Layer), IPSec(Internet Protocol Security 등)과 같은 표준화된 암호화 프로토콜을 사용하여야 한다.

세부 내용	디지털의료기기

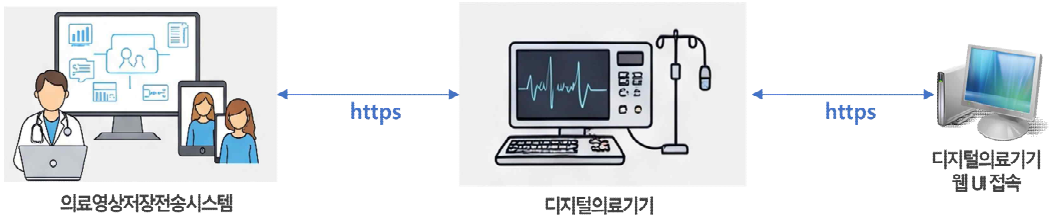
√ 디지털의료기기는 보안을 고려하여 통신 구간 암호화를 제공해야 함
· 디지털의료기기에서 표준화된 암호화 프로토콜을 사용하여 통신 구간 암호화 기능을 제공

보안 활동	디지털의료기기	
구분		설명
제3항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기에서 통신 구간 암호화 기능을 제공

예시	디지털의료기기

√ 디지털의료기기에서 표준화된 암호화 프로토콜(TLS 등)을 사용하여 통신 구간 암호화 기능 제공

√ 디지털의료기기에서 생성된 데이터를 https 프로토콜을 사용하여 전송
√ 사용자가 디지털의료기기의 웹 UI 접속 시 https 프로토콜 사용



<통신 구간 암호화 기능>

- 디지털의료기기에서 통신 구간 암호화 기능을 제공할 수 없는 경우, 운영환경(VPN 통신 등)의 지원을 받을 수 있다.

세부 내용	운영환경의 보안설정 및 구성

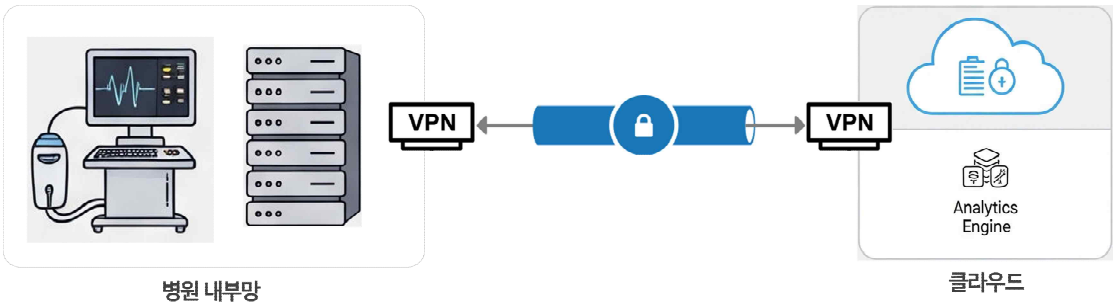
√ 디지털의료기기는 보안을 고려하여 통신 구간 암호화를 제공해야 함
· 운영환경(VPN 통신 등)의 지원을 받아 통신 구간 암호화 수행

보안 활동	운영환경의 보안설정 및 구성	
구분		설명
제3항 기준	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자 (디지털의료기기제조업자등의 설치 담당자)
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** 디지털의료기기의 통신 구간 암호화가 적용되도록 네트워크 운영환경(VPN 통신 등)의 보안설정 및 구성에 대한 절차를 사용자 매뉴얼에 명시해야 함

예시	사용자 매뉴얼

√ 디지털의료기기가 운영되는 네트워크와 공용 네트워크 망(인터넷 등) 간 보안통신 설정 절차 등을 명시

· 병원의 VPN 게이트웨이와 클라우드 운영환경의 VPN 게이트웨이를 연결하여 VPN 터널링을 통해 디지털의료기기에서 생성된 데이터 전송



<VPN을 이용한 통신 구간 암호화>

제5조(권한 및 인증)

디지털의료기기제조업자등은 다음 각 호의 사항을 고려하여 디지털의료기기 및 그 운영 환경의 권한 및 인증 방안을 마련하여야 한다.

1. 사용자 접근 통제 강화 및 계정별 권한 설정
2. 세션 종료, 중복 로그인 방지 등 로그인 세션 및 쿠키 설정
3. 미승인 기기 접근 제한 등 신원 확인을 위한 인증 사용
4. 원격 접속 차단 또는 제한된 원격 접속 조치(사용자 인증, 보안 통신 사용 등)

[의료기기의 사이버보안 허가·심사 가이드라인 관련 요구사항]

- IA-01 사용자 식별 및 인증
- IA-02 계정 관리
- IA-03 식별정보 관리
- IA-04 인증정보 관리
- IA-06 인증정보에 대한 피드백
- IA-07 연속적인 로그인 시도 실패 시 로그인 제한
- IA-08 시스템 사용 알림 메시지
- SI-07 오류 처리
- UC-01 권한 부여
- UC-03 세션 잠금

❑ 사용자 접근 통제 강화 및 계정별 권한 설정

○ 디지털의료기기 및 그 운영 환경에서의 사용자 접근 권한을 관리하기 위하여, 사용자 접근 통제 강화 및 계정별 권한 설정 방안을 마련하여야 한다.

- 사용자(사람, 기기, 소프트웨어)가 접근할 수 있는 디지털의료기기의 인터페이스를 사용자 매뉴얼에 명시하여야 한다.

보안 활동		**사용자 매뉴얼**
구분		**설명**
제5조 전체	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등
	보안활동 수행 결과 (output)	**(사용자 매뉴얼)** 디지털의료기기에 접근할 수 있는 사용자(사람, 기기, 소프트웨어)와 인터페이스를 명시해야 함

예시 **사용자 매뉴얼**

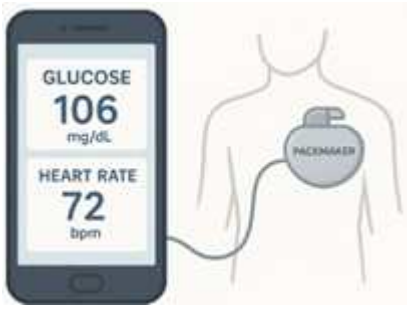
√ 사용자 매뉴얼에 사용자가 접근 가능한 인터페이스를 명시해야 함
√ 사용자(사람)가 접근 가능한 인터페이스의 예 : GUI(Graphical user interface), CLI(Command User interface), Web 인터페이스 등
√ 사용자(기기, 소프트웨어)가 접근 가능한 인터페이스의 예 : 네트워크 통신 프로토콜, API 등

- 디지털의료기기의 인터페이스에 접근하는 사용자(사람, 기기, 소프트웨어 등)를 식별 및 인증하는 기능이 제공하여야 한다.

세부 내용 **디지털의료기기 & 운영환경**

√ 사용자(사람, 기기, 소프트웨어)에 대한 식별 및 인증 기능을 제공해야 함
· 디지털의료기기 또는 운영환경(운영체제, 외부 인증 서버 등)은 사용자가 인터페이스에 접근 시 식별 및 인증 기능을 제공해야 함
· 환자의 생명에 직접적인 영향을 미치는 의료기기와 통신하는 제품 및 소프트웨어 의료기기(SaMD)의 경우 의료기기 자체적으로 사용자의 식별 및 인증 기능을 구현하는 것을 우선 고려해야 함
  - 예) 체외용인슐린주입기 등 약물을 주입하는 의료기기와 통신하는 모바일 의료용 앱 등
  - 예) 이식형심작박동기 이식형심장충격기 등과 통신하는 심장박동기분석기 및 모바일 의료용 앱 등





· 식별 및 인증 과정에서 인증에 사용되는 정보를 출력장치에 표시하지 않아야 함
· 식별 및 인증 실패 시, 실패 사유에 대한 피드백을 제공하지 않아야 함

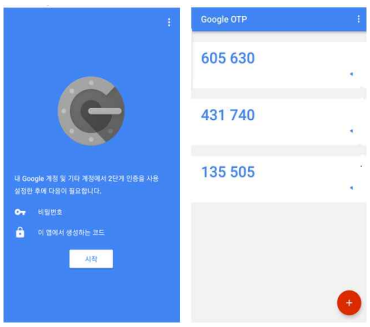
※ 디지털의료기기에 사용자가 접근 가능한 인터페이스가 없는 경우에는 적용하지 않음

· 디지털의료기기가 사용자에 대한 식별 및 인증 기능을 제공할 수 있다.

보안 활동		디지털의료기기
구분		**설명**
제1항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기에 접근할 수 있는 사용자(사람, 기기, 소프트웨어)가 인터페이스 및 중요 설정 접근 시 식별 및 인증하는 기능을 제공해야 함

예시 디지털의료기기

√ ID/패스워드 방식, OTP(One-Time Password) 방식, 인증서 방식, 생체인증 방식 등 식별 및 인증 기능



<OTP(one-time password)>
<출처>: Google OTP



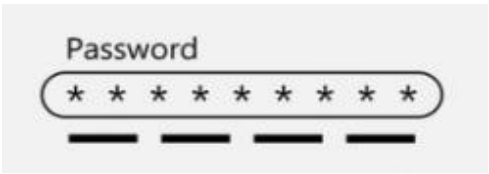
<인증서 방식>
<출처>: NICE 아이디



<생체인증>
<출처>: Apple FACE ID, Touch ID

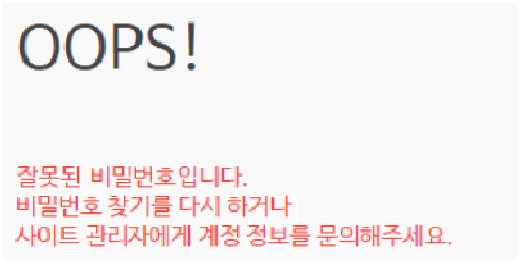
예시 디지털의료기기

√ 인증에 사용되는 정보는 입력 내용 미표시, 입력문자 대신 '*' 로 표시



예시 **디지털의료기기**

· 존재하지 않는 계정, 패스워드 오류 등 실패 사유에 대한 피드백을 제공하지 않아야 함



<인증 실패 이유에 대한 피드백 제공(잘못된 예)>



<피드백 미제공>

· 디지털의료기기는 운영환경(운영체제, 외부 인증서버 등)으로부터 사용자에 대한 식별 및 인증 기능을 제공받을 수 있다.

보안 활동		**운영환경의 보안설정 및 구성**
구분		**설명**
제1항 기준	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자 (디지털의료기기제조업자등의 설치 담당자)
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** 디지털의료기기가 운영환경으로부터 식별 및 인증기능을 제공받을 수 있도록 보안설정 및 구성하는 절차를 사용자 매뉴얼에 명시해야 함

예시 **사용자 매뉴얼**

√ 사용자 매뉴얼에 디지털의료기기가 운영환경으로부터 식별 및 인증 기능을 제공받을 수 있도록 보안설정 절차를 명시

· 보안설정의 예: 인증시스템인 LDAP(Lightweight Directory Access Protocol)과 디지털의료기기를 연결하는 절차 및 방법

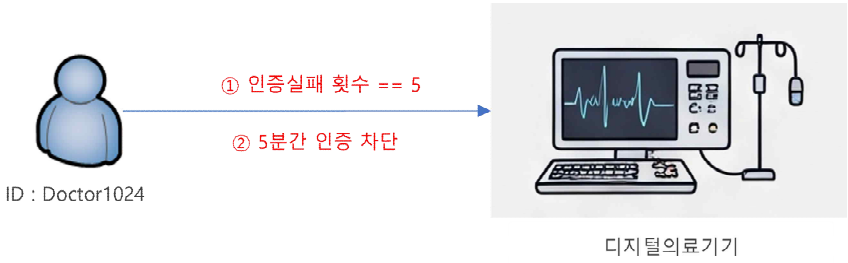
- 디지털의료기기의 인터페이스에 접근하는 사용자(사람, 기기, 소프트웨어 등)가 연속적으로 잘못된 인증을 시도하는 경우 인증 기능을 비활성화해야 한다.

세부 내용	디지털의료기기 & 운영환경

√ 사용자가 연속 인증 실패 시, 인증 제한 기능을 제공해야 함
· 사용자가 연속적으로 잘못된 인증을 시도하는 경우 인증 기능을 비활성화해야 함
· 연속적으로 잘못된 인증이 정해진 횟수에 도달했을 때 정해진 시간 동안 또는 관리자가 잠금 해제할 때까지 인증 기능을 비활성화해야 함

예시	디지털의료기기

√ 5회 연속적인 인증 실패 시 5분간 인증 기능 비활성화 기능 제공



<잘못된 로그인 연속 시도에 대한 비활성화>

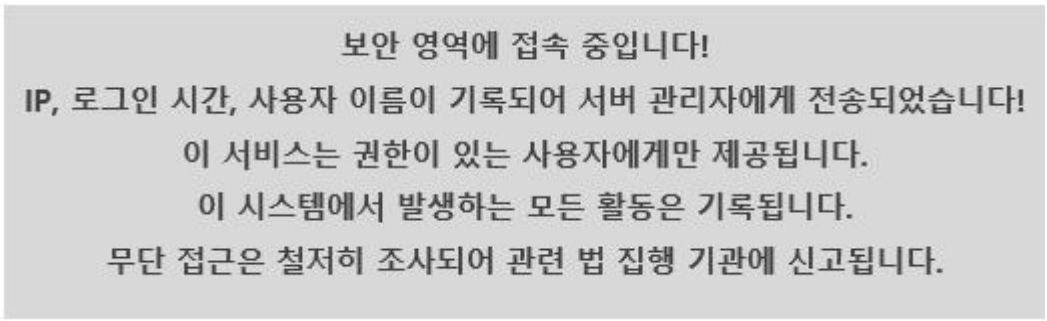
- 디지털의료기기에 접근한 사용자(사람, 기기, 소프트웨어 등)에 대한 식별 및 인증이 완료된 후 시스템 사용 알림 메시지를 출력하는 기능이 제공하여야 한다.

보안 활동	디지털의료기기

구분		설명
제1항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 식별 및 인증 완료 후 사용자 인터페이스에서 시스템 사용 알림 메시지(경고 배너)를 출력하는 기능을 제공해야 함

예시 **디지털의료기기**

√ 로그인 후 디지털의료기기 접근 이력, 보안 경고 등 시스템 사용 알림 메시지(경고 배너) 출력
√ 시스템 사용 알림 메시지(경고 배너)의 예
· 개인 자산 소유자가 소유한 시스템에 접근함
· 시스템 사용은 모니터링, 기록 및 감사 대상이 될 수 있음
· 인가되지 않은 시스템 사용은 금지되고 민·형사상의 처벌 대상임
· 시스템의 사용은 모니터링과 기록에 동의함을 의미함



<로그인 성공 후 배너 출력>

- 디지털의료기기의 인터페이스에 접근하는 사용자(사람, 기기, 소프트웨어 등)의 계정 및 인증정보를 관리하는 기능을 제공하여야 한다.

세부 내용 **디지털의료기기 & 운영환경**

√ 사용자 계정 관리 기능을 제공해야 함

· 디지털의료기기 또는 운영환경을 통해 사용자에 대한 계정 추가, 수정, 삭제, 활성화/비활성화 등 관리하는 기능을 제공해야 함

구분	설명
디지털의료기기	디지털의료기기에서 사용자의 계정 관리 기능을 제공
운영환경	디지털의료기기가 운영환경의 지원을 받아 계정 관리 기능 제공 - 운영체제(MS Windows, Linux, Unix, Android OS 등)을 통한 계정 관리

· 생성된 계정은 각 계정을 명확하게 식별하기 위해 유일한 식별 정보를 사용해야 함

· 디지털의료기기의 필수 기능(예: 생명에 직접적인 연관이 있는 질병의 치료를 위한 중요 기능 등)에 사용되는 계정은 일시적으로라도 해당 기능이 잠기지 않아야 함

· 계정관리시스템을 통해 계정 관리 시, 계정관리시스템에 가용성 문제가 발생한 경우에도 디지털의료기기의 식별 및 인증 기능에 영향을 받지 않아야 함

√ 사용자 인증정보를 관리하는 기능을 제공해야 함

· 사용자 인증정보의 예

- 비밀번호, 토큰, 대칭키, 비대칭키(공개키/개인키), 생체인식, 물리적 키, 키 카드 등

· 디지털의료기기 또는 운영환경을 통해 사용자에 대한 인증정보 추가, 수정, 삭제 등 관리하는 기능을 제공해야 함

· 디지털의료기기 설치 시, 디폴트 비밀번호가 제공되는 경우 설치 후 강제로 변경하는 기능을 제공하거나, 디폴트 비밀번호가 변경되지 않았음을 알 수 있도록 표시하는 기능을 제공해야 함

· 주기적으로 인증정보를 변경할 수 있는 기능을 제공해야 함

· 디지털의료기기가 인증정보로 비밀번호를 사용할 경우, 비밀번호 강도를 적용하는 기능을 제공하거나 사용자 매뉴얼에서 비밀번호 설정 시 높은 강도로 설정하도록 명시해야 함

보안 활동 **디지털의료기기**

구분		설명
제1항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기에 접근할 수 있는 사용자(사람, 기기, 소프트웨어)에 대한 인증정보를 관리하는 기능을 제공해야 함

예시 **디지털의료기기**

√ 최초 접속 시 디폴트 비밀번호 강제 변경 기능
√ 비밀번호 설정 시 강도 확인 기능
· 최소 길이 8자, 영문자/숫자/특수문자 조합



<비밀번호 강도 확인>

- 디지털의료기기의 의도된 사용에 따라 역할(Roles)을 정의하고, 각 역할에 필요한 권한을 부여하여야 하며, 그에 따른 접근 통제(Access Control) 기능을 제공하고 모든 사용자 활동에 대한 추적성을 확보하여야 한다.

· 사용자(사람)별 계정을 부여하고, 최소 권한 원칙*에 따라 업무 범위에 맞는 최소 권한만 부여하여야 한다.

<최소 권한 원칙에 대한 설명>

- NIST SP 800-53 Rev.5 (2020.9.23.)에서는 최소 권한 원칙을 적용하여 할당된 조직 임무를 수행하는데 필요한 권한만 사용자(프로세스)에게 허용해야 한다고 명시하고 있음

- AC-6 LEAST PRIVILEGE

"Employ the principle of least privilege, allowing only authorized accesses for users (or processes acting on behalf of users) that are necessary to accomplish assigned organizational tasks."

· 예를 들어, 사용자가 의사, 간호사 등 사용자의 직무/직책에 따른 구분이 있을 경우 해당 구분에 따라 환자정보 조회, 진단 정보 변경 등의 변경 권한 등이 부여될 수 있다.

· 또한, 디지털의료기기가 관리자 또는 사용자 권한을 사전 정의한 경우 이에 대한 설정과 변경 권한 범위 등을 사용자 매뉴얼 등에 기재하여

사용자의 권한 범위를 명확히 식별할 수 있도록 한다.

• 또한, 디지털의료기기제조업자등은 불필요하거나 기한이 만료된 계정 권한을 식별하고, 해당 권한을 회수하는 절차를 수립하고 이행하여야 한다.

<불필요한 권한 예시>
- 업무 수행을 위해 일시적인 권한 할당 후, 업무 목적이 종료되었음에도 권한이 남겨져 있는 경우
- 공용으로 사용하는 계정
- 퇴사자 계정 등

세부 내용	디지털의료기기 & 운영환경

√ 사용자(사람) 권한 설정 및 접근 통제 기능을 제공해야 함
· 사용자 매뉴얼에 사용자(사람)별 권한과 역할을 설정하는 방법을 명시해야 함
※ 단일 권한 및 역할만 제공 가능(별도 설정 기능 불필요)
· 사용자 역할의 예
- 최상위 관리자, 일반 관리자, 일반 사용자
· 디지털의료기기는 사용자 매뉴얼에서 정의된 권한과 역할에 따라 허용된 기능에만 접근 및 사용이 가능하도록 접근 통제 기능을 제공해야 함

보안 활동	디지털의료기기	
구분		설명
제1항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기는 사용자(사람)에게 권한을 부여하는 기능을 제공해야 함

❑ 세션 종료, 중복 로그인 방지 등 로그인 세션 및 쿠키 설정

○ 인증 보안 강화를 위하여 세션 종료 및 중복 로그인 방지 등의 로그인 세션 설정 및 무단 접근 방지 방안을 마련하여야 한다.

- 로그인 세션 종료 또는 세션 잠금 기능을 제공하여야 한다.

세부 내용	디지털의료기기 & 운영환경
√ 사용자(사람, 기기, 소프트웨어) 세션 종료 또는 세션 잠금 기능을 제공해야 함 · 사용자(사람, 소프트웨어, 기기)가 정해진 시간(예 : 10분 이하의 값) 동안 디지털의료기기를 사용하지 않을 경우 세션 종료 또는 세션 잠금 기능을 제공해야 함 - 세션 잠금 기능을 해제하기 위해서는 재인증을 수행하는 기능을 제공해야 함 - 단, 생명과 직결되는 디지털의료기기 또는 모니터링만 수행하는 사용자 세션에 대해서는 세션을 잠그거나 종료시키지 않을 수 있음 (안전 기능에 부정적인 영향을 주지 않아야 함)	

· 디지털의료기기에서 세션 종료 또는 세션 잠금 기능을 제공할 수 있다.

보안 활동		디지털의료기기
구분		설명
제2항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기는 세션 종료 또는 세션 잠금 기능을 제공해야 함

예시	디지털의료기기
√ 디지털의료기기에서 세션 종료 또는 세션 잠금 기능을 제공	

· 디지털의료기기는 운영환경(운영체제, 외부 인증서버 등)으로부터 세션 종료 또는 세션 잠금 기능을 제공받을 수 있다.

보안 활동		운영환경의 보안설정 및 구성
구분		설명
제2항 기준	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자 (디지털의료기기제조업자등의 설치 담당자)
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** 디지털의료기기가 운영환경(운영체제, 네트워크 장비, 방화벽 등)으로부터 세션 종료 또는 세션 잠금 기능을 제공 받을 수 있도록 보안설정 및 구성하는 절차를 사용자 매뉴얼에 명시해야 함

예시	운영환경의 보안설정 및 구성
√ 디지털의료기기가 운영환경의 지원을 받아 세션 잠금 기능 제공 · 운영체제(MS Windows, Linux, Unix, Android OS 등)을 통한 세션 종료 또는 세션 잠금 기능 · 방화벽, 스위치 등 네트워크 장비를 통한 세션 종료 기능	

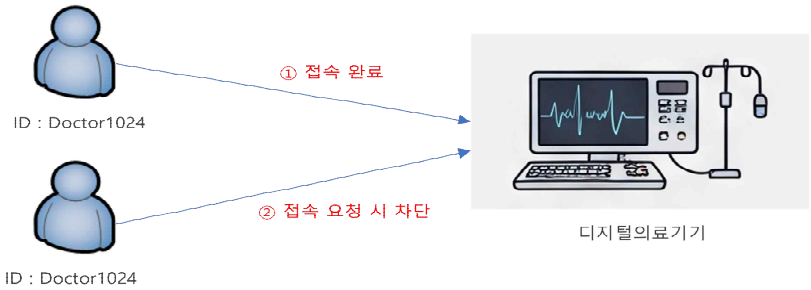
- 동일 계정으로 동시에 접속하지 못하도록 중복 로그인 방지 기능을 제공하여야 한다.

세부 내용	디지털의료기기
√ 동일한 계정으로 중복 로그인을 할 수 없도록 제한하는 기능(다중 접속 금지)을 제공해야 함	

보안 활동		디지털의료기기
구분		설명
제2항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기는 중복 로그인 방지 기능 등을 제공해야 함

예시 **디지털의료기기**

√ 동일 계정으로 로그인 시, 신규 접속을 차단하거나 이전 접속을 종료
(또한, '다른 장치에서 로그인되었으므로 기존 세션이 종료됩니다.' 등의 메시지 제공 권고)



- 로그인 세션에서 쿠키 정보를 사용하는 경우 안전한 쿠키 사용 등 무단 접근 방지 방안을 마련하여야 한다.

세부 내용 **디지털의료기기 & 운영환경**

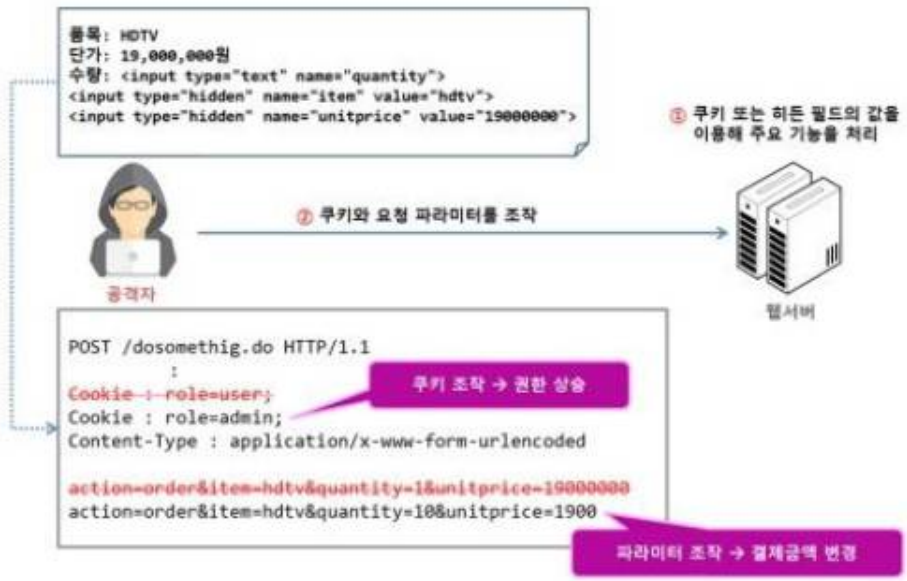
√ 안전한 쿠키 사용을 위한 조치를 적용해야 함
· 안전한 쿠키를 사용하도록 조치(암호화 적용, Server Side Session 사용 등)
- 모든 쿠키 전송은 HTTPS 프로토콜을 적용하여 보안을 유지하여야 함
- 클라이언트 쿠키에는 세션 ID만 저장하되, 실제 사용자 상태/데이터는 서버 저장소(DB 등)에 저장하도록 구현
- 만약, 클라이언트 쿠키에 세션 ID 뿐만 아니라 데이터(사용자 ID, 권한, 만료 시간 등)가 저장된다면 보안에 취약할 수 있음
· 필수(Essential), 비필수(기능, 성능, 소셜 등) 쿠키를 분류하여 안전한 보안을 유지할 수 있도록 조치 및 안내 필요
- 모든 인증·세션 쿠키에 Secure, HttpOnly, SameSite=Lax 적용
- 예외적으로 크로스사이트 적용이 필요한 경우(SSO 등), SameSite=None; Secure 적용
- Path, Domain 값은 최소화하여 적용
- 제품 내 광고, 소셜(Social) 연동이 필요하지 않다면 비필수 쿠키는 미적용하는 것을 권고
· 쿠키값에 개인정보, 환자정보 등의 민감 정보 및 자격증명 정보를 저장하지 않아야 함

예시	디지털의료기기 & 사용자 매뉴얼

√ 디지털의료기기에서 안전하게 쿠키를 사용하기 위한 기능을 제공하거나 조치를 적용

√ 디지털의료기기 화면 또는 사용자 매뉴얼에 쿠키 사용 여부에 대한 안내 문구를 제공하고 필수/비필수 쿠키 정보를 사용자에게 안내할 수 있어야 함

√ 클라이언트에서 디지털의료기기로 전달하는 쿠키, 환경변수, 파라미터 등을 충분히 검증하지 않을 경우, 공격자는 이에 대한 변수를 조작하여 서버로 요청한 뒤, 상승된 권한으로 작업을 수행할 수 있음



<출처>: KISA 소프트웨어 개발보안 가이드(2021)

❑ 미승인 기기 접근 차단 및 원격 접속 제한 조치

❍ 등록되지 않은 기기(미승인 기기) 또는 인증되지 않은 장비로부터 접근을 제한하고 신원을 확인하기 위한 인증 수단을 적용하여야 한다.

- 디지털의료기기는 미승인 기기가 접근하는 것을 차단하기 위해 사용자(기기, 소프트웨어)에 대한 인증 기능을 제공하여야 한다.

세부 내용	**디지털의료기기**
√ 사용자(기기, 소프트웨어)에 대한 인증 기능을 제공하여야 함 · 사용자 매뉴얼에 사용자(기기, 소프트웨어)가 접근 가능한 인터페이스를 명시하여야 함 · 미승인 기기가 접근하는 것을 차단하기 위해 디지털의료기기는 사용자(기기, 소프트웨어)에 대한 인증 기능을 제공하여야 함 - 인증서 방식, 사전공유키 방식, 토큰 기반 인증 등 √ 기기 등록 및 승인 절차를 마련하고, 승인되지 않은 장비에서의 접속 시 경고 또는 차단 기능을 제공하여야 함	

보안 활동		**디지털의료기기**
구분		**설명**
제3항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기로 미승인 기기가 접근할 수 없도록 인증 기능 등을 제공하여야 함

예시 **디지털의료기기**

· 디지털의료기기로 기기 접근 요청 시 인증 기능 수행
· 미승인 기기 접근 차단



<인증서 방식> <사전 공유키 방식> <토큰 기반 인증>

❍ 외부 위협으로부터의 침해를 방지하기 위하여, 원격 접속 차단 또는 제한된 원격 접속 조치를 마련하여야 한다.

- 디지털의료기기에 원격 접속할 수 없도록 차단하거나 인가된 사용자(사람)에게만 원격 접속을 허용하여야 한다.

※ 원격 접속 허용 시, 사용자 단말기 또는 다른 기기가 사전 지정된 IP주소에서만 원격 접속을 허용하도록 접근 통제 정책을 적용해야 하며, IP주소 범위를 지정하거나 네트워크 전체 범위를 지정하여 추가하는 것은 허용되지 않음

세부 내용 **디지털의료기기 & 운영환경**

√ 원격 접속
· 사용자(사람)가 다른 장소에 있는 시스템에서 네트워크를 통해 디지털의료기기에 접속하는 것
√ 디지털의료기기에 원격 접속할 수 없도록 차단하거나 인가된 사용자(사람)에게만 원격 접속을 허용하여야 함
· 원격 접속 시 보안통신(예 : HTTPS, SSH, TLS 등)만 허용하여야 함
· 디지털의료기기가 원격 접속 관련 기능을 제공하거나 운영환경(운영체제 등)의 기능을 이용해야 제공할 수 있음
· 원격 접속 이력은 반드시 감사 로그로 기록·관리하고 주기적으로 점검할 수 있어야 함

· 디지털의료기기는 원격 접속 차단 또는 제한된 원격 접속 기능을 제공할 수 있다.

보안 활동		디지털의료기기
구분		설명
제3항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기에 원격 접속할 수 없도록 차단하거나 인가된 사용자에게만 원격 접속을 허용하는 기능을 제공하여야 함

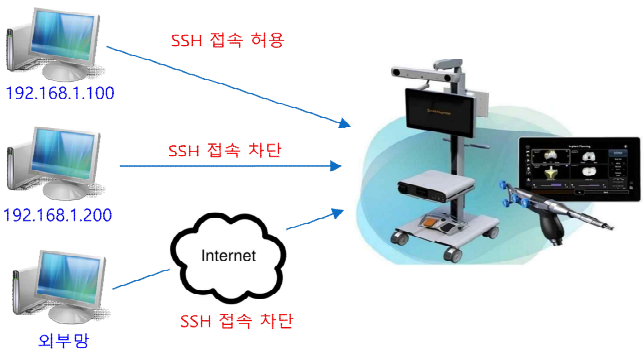
예시 **디지털의료기기**

√ 원격 접속 차단 기능



<원격 접속 차단>

√ 인가된 사용자로 등록된 IP주소에서 보안통신(예: SSH)을 이용한 원격 접속 허용



<제한된 원격 접속 허용>

· 운영환경의 보안설정 및 구성을 통해 디지털의료기기에 대한 원격 접속 차단 또는 제한된 원격 접속을 수행할 수 있다.

보안 활동		운영환경의 보안설정 및 구성
구분		설명
제2항 기준	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자 (디지털의료기기제조업자등의 설치 담당자)
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** 디지털의료기기가 운영환경(운영체제, 네트워크 장비, 방화벽 등)으로부터 원격 접속할 수 없도록 차단하거나 인가된 사용자에게만 원격 접속을 허용하는 기능을 제공 받을 수 있도록 보안설정 및 구성하는 절차를 사용자 매뉴얼에 명시하여야 함

예시	운영환경의 보안설정 및 구성
√ 방화벽에서 원격 접속 포트(예: SSH, telnet)에 대한 차단 정책을 통해 원격 접속 차단 √ 운영체제의 방화벽 설정, 네트워크 방화벽에서 특정 IP주소에서의 원격 접속 포트(예: SSH)에 대한 허용 정책, 다른 IP주소는 모두 차단 정책을 통해 제한된 원격 접속 허용	

제6조(기술적 보안)

① 디지털의료기기제조업자등은 디지털의료기기 및 그 운영 환경, 네트워크, 제품 관련 장비 및 자료보호 등을 위한 기술적 보안 사항을 고려하여야 한다.

② 디지털의료기기제조업자등은 디지털의료기기가 운영되는 기술적 보안 환경을 분석하고 각종 기술적 위협으로부터 보호할 수 있도록 대책을 마련하여야 한다.

③ 디지털의료기기제조업자등은 개인정보 또는 개인정보가 포함된 데이터 취득 또는 보관 시, 개인정보 보호를 위한 조치를 하여야 한다.

[의료기기의 사이버보안 허가·심사 가이드라인 관련 요구사항]

- DC-01 정보에 대한 기밀성 보장
- DC-02 보건의료정보 비식별화
- DC-03 안전한 암호화 사용

❑ 운영환경에서의 기술적 보안 사항 고려

○ 디지털의료기기제조업자등은 사전에 파악한 자사 제품 운영 환경에 대한 설치 및 운영 환경, 네트워크, 제품 관련 장비 및 자료 보호 등을 위한 기술적 보안 구성을 고려하여야 한다.

기술적 보안 구성이란, 디지털의료기기제조업자등이 자사 제품이 판매되어 실제 납품될 환경(예 : 병원, 의료원, 재활센터 등)에서 **기술적인 보안**을 준수할 수 있도록 **구성 체계를 준비하여 이를 납품될 환경에 적용**하는 것을 의미함
이는 디지털의료기기제조업자등이 납품 후 사용, 유지보수 등에 대한 제품 상에서의 보안만 다루는 것이 아니라 제품을 실제 사용해야 하는 환경에서도 보안 조치를 강구하기 위함임

※ 제품을 병원 등이 아닌 일반 가정 환경, 모바일 환경에서 사용할 경우 최소한의 기술적 보안 구성을 고려할 수 있으며 보안 구성에 대한 방법을 사용자 매뉴얼, 도움말 등을 통해 전달할 수 있음

○ 디지털의료기기 및 그 운영 환경, 네트워크, 제품 관련 장비 및 자료 보호 등을 위한 기술적 보안 사항을 고려하여야 한다.

- 의료서비스제공자 및 사용자 영역에서 운영할 경우, 해당 환경의 보안에 맞는 안전한 구성을 사용하여 기기의 보안을 강화하거나 강화할 수 있는 방법을 적용하여야 한다.

세부 내용 **운영환경의 보안설정 및 구성 - 의료서비스제공자 및 사용자 영역**

√ 디지털의료기기가 의료서비스제공자 및 사용자 영역에서 운영될 경우 디지털의료기기를 운영하는 기술적 보안환경에서 발생할 수 있는 각종 기술적 위협으로부터 보호할 수 있도록 대책을 사용자 매뉴얼에 명시하여야 함

· 보안에 안전한 구성을 사용하여 기기의 보안을 강화하거나 강화할 수 있는 방법에 관해 사용자 매뉴얼에 관련 내용을 명시하고, 관련 보안 활동을 권고하여야 함

√ 보안에 안전한 구성의 예

· 악성코드 방지 솔루션 연동
· DDoS 대응 장비 구축
· 방화벽: 방화벽 규칙, 화이트리스트
· 엔드포인트 보호 기능
· 물리적 보안 감지
· 네트워크 망분리
· VPN 통신 연결 등



<일반 구성>



<안전한 구성>

<출처> : ㈜아임넷

보안 활동		운영환경의 보안설정 및 구성 - 의료서비스제공자 및 사용자 영역
구분		설명
제1항 및 제2항 기준	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 설치 담당자, 의료서비스제공자 또는 사용자
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** - 디지털의료기기가 의료서비스제공자 및 사용자 영역에서 운영될 경우 디지털의료기기를 운영하는 기술적 보안환경에서 발생할 수 있는 각종 기술적 위협으로부터 보호할 수 있도록 명시하여야 함 - 보안에 안전한 구성을 사용하여 기기의 보안을 강화하거나 강화할 수 있는 방법을 명시하고, 관련 보안 활동을 권고하여야 함 **(기술적 보안구성 체크리스트)** - 디지털의료기기제조업자등의 설치 담당자가 설치 현장에 대한 기술적 보안구성 요건 확인을 위한 체크리스트를 사용할 수 있음

예시	기술적 보안구성 체크리스트

번호	점검 영역	점검 항목	확인 결과 (O/X)
1	네트워크 보안	방화벽 등의 네트워크 보안 장비 등으로 보호되고 있는가?	
2		내부망과 외부망이 물리적으로 또는 논리적으로 분리되어 있는가?	
3		방화벽 정책 등으로 인해 외부에서 공용 네트워크로 원격 접속할 수 없는 환경인가?	
4		DDoS(분산 서비스 거부) 대응 장비, WIPS(무선 네트워크 침입 방지 시스템) 등의 네트워크 공격으로부터 보호되고 있는가?	
5	데이터 보안	제품에 포함된 데이터베이스가 아닌 외부 데이터베이스를 사용하여 제품을 설치하는 경우, 데이터베이스 최소 보안 규칙(제8조 데이터 보안)이 적용되었는가?	
6		...	
7	운영 및 모니터링	제11조제1호제3호에 따라 제품이 설치된 시스템에 안티 바이러스 소프트웨어가 설치되어 있는가?	
8		보안 이벤트(감사 로그 등)를 관리하는 시스템이 운영되고 있는가?	
...	...	...	

<설치 현장에 대한 기술적 보안 구성 요건 확인을 위한 체크리스트>

예시	사용자 매뉴얼

√ 제품이 설치되어야 하는 네트워크 영역(인터넷망, DMZ, 내부망, 폐쇄망 등) 관련 내용 명시
√ 제품을 상호운용기기와 연결 시 동일 네트워크 영역에 위치해야 할 경우 관련 내용 명시 (예: 보안을 위해 내부망에서만 통신 허용)
√ 제품이 중요 정보를 데이터베이스 등에 저장할 경우 필요한 물리적 보안 구성 명시(예: 물리적으로 동일한 시스템에 함께 설치, 제품 및 데이터베이스를 분리하여 설치할 경우 각각의 네트워크 연결 설정 등)
√ 디지털의료기기의 운영환경에 대한 안전한 네트워크 구성 절차
√ 제품을 상호운용기기 또는 인프라와 연결 시 필요한 보안 관련 설정 기능 명시
· 디지털의료기기가 설치된 네트워크의 방화벽 설정 절차
· 디지털의료기기와 연동된 시스템 간의 VPN 설정 절차
· 디지털의료기기와 안티바이러스 솔루션 연동 절차
· 디지털의료기기의 네트워크와 인터넷 간의 망분리

- 디지털의료기기를 디지털의료기기제조업자등이 관리하는 인프라에 설치 및 운영할 경우, 디지털의료기기제조업자등은 기술적 보안환경에서 발생할 수 있는 각종 기술적 위협으로부터 보호할 수 있도록 대책을 마련하여야 한다.

세부 내용 **운영환경의 보안설정 및 구성 - 인프라**

√ 디지털의료기기제조업자등은 기술적 보안환경에서 발생할 수 있는 각종 기술적 위협으로부터 디지털의료기기를 보호할 수 있도록 인프라를 안전하게 구성 및 운영해야 함

· 디지털의료기기의 보안설정 및 구성을 통해 보안을 강화할 수 있는 방법을 적용하여야 함

· 인프라(데이터센터, 클라우드 등)에서 제공하는 서비스를 이용하여 디지털의료기기의 보안을 강화할 수 있도록 보안설정 및 구성을 적용하여야 함

예시 **운영환경의 보안설정 및 구성 - 인프라(클라우드 운영환경)**

√ (인프라) 클라우드 운영환경에서의 보안의 안전한 구성의 예

· 클라우드 서비스 제공자(CSP)의 네트워크 보안 서비스 이용: 방화벽, 웹 방화벽, DDoS (Distributed Denial of Service) 대응 기능, VPN(Virtual Private Network)으로 안전한 통신 채널 확보 등

· 접근 제어 서비스 이용: IAM(Identity and Access Management)을 통한 사용자 권한 관리

· 데이터 보안: 저장·전송 데이터 암호화 및 DLP(Data Loss Prevention)로 중요 데이터 유출 방지

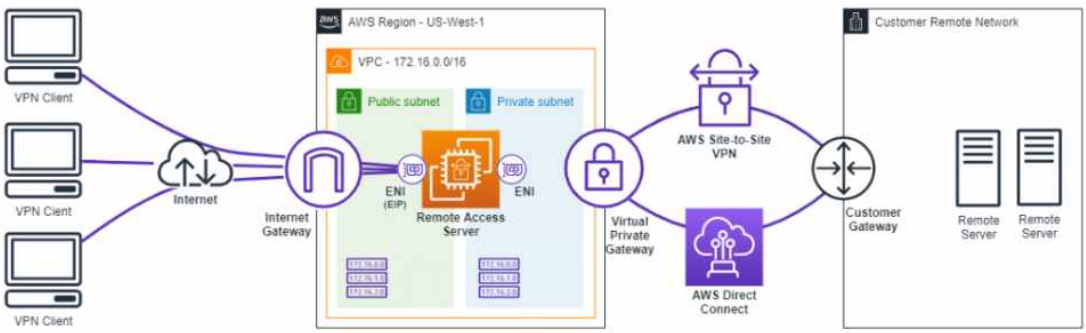
· 보안 감시: 보안 모니터링 시스템 구축, 로깅(Log) 및 이상 징후 분석



<클라우드 방화벽 서비스>



<클라우드 접근제어 서비스>



<클라우드 보안 서비스>

<출처> : AWS

○ 디지털의료기기제조업자등은 개인정보 또는 개인정보가 포함된 데이터를 수집하거나 저장할 경우, 이를 보호하기 위한 적절한 보안 조치를 시행하여야 한다.

보안 활동		디지털의료기기
구분		설명
제3항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** - 개인정보는 적법하고 정당하게 수집·이용하여야 하며, 정보주체의 동의를 근거로 수집하는 경우에는 적법한 방법으로 정보주체의 동의를 받아야 함 - 개인정보에 대한 암호화 등 안전성 확보에 필요한 조치를 제공하여야 함 - 디지털의료기기에 개인정보처리시스템이 포함될 경우 법적 요구사항을 만족하도록 운영하여야 함 - 개인정보에 대한 가명정보를 처리하는 경우 목적 제한, 가명처리 방법 및 기준, 적정성 검토, 재식별 금지 및 재식별 발생 시 조치사항 등 가명정보를 적정하게 처리하기 위한 절차를 수립·이행하여야 함
적용 예외 사항		디지털의료기기에 개인정보를 수집·보유·이용하지 않는 경우 본 항목은 '해당사항 없음'으로 처리함

- 개인정보는 적법하고 정당하게 수집·이용하여야 하며, 정보주체의 동의를 근거로 수집하는 경우에는 적법한 방법으로 정보주체의 동의를 받아야 한다.
- 개인정보에 대한 암호화 등 안전성 확보에 필요한 조치를 제공하여야 한다.
- 디지털의료기기에 개인정보처리시스템이 포함될 경우 법적 요구사항을 만족하도록 운영하여야 한다.
- 개인정보에 대한 가명정보를 처리하는 경우 목적 제한, 가명처리 방법 및 기준, 적정성 검토, 재식별 금지 및 재식별 발생 시 조치사항 등 가명정보를 적정하게 처리하기 위한 절차를 수립·이행하여야 한다.

< 가명정보란? >

√ '가명처리'란 개인정보의 일부를 삭제하거나 일부 또는 전부를 대체하는 등의 방법으로 추가 정보가 없이는 특정 개인을 알아볼 수 없도록 처리하는 것을 말함

√ '가명정보'란 개인정보를 가명처리함으로써 원래의 상태로 복원하기 위한 추가 정보의 사용·결합 없이는 특정 개인을 알아볼 수 없는 정보로서 개인정보의 범주에 포함됨

√ 가명정보는 가명정보 처리에 관한 특례에 따라 통계작성, 과학적 연구, 공익적 기록보존 등 3가지 목적에 대하여 정보주체의 동의 없이 이용·제공 등 처리 가능

※ 디지털의료기기에서 가명정보를 처리할 경우에만 적용하며, 디지털의료기기에서 개인정보를 수집하고, 가명정보 처리를 연동되는 별도의 시스템, 인프라 등에서 수행할 경우 적용하지 않음

- 디지털의료기기를 통해서 개인정보를 수집 및 보유하고 있을 경우, 권한이 있는 자만 접근할 수 있도록 인증 및 접근 통제를 실행하여야 한다.

<개인정보의 종류 예시>

- 고유식별정보 : 주민등록번호, 여권번호, 운전면허정보, 외국인등록번호
- 개인식별정보 : 이름, 주소, 전화번호, 휴대폰 번호, 이메일 주소, 생년월일, 성별 등
- 개인 관련 정보 : 학력, 직업, 키, 몸무게, 혼인여부, 가족구성, 취미 등
- 인증정보 : 비밀번호, 생체인식정보(지문, 홍채, 정맥 등)
- 신용정보/금융정보 : 신용정보, 신용카드번호, 계좌번호 등
- 의료정보 : 건강상태, 진료기록 등
- 위치정보 : 개인 위치정보 등
- 자동생성정보 : IP 정보, MAC 주소, 사이트 방문기록, 쿠키(cookie) 등
- 가공정보 : 통계성 정보, 가입자 성향 등
- 제한적 본인식별정보 : 회원번호, 사번, 내부용 개인식별정보 등

- 디지털의료기기에서 처리・전송・저장되는 개인정보는 비식별화 조치(예 : 암호화, 마스킹 처리 등)를 통해 안전하게 보호하여야 한다.

・법적 요구사항에 따라 지정된 개인정보를 저장할 경우, 안전한 암호 알고리즘으로 암호화하여 저장하여야 한다.

・인증정보 중 비밀번호를 저장하는 경우, 복호화되지 아니하도록 일방향 암호화하여 저장하여야 한다.

· 일방향 암호화는 개인정보취급자 및 정보주체 등이 입력한 비밀번호를 평문 형태가 아닌 해시함수 등을 통해 암호화한 데이터로 저장하는 것을 말한다.

※ 비밀번호 일방향 암호화 시 무작위 대입 공격, 레인보우 테이블 공격 등에 대응하기 위해 해시함수에 솔트값(입력 데이터에 무작위 데이터를 추가하여 해시값을 다르게 생성하기 위한 값)을 추가하여야 한다.

· 개인영상 정보와 같이 저장용량이 큰 정보를 저장하는 경우 특정 영역 마스킹 또는 부분 암호화, 자체 인코딩(Base64 등 쉽게 디코딩 가능한 단순 인코딩 제외)을 통해 비식별화 조치 요구사항을 대체할 수 있다.

<국내외 권고 암호 알고리즘>

분류		NIST(미국) (2015)	CRYPTREC(일본) (2013)	ECRYPT(유럽) (2018)	국내[1] (2018)
대칭키 암호 알고리즘 (블록암호)		AES 3TDEA[2]	AES Camellia	AES Camellia Serpent	SEED HIGHT ARIA LEA
해시함수		SHA-224 SHA-256 SHA-384 SHA-512 SHA-512/224 SHA-512/256 SHA3-224 SHA3-256 SHA3-384 SHA3-512	SHA-256 SHA-384 SHA-512	SHA-256 SHA-384 SHA-512 SHA-512/256 SHA3-256 SHA3-384 SHA3-512 SHA3-shake128[3] SHA3-shake256[3] Whirlpool-512 BLAKE-256 BLAKE-384 BLAKE-512	SHA-224 SHA-256 SHA-384 SHA-512 SHA-512/224 SHA-512/256 SHA3-224 SHA3-256 SHA3-384 SHA3-512 LSH-224 LSH-256 LSH-384 LSH-512 LSH-512-224 LSH-512-256
공개키 암호 알고리즘	키 공유용	DH ECDH MQV ECMQV	DH ECDH	ECIES-KEM PSEC-KEM RSA-KEM	DH ECDH
	암·복호화용	RSA	RSA-OAEP	RSA-OAEP	RSAES

<출처>: 암호 알고리즘 및 키 길이 이용 안내서(KISA,2018)

※「개인정보의 안전성 확보조치 기준」제7조(개인정보의 암호화)

① 개인정보처리자는 비밀번호, 생체인식정보 등 인증정보를 저장 또는 정보통신망을 통하여 송·수신하는 경우에 이를 안전한 암호 알고리즘으로 암호화하여야 한다. 다만, 비밀번호를 저장하는 경우에는 복호화되지 아니하도록 일방향 암호화하여 저장하여야 한다.

② 개인정보처리자는 다음 각 호의 해당하는 이용자의 개인정보에 대해서는 안전한 암호 알고리즘으로 암호화하여 저장하여야 한다.

1. 주민등록번호
2. 여권번호
3. 운전면허번호
4. 외국인등록번호
5. 신용카드번호
6. 계좌번호
7. 생체인식정보

- 중략 -

⑤ 개인정보처리자는 이용자의 개인정보 또는 이용자가 아닌 정보주체의 고유식별정보, 생체인식정보를 개인정보취급자의 컴퓨터, 모바일 기기 및 보조저장매체 등에 저장할 때에는 안전한 암호 알고리즘을 사용하여 암호화한 후 저장하여야 한다.

· 법적 요구사항에 따라 개인정보를 전송할 경우, 전송 구간에서의 도청을 방지하기 위해 암호화하여야 한다.

※「개인정보의 안전성 확보조치 기준」제7조(개인정보의 암호화)

④ 개인정보처리자는 개인정보를 정보통신망을 통하여 인터넷망 구간으로 송·수신하는 경우에는 이를 안전한 암호 알고리즘으로 암호화하여야 한다.

· 내부망과 외부망(예: 인터넷망 등)을 포함한 모든 통신망에서 인증정보 송수신 시, 이를 안전한 암호 알고리즘으로 암호화하여야 한다.

※ 국내/외에서 안전성이 검증된 보안강도 112비트 이상을 가지는 암호화 알고리즘을 사용하여야 한다.

· 송·수신 암호화 방법으로는 통신구간 암호화 프로토콜(예: SSL/TLS 등), 응용프로그램을 통한 암호화 전송 등의 방법을 사용할 수 있다.

- 법적 요구사항에 따라 개인정보를 파기할 경우, 안전한 조치를 마련하고 제공하여야 한다.

※「개인정보의 안전성 확보조치 기준」제13조(개인정보의 파기)

① 개인정보처리자는 개인정보를 파기할 경우 다음 각 호 중 어느 하나의 조치를 하여야 한다.

1. 완전파괴(소각・파쇄 등)
2. 전용 소자장비(자기장을 이용해 저장장치의 데이터를 삭제하는 장비)를 이용하여 삭제
3. 데이터가 복원되지 않도록 초기화 또는 덮어쓰기 수행

② 개인정보처리자가 개인정보의 일부만을 파기하는 경우, 제1항의 방법으로 파기하는 것이 어려울 때에는 다음 각 호의 조치를 하여야 한다.

1. 전자적 파일 형태인 경우 : 개인정보를 삭제한 후 복구 및 재생되지 않도록 관리 및 감독
2. 제1호 외의 기록물, 인쇄물, 서면, 그 밖의 기록매체인 경우 : 해당 부분을 마스킹, 구멍 뚫기 등으로 삭제

- 디지털의료기기에 개인정보처리시스템이 포함될 경우, 법적 요구사항을 만족하도록 운영하여야 한다.

※「개인정보의 안전성 확보조치 기준」제2조(정의)

이 기준에서 사용하는 용어의 뜻은 다음과 같다.

1. "개인정보처리시스템"이란 데이터베이스시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성한 시스템을 말한다.

- 중략 -

3. "접속기록"이란 개인정보처리시스템에 접속하는 자가 개인정보처리시스템에 접속하여 수행한 업무내역에 대하여 식별자, 접속일시, 접속지 정보, 처리한 정보주체 정보, 수행업무 등을 전자적으로 기록한 것을 말한다. 이 경우 "접속"이란 개인정보처리시스템과 연결되어 데이터 송신 또는 수신이 가능한 상태를 말한다.

・개인정보처리시스템에 대한 접근권한을 최소한의 범위로 부여하고, 권한 부여 기록을 최소 3년간 보관하며, 인증 수단을 안전하게 적용하고 관리하는 등 안전하게 운영하여야 한다.

※「개인정보의 안전성 확보조치 기준」제5조(접근 권한의 관리)

① 개인정보처리자는 개인정보처리시스템에 대한 접근 권한을 개인정보취급자에게만 업무 수행에 필요한 최소한의 범위로 차등 부여하여야 한다.

② 개인정보처리자는 개인정보취급자 또는 개인정보취급자의 업무가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근 권한을 변경 또는 말소하여야 한다.

③ 개인정보처리자는 제1항 및 제2항에 의한 권한 부여, 변경 또는 말소에 대한 내역을 기록하고, 그 기록을 최소 3년간 보관하여야 한다.

④ 개인정보처리자는 개인정보처리시스템에 접근할 수 있는 계정을 발급하는 경우 정당한 사유가 없는 한 개인정보취급자 별로 계정을 발급하고 다른 개인정보취급자와 공유되지 않도록 하여야 한다.

⑤ 개인정보처리자는 개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리하여야 한다.

⑥ 개인정보처리자는 정당한 권한을 가진 개인정보취급자 또는 정보주체만이 개인정보처리시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 개인정보처리시스템에 대한 접근을 제한하는 등 필요한 조치를 하여야 한다.

- 개인정보처리시스템에 대한 불법적인 접근 및 침해사고 방지를 위해 안전한 조치를 하여야 한다.

※「개인정보의 안전성 확보조치 기준」제6조(접근통제)

① 개인정보처리자는 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 다음 각 호의 안전조치를 하여야 한다.

1. 개인정보처리시스템에 대한 접속 권한을 인터넷 프로토콜(IP) 주소 등으로 제한하여 인가받지 않은 접근을 제한

2. 개인정보처리시스템에 접속한 인터넷 프로토콜(IP) 주소 등을 분석하여 개인정보 유출 시도 탐지 및 대응

② 개인정보처리자는 개인정보취급자가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하여야 한다. 다만, 이용자가 아닌 정보주체의 개인정보를 처리하는 개인정보처리시스템의 경우 가상사설망 등 안전한 접속수단 또는 안전한 인증수단을 적용할 수 있다.

③ 개인정보처리자는 처리하는 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 개인정보취급자의 컴퓨터 및 모바일 기기 등에 조치를 하여야 한다.

④ 개인정보처리자는 개인정보처리시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 일정시간 이상 업무처리를 하지 않는 경우에는 자동으로 접속이 차단되도록 하는 등 필요한 조치를 하여야 한다.

⑤ 개인정보처리자는 업무용 모바일 기기의 분실·도난 등으로 개인정보가 유출되지 않도록 해당 모바일 기기에 비밀번호 설정 등의 보호조치를 하여야 한다.

⑥ 전년도 말 기준 직전 3개월간 그 개인정보가 저장·관리되고 있는 이용자 수가 일일평균 100만명 이상인 개인정보처리자는 개인정보처리시스템에서 개인정보를 다운로드 또는 파기할 수 있거나 개인정보처리시스템에 대한 접근 권한을 설정할 수 있는 개인정보취급자의 컴퓨터 등에 대한 인터넷망 차단 조치를 하여야 한다. 다만,「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」제2조제3호에 따른 클라우드컴퓨팅서비스를 이용하여 개인정보처리시스템을 구성·운영하는 경우에는 해당 서비스에 대한 접속 외에는 인터넷을 차단하는 조치를 하여야 한다.

· 개인정보처리시스템에 대한 접속기록은 법적 요구사항을 준수할 수 있도록 필요한 항목을 모두 포함하여 일정 기간 안전하게 보관하여야 한다.

<접근 권한 내역·보관 기록 예시>

번호	사용자ID	사용자명	권한명	권한ID	유형	일자	작업자	사유	…
…									
51503	cskim	김철수	회원관리자	S0002	부여	20190220 10:22:01	gdhong	담당업무 변경	…
51504	yhkim	김영희	상담관리자	C0005	부여	20181210 09:50:33	gdhong	상담팀 입사	…
51505	yhkim	김영희	상담관리자	C0005	말소	20190420 13:55:20	gdhong	퇴사	…
…									

<출처>: 개인정보의 안전성 확보조치 기준 안내서(개인정보보호위원회,2024)

※「개인정보의 안전성 확보조치 기준」 제8조(접속기록의 보관 및 점검)

① 개인정보처리자는 개인정보취급자의 개인정보처리시스템에 대한 접속기록을 1년 이상 보관·관리하여야 한다. 다만, 다음 각 호의 어느 하나에 해당하는 경우에는 2년 이상 보관·관리하여야 한다.

1. 5만명 이상의 정보주체에 관한 개인정보를 처리하는 개인정보처리시스템에 해당하는 경우
2. 고유식별정보 또는 민감정보를 처리하는 개인정보처리시스템에 해당하는 경우
3. 개인정보처리자로서 「전기통신사업법」제6조제1항에 따라 등록을 하거나 같은 항 단서에 따라 신고한 기간통신사업자에 해당하는 경우

② 개인정보처리자는 개인정보의 오·남용, 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위하여 개인정보처리시스템의 접속기록 등을 월 1회 이상 점검하여야 한다. 특히 개인정보의 다운로드가 확인된 경우에는 내부 관리계획 등으로 정하는 바에 따라 그 사유를 반드시 확인하여야 한다.

③ 개인정보처리자는 접속기록이 위·변조 및 도난, 분실되지 않도록 해당 접속기록을 안전하게 보관하기 위한 조치를 하여야 한다.

· 화재, 홍수, 단전 등의 재해 · 재난 발생 시 개인정보처리시스템 보호를 위한 조치를 하여야 한다.

※「개인정보의 안전성 확보조치 기준」 제11조(재해·재난 대비 안전조치)

10만명 이상의 정보주체에 관하여 개인정보를 처리하는 대기업·중견기업·공공기관 또는 100만명 이상의 정보주체에 관하여 개인정보를 처리하는 중소기업·단체에 해당하는 개인정보처리자는 화재, 홍수, 단전 등의 재해·재난 발생 시 개인정보처리시스템 보호를 위한 다음 각 호의 조치를 하여야 한다.

1. 위기대응 매뉴얼 등 대응절차를 마련하고 정기적으로 점검
2. 개인정보처리시스템 백업 및 복구를 위한 계획을 마련

· 개인정보처리시스템에서 개인정보의 출력 시 용도에 따라 출력 항목을 최소화하여야 한다.

※「개인정보의 안전성 확보조치 기준」 제12조(출력·복사시 안전조치)

① 개인정보처리자는 개인정보처리시스템에서 개인정보의 출력시(인쇄, 화면표시, 파일생성 등) 용도를 특정하여야 하며, 용도에 따라 출력 항목을 최소화하여야 한다.

제7조(파일 및 입력 유효성)

디지털의료기기제조업자등은 다음 각 호의 사항을 고려하여 디지털의료기기 및 그 운영 환경의 중요 파일 및 입력 유효성 확보 방안을 마련하여야 한다.

1. 파일을 업로드하는 경우 파일 확장자, 형식 등 유효성 및 무결성 검증
2. 파일을 다운로드하는 경우 해시값 비교 등 원본 파일과의 동일 여부에 대한 유효성 및 무결성 검증
3. 디지털의료기기에서 작동 가능한 실행 파일 업로드 방지
4. 입력 데이터 검증, 버퍼 초과 오류 검증 등 입력 정보의 유효성 검증

[의료기기의 사이버보안 허가·심사 가이드라인 관련 요구사항]

- SI-05 입력값 검증
- UC-02 모바일 코드 사용 통제

❑ 중요 파일 및 입력 유효성 확보 방안

○ 디지털의료기기 파일을 업로드하는 경우, 악성 실행 파일 업로드를 방지할 수 있도록 확장자, 형식 등 유효성 및 무결성 검증 기능을 제공하여야 한다.

세부 내용	디지털의료기기
√ 디지털의료기기가 파일 업로드 기능이 제공되는 경우, 업로드 대상 파일에 대해 유효성 검증 기능을 제공하여야 함 · 허용된 파일 확장자 등에 대한 일치 여부 검사 · 업로드 전 파일 크기에 대한 제한 설정 · 디지털 서명, 해시값(예 : SHA-256), 체크섬 등을 활용한 파일 무결성 확인 등 · 허용된 파일 형식 외에 업로드 시도를 차단하도록 구현하여야 하며, exe, bat, sh, js 등의 실행 파일 또는 스크립트 파일(asp, jsp, php, html 등) 업로드를 원천적으로 차단 (실행 파일을 압축하여 업로드하는 경우에도 이를 감지하여 차단하여야 함) √ 디지털의료기기가 파일 업로드 기능이 제공되는 경우, 업로드 대상 파일 무결성(진본 여부 확인) 검증 기능을 제공하여야 함 · 원본 파일의 해시값(예: SHA-256 등)과 업로드하려는 파일의 해시값을 비교하여 두 값이 일치하는지에 대한 검증 수행	

보안 활동		디지털의료기기
구분		설명
제1항 기준	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기의 파일 업로드 기능에서 파일 확장자, 형식 등 유효성 및 무결성 검증을 제공하여야 함

예시 디지털의료기기

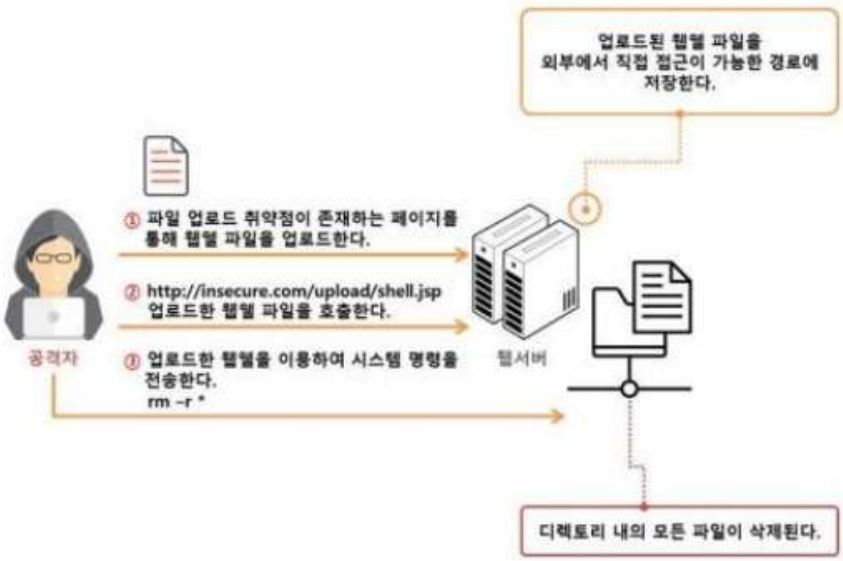
√ 파일 업로드 기능에서 유효성 검증 기능 제공

· 파일 업로드 기능에서 입력값 검증 기능 제공

· 허용되지 않은 확장자 파일(예 : json, png, csv 등)에 대한 업로드 차단

· 정의된 최대 파일 크기보다 큰 파일을 업로드하는 경우, 오류 메시지, 에러 코드 제공, 업로드 시도 제한 등의 검증 방법 제공

· 이미지 파일(예 : DCM) 업로드 기능이 제공되는 경우, 이미지 파일 외의 다른 파일이 업로드 되지 않도록 차단



<허용되지 않은 파일 확장자 및 형식 업로드>

<출처>: KISA 소프트웨어 개발보안 가이드(2021)

예시	디지털의료기기

```
from flask import  request, abort


Flask(__name__)
ALLOWED_EXTENSIONS = 'txt','pdf','png','jpg','

def allowed_file(fienaame):
    return '.' in filename and \
          filename.rsplit('.',),1)[1].lower() in

@app.route('/upload', methods=['POST']
def upload_file():
    file = request.files[file.filename):
    if file and allowed_file(filename):
      // 파일 저장 로직
      return 'File accected'
  else:
    abort(400, description=허용되지 않은
    확장자입니다.
```

<허용되지 않은 확장자 파일 시도 차단>



<파일 사이즈 에러 코드 제공>

√ 파일 업로드 기능에서 무결성 검증 기능 제공

· 업로드하려는 파일에 대한 해시값(예: SHA-256 등)을 생성하여 원본 파일의 해시값과 일치하지 않을 경우 업로드 차단

❍ 디지털의료기기에서 파일을 다운로드하는 경우, 원본 파일과의 동일 여부에 대한 유효성 및 무결성 검증 기능을 제공하여야 한다.

세부 내용 **디지털의료기기**

√ 디지털의료기기에서 파일을 다운로드하는 경우 해시값(SHA-256 등) 비교, 체크섬, 디지털 서명 검증 절차 등 유효성 및 무결성 검증 기능을 제공해야 함

√ 다운로드 과정에서 보안 프로토콜(예 : HTTPS) 사용을 통해 구간 내 파일 내용이 변조되지 않았는지 체크섬 또는 해시값 비교 등을 통해 검증을 수행하여야 함

보안 활동 **디지털의료기기**

구분		설명
제7조 전체	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기의 파일 다운로드 기능에서 해시값 비교 등 유효성 및 무결성 검증 기능을 제공해야 함

예시 **디지털의료기기**

√ 파일 다운로드 기능에서 무결성 검증 기능 제공

· 디지털의료기기는 파일에 대한 해시값(예: SHA-256 등)을 생성하여 다운로드되는 파일과 해시값 파일을 함께 제공

· 디지털의료기기는 다운로드 파일에 디지털 서명을 생성하여 제공

○ 디지털의료기기는 허용된 파일 외에 실행 파일의 업로드 차단을 위하여 유효성 및 무결성 검증 기능을 제공하여야 한다.

세부 내용	디지털의료기기

√ 파일 업로드 기능에서 실행 파일 업로드 차단 기능 제공
· 제품에서 사용해야 하는 파일 외에 실행 파일(예: exe, bat, sh 등) 및 실행 가능한 스크립트 파일(예: js, py, php 등)에 대한 업로드 차단
√ 사용자(사람, 기기, 소프트웨어)가 모바일 코드 송수신 시 실행 통제
· 모바일 코드 실행 전에 무결성 점검 결과를 기반으로 모바일 코드 실행 통제
※ 모바일 코드란, 수신자가 명시적으로 설치하지 않아도 실행되는 자산들 사이에 전송되는 프로그램으로 사용자의 별도 상호작용 없이 자동으로 다운로드 받은 환경에서 단독으로 실행되는 코드를 포함(JavaScript, VBScript, Java Applets, ActiveX 컨트롤러, Flash 애니메이션, Shockwave 동영상 및 MS office 매크로 등)

보안 활동	디지털의료기기

구분		설명
제7조 전체	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기의 파일 업로드 기능에서 허가된 파일을 제외한 실행 파일 업로드를 차단해야 함

예시	디지털의료기기

√ 실행 파일에 대한 업로드 차단
√ 업로드 전 디지털 서명 검증을 통해 신뢰된 실행 파일만 업로드 허용

○ 디지털의료기기는 입력 데이터 검증, 버퍼 초과 오류 검증 등 악의적인 입력이나 예상치 못한 동작이 발생하지 않도록 차단하기 위하여 입력 정보의 유효성 검증 기능을 제공하여야 한다.

세부 내용	디지털의료기기

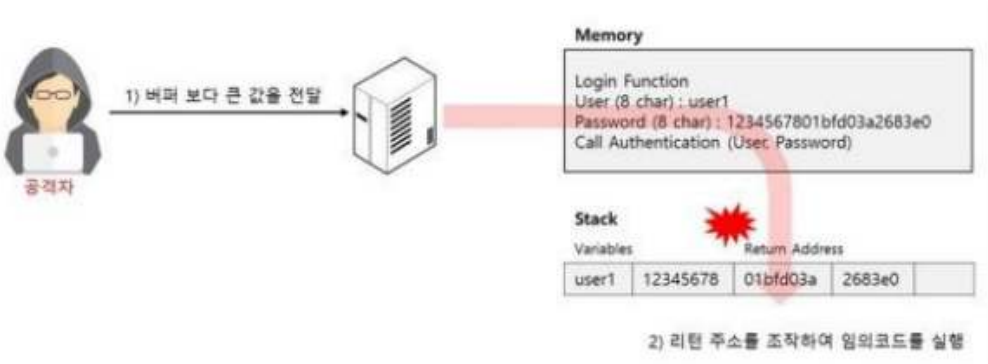
√ 사용자 또는 외부 시스템으로부터 입력을 받는 모든 필드에 대해 입력값 검증 기능을 제공해야 함
- 자릿수 제한, 입력 형식 제한
- 허용되지 않는 특수문자 및 제어문자(₩r, ₩n 등), 이스케이프 처리(Escape Handling)
- 지나치게 긴 입력으로 인한 버퍼 초과(오버플로우) 방지
- SQL Injection 및 크로스사이트 스크립트(XSS) 방지
- 운영체제 명령어(rm –rf, ls / 등) 삽입 방지 등
- 잘못된(malformed) 패킷 검증 등

보안 활동		디지털의료기기
구분		**설명**
제7조 전체	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기에서 입력 데이터 검증, 버퍼 초과 오류 검증 등 입력 정보의 유효성 검증을 제공해야 함

예시 **디지털의료기기**

√ 입력 필드에 대한 자릿수, 입력값 기준(숫자/문자 등), 버퍼 오버플로우를 발생시킬 수 있는 문자열에 대한 입력 차단 등 입력 정보에 대한 유효성 검증

※ 버퍼 오버플로우 : 스택(Stack)이나 힙(Heap)에 할당되는 메모리에 문자열 등이 저장될 때 최초 정의된 메모리의 크기를 초과하여 문자열을 저장하는 경우 버퍼 오버플로우 발생



< 버퍼 오버플로우 발생 예시 >

<출처>: KISA 소프트웨어 개발보안 가이드(2021)

예시 **디지털의료기기**

√ 프레임워크 및 라이브러리 이용하여 SQL Injection 및 크로스사이트 스크립트(XSS) 방지

· XSS 방어를 위한 라이브러리 및 클래스 예시

개발환경	활용 가능한 프레임워크 또는 라이브러리
ASP.NET	• MS Anti-XSS Library: http://wpl.codeplex.com/ • ASP.NET 웹기반 애플리케이션 개발 시, XSS공격으로부터 안전할 수 있도록 도와주는 인코딩 라이브러리이다.
	• MS AntiXSSEncoder 클래스: http://social.msdn.microsoft.com/Search/en-US?query=antixssencoder&pgArea=header&emptyWatermark=true&ac=4 • HTLM, XML, CSS, URL 문자열을 인코딩하여 XSS공격의 위협에 대응할 수 있는 클래스이다. HttpEncoder클래스의 HttpUtility, HttpServerUtility, HttpResponseHeader 메소드를 오버라이드하여 사용가능하다.
	• HTML Sanitizer 라이브러리: https://github.com/mganss/HtmlSanitizer • HTML/CSS문서를 파싱하고 조작하여 XSS공격으로 이어질 수 있는 구조를 정리해주는 XSS 방어 라이브러리이다. HTML 파서를 기반으로 하기 때문에 HTML태그의 변조도 방지 가능하다. MIT License에 따라 사용가능하다.
Java	• LUCY XSS Filter: http://github.com/naver/lucy-xss-filter • 웹 애플리케이션을 XSS공격으로부터 보호하기 위한 화이트리스트 설정방식의 자바 라이브러리이다. Apache Software License v2.0 정책에 따라 자유롭게 사용가능하다.
PHP	• OWASP ESAPI XSS Filter: https://www.owasp.org/index.php/Category:OWASP_Enterprise_Security_API • ESAPI(Enterprise Security API)는 웹 애플리케이션 개발 과정에서 발생하는 다양한 보안 침해사고를 해결하기 위해 OWASP에서 OWASP TOP10과 함께 해당 문제점을 개선하기 위해 제작, 배포되는 보안 라이브러리이다.
	• HTML Purifier 라이브러리: http://htmlpurifier.org/ • XSS, SQL인젝션 방어를 제공하는 화이트리스트 구현방식의 HTML 필터 라이브러리이다. LGPL v2.1+에 따라 사용가능하다.

출처: KISA 소프트웨어 개발보안 가이드(2021)

√ SQL 삽입(Injection) 보안약점 대응 프레임워크 및 라이브러리

개발환경	활용 가능한 프레임워크 또는 라이브러리
Java	• Hibernate: http://hibernate.org/ • 자바언어를 위한 객체관계매핑(ORM) 프레임워크, 객체지향도메인 모델을 관계형 데이터베이스로 매칭하기 위한 프레임워크로 GNU LGPL v2.1*로 배포되는 자유 소프트웨어이다. * LGPL(Lesser General Public License)은 LGPL로 작성된 소스코드를 라이브러리(정적, 동적)로만 사용하는 경우에는 소스코드를 공개하지 않아도 된다. 그 외의 경우에는 수정한 소스코드 또는 GPL 소스코드를 활용한 소프트웨어 모두를 GPL로 공개해야 한다. 상업적 목적으로 사용가능하며 배포, 수정이 가능하고 이 때 라이선스 및 저작권, 변경사항을 명시해야 한다
	• Mybatis: http://blog.mybatis.org/ • 객체지향언어인 자바의 관계형 데이터페이스 프로그래밍을 좀 더 쉽게 도와주는 개발 프레임워크이다. • Apache Software License v2.0* 정책에 따라 자유롭게 사용 가능하다. * Apache Software License 2.0 은 누구든 자유롭게 아파치 소프트웨어를 다운 받아 부분 혹은 전체를 개인적 혹은 상업적 목적으로 이용할 수 있으며 재배포시에는 원본소스코드 또는 수정한 소스코드를 반드시 포함시키지 않아도 되지만 아파치 라이센스 버전 2.0을 포함시켜야 하며 아파치 소프트웨어 재단에 개발된 소프트웨어라는 것을 명확하게 밝혀야 한다.
	• JPA(Java Persistence API): https://jcp.org/en/home/index • 관계형 데이터베이스에 접근하기 위한 표준 ORM 기술을 제공하며, 자바플랫폼, 표준 에디션 및 자바플랫폼, 엔터프라이즈에디션을 사용하는 애플리케이션에서의 관계형데이터 관리를 목적으로 하는 프로그래밍 인터페이스다.
ASP.NET (확장가능)	• AntiSQLi 라이브러리: http://ironbox.github.io/AntiSQLi/ • SQL인젝션의 위협이 있는 데이터를 자동으로 파라미터화하는 오픈소스 라이브러리이다. BSD License*에 따라 사용할 수 있다. * BSD License는 자유소프트웨어 저작권의 일종으로써, 해당 소프트웨어는 누구나 부분 혹은 전체적으로 수정가능하고 제한 없이 재배포할 수 있다. 수정한 소스코드는 의무적으로 재배포하지 않아도 되므로 상용 소프트웨어에도 사용할 수 있다.
PHP	• MeekroDB 라이브러리: http://meekro.com/ • SQL인젝션 방어를 위한 PHP-MySQL 오픈소스 라이브러리이며, LGPLv3 License에 따라 사용가능하다.
	• HTML Purifier 라이브러리: http://htmlpurifier.org/ • XSS, SQL인젝션 방어를 제공하는 화이트리스트 구현방식의 HTML 필터 라이브러리이다. LGPL v2.1+에 따라 사용가능하다.

출처: KISA 소프트웨어 개발보안 가이드(2021)

제8조(데이터 보안)

디지털의료기기제조업자등은 다음 각 호의 사항을 고려하여 디지털의료기기 및 그 디지털의료기기가 작동하는 운영 환경의 중요 데이터 보안 방안을 마련하여야 한다.

1. 안전한 데이터베이스 패스워드 설정, 패스워드의 주기적 변경, 미사용 중인 관리자 계정 삭제 등 데이터베이스 보안 관리
2. 개인정보에 대한 암호화 등 데이터 비식별화 조치
3. 시스템 간 데이터 송수신 시, 데이터 암호화 또는 보안 통신 적용 등 암호화 조치
4. 국내 · 외 암호화 알고리즘 사용 시, 널리 권고되는 암호화 및 해시 알고리즘 사용

[의료기기의 사이버보안 허가·심사 가이드라인 관련 요구사항]

- IA-05 비밀번호 강도 설정
- DC-01 정보에 대한 기밀성 보장
- DC-02 보건의료정보 비식별화
- DC-03 안전한 암호화 사용
- SI-01 통신에 대한 무결성 보장

❑ 데이터 보안 방안

○ 안전한 데이터베이스 패스워드 설정, 패스워드의 주기적 변경, 미사용 중인 관리자 계정 삭제 등 체계적이고 지속적인 데이터베이스 보안 관리를 철저히 진행하여야 한다.

세부 내용	디지털의료기기 & 운영환경

√ 데이터베이스의 디폴트 패스워드(비밀번호)는 변경하여 사용하여야 함
√ 비밀번호 설정 또는 변경 시 비밀번호 설정 지침(예: 정보통신망연결기기등 정보보호인증기준 상세 해설서)에 따른 비밀번호 강도를 적용하여야 함
· 최소길이 8자리 이상 필수
· 영문자(대소), 숫자, 특수문자 중 3가지 이상을 필수 조합
√ 데이터베이스에서 사용하지 않는 계정, 테스트용 계정, 기본 계정 등 삭제하여야 함

- 의료서비스제공자가 운영하는 데이터베이스와 연동하거나 디지털의료기기제조업자의 설치 담당자가 데이터베이스를 설치하는 경우, 데이터베이스를 안전하게 구성하도록 사용자 매뉴얼에 관련 절차를 명시하여야 한다.

보안 활동		**운영환경의 보안설정 및 구성**
구분		**설명**
제1항 기준	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자 (디지털의료기기제조업자등의 설치 담당자)
	보안활동 수행 결과 (output)	**(사용자 매뉴얼)** 데이터베이스의 디폴트 패스워드 변경, 패스워드 주기적 변경, 미사용 계정 삭제 등을 수행하도록 명시하여야 함

예시	**사용자 매뉴얼**
√ 디지털의료기기에서 사용하는 데이터베이스의 디폴트 패스워드 변경하여 사용하도록 관련 내용 명시 √ 디지털의료기기에서 사용하는 데이터베이스의 비밀번호 설정 및 변경 시 비밀번호 설정 지침을 따르도록 관련 내용 명시 √ 디지털의료기기에서 사용하는 데이터베이스의 사용하지 않는 계정, 테스트용 계정, 기본 계정 등 삭제하도록 관련 내용 명시	

- 디지털의료기기를 디지털의료기기제조업자등이 관리하는 인프라에 설치 및 운영할 경우, 디지털의료기기제조업자등은 데이터베이스를 안전하게 구성하여야 한다.

보안 활동		데이터베이스
구분		설명
제1항 기준	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 인프라 운영 담당자
	보안활동 수행 결과 (output)	**(데이터베이스)** 디지털의료기기에서 사용하는 데이터베이스를 인프라에서 운영할 경우, 디지털의료기기제조업자등은 데이터베이스의 디폴트 패스워드 변경, 패스워드 주기적 변경, 미사용 계정 삭제 등을 수행해야 함

예시	데이터베이스
√ 데이터베이스 설치 후 디폴트 패스워드 변경 √ 비밀번호 설정 지침의 비밀번호 강도에 따라 데이터베이스의 비밀번호 설정 √ 데이터베이스에서 사용하지 않는 계정, 테스트용 계정, 기본 계정 등 삭제	

○ 개인정보에 대한 암호화 등 적절한 데이터 비식별화 조치를 시행하고, 이를 통해 외부 침해나 내부 유출과 같은 잠재적 위험으로부터 개인정보 자산을 안전하게 보호하여야 한다.

- 개인정보 저장 시 비식별화(예: 암호화, 마스킹처리 등)가 조치를 수행하여야 한다.

세부 내용	디지털의료기기 & 운영환경

√ 디지털의료기기 및 운영환경은 개인정보 저장 시 비식별화를 통해 기밀성을 보장하여야 함
· 디지털의료기기에서 구현된 암호화 기능을 이용하여 개인정보 저장 시 암호화
· 디지털의료기기에서 개인정보의 일부 정보를 마스킹 처리
· 디지털의료기기가 데이터베이스에 개인정보 저장 시 운영환경(DB 암호화 솔루션 등)에서 제공하는 기능을 이용하여 암호화

보안 활동	디지털의료기기	
구분		**설명**
제2항 기준	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	※ 제6조(기술적 보안)의 ③ 내용 참조

예시	디지털의료기기

√ 디지털의료기기의 사용자 계정으로 환자 전화번호를 조회할 경우, 010-****-1234와 같이 마스킹 처리되어 환자 개별 식별이 불가하며, 원본 데이터 조회는 접근 거부
√ 디지털의료기기의 관리자 계정에서 개인정보에 대한 복호화를 요청하는 경우에는 사전 승인 절차 및 사유 기록이 필수적으로 남고, 해당 내역은 감사 로그에 자동 저장되어 정기적으로 검토
√ 백업 파일에 대한 정기적·무작위 검사를 통해 개인정보 컬럼이 평문으로 출력되지 않음을 검증하고, 그 결과를 점검 보고서로 관리

❍ 시스템 간 데이터 송수신 시, 데이터 암호화 또는 보안 통신 적용 등 적절한 암호화 조치하여야 한다. 이를 통해 전송 과정에서 발생할 수 있는 잠재적 보안 위협을 예방하여야 한다.

세부 내용	디지털의료기기 & 운영환경

√ 디지털의료기기 및 운영환경은 데이터 암호화 또는 신뢰된 암호통신 프로토콜을 사용하여 전송되는 중요정보의 기밀성·무결성을 보장하여야 함

√ 암호화 위치, 시스템 특성 등을 고려하여 암호화 방식을 적용하여야 함

· 보안 통신을 적용하는 방식의 예

- SSL(Secure Socket Layer) 인증서를 설치하여 전송하는 정보를 암호화 송수신
- 암호화 응용프로그램을 설치하여 전송하는 정보를 암호화 송·수신
- VPN(Virtual Private Network 통신을 통해 암호화 송·수신

· 데이터를 암호화하여 전송하는 방식의 예

- PGP(Pretty Good Privacy)를 통해 전송하는 정보를 암호화

√ 공개된 암호통신 프로토콜을 사용하는 경우, 프로토콜 버전, 암호 알고리즘, 모드, 옵션 등에 따라 취약점이 존재하므로 안전하게 설정하여 사용하여야 함

· 취약한 암호통신 프로토콜(TLS 1.1 이하, SSH v1, WPA, TKIP 등)은 지원되지 않도록 제거하거나 비활성화하여야 함

- 디지털의료기기는 데이터 암호화 또는 보안 통신 기능을 제공할 수 있다.

보안 활동	디지털의료기기	
구분		**설명**
제3항 기준	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 개인정보 및 주요 정보의 보호를 위하여 법적 요구사항, 처리 정보 민감도 및 중요도를 반영하여 시스템 간 전송되는 개인정보 및 중요정보를 암호화
적용 예외 사항		- 기밀성이 요구되지 않는 정보의 경우 무결성만이 보장되도록 전송할 수 있음 - 전용망 또는 전용망으로 간주될 수 있는 전송선로*를 통해 중요정보가 전송되는 경우 본 항목에 대해 '해당사항 없음'으로 처리하고 사유를 작성 * 전송선로 : 기기에 장착된 물리적 포트로 직접 연결되어 데이터를 전송하는 수단 (시리얼 통신, HDMI, USB 연결 등)

예시	디지털의료기기

√ 디지털의료기기에서 의료영상데이터 전송 시 TLS 1.2 프로토콜을 사용하여 암호화 전송

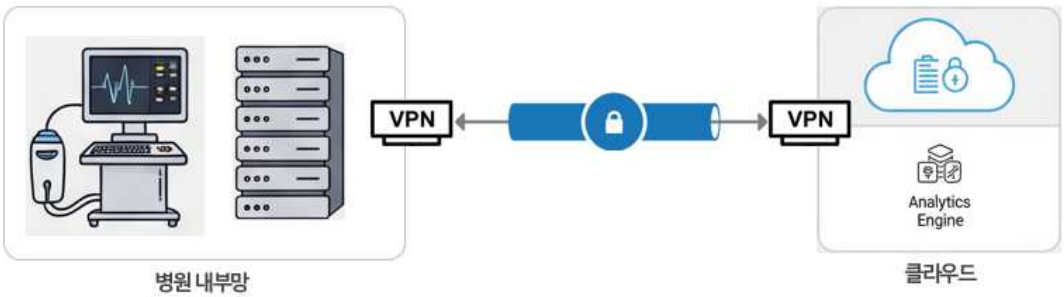
√ 디지털의료기기의 웹 보안관리 화면에서 입력된 인증정보를 HTTPS 프로토콜을 사용하여 암호화 전송

- 운영환경의 보안설정 및 구성을 통해 디지털의료기기가 전송하는 데이터에 대한 암호화를 수행할 수 있다.

보안 활동		운영환경의 보안설정 및 구성
구분		설명
제3항 기준	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자 (디지털의료기기제조업자등의 설치 담당자)
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** 디지털의료기기의 네트워크 환경을 고려하여 보안 통신을 적용받을 수 있도록 절차를 명시하여야 함

예시 **운영환경의 보안설정 및 구성**

√ 디지털의료기기는 2개로 구성되며 중요 정보를 전송함
· 병원 내에서 환자의 의료영상데이터를 수집하는 내장형 디지털의료기기 소프트웨어 기능
· 인프라에서 의료영상데이터를 분석하는 독립형 디지털의료기기 소프트웨어 기능
· 디지털의료기기 간 의료영상데이터 전송
√ 병원과 인프라 간의 VPN 채널
· 병원 내 내부망에 위치한 디지털의료기기가 인터넷망을 통해 디지털의료기기제조업자등이 운영하는 인프라 내 디지털의료기기(AI 분석 기능)로 의료영상데이터를 전송할 경우 병원의 게이트웨이부터 인프라의 게이트웨이까지 VPN(Virtual Private Network) 채널을 맺어 암호화 송수신
· 병원의 VPN 솔루션은 의료서비스제공자가 구축 및 운영할 수 있음
· 인프라(클라우드 환경 등)의 VPN 솔루션은 디지털의료기기제조업자등이 구축 및 운영하여야 함



√ 암호화 응용프로그램을 설치하여 전송하는 데이터를 암호화 송수신
√ PGP(Pretty Good Privacy)를 통해 데이터를 암호화한 후 전송

○ 국내·외 암호화 알고리즘 사용 시, 보안 표준으로 널리 권고되는 암호화 및 해시 알고리즘 사용하여야 하며, 이를 통해 안정성과 신뢰성을 확보하고 보안 취약점을 최소화하여야 한다.

세부 내용 **디지털의료기기**

√ 국내·외에서 안전성이 검증된 보안강도 112 비트(bit) 이상을 가지는 암호 알고리즘을 사용하여야 함

※ 보안강도 112 비트급 이상 암호 알고리즘의 세부 사항은 「암호 알고리즘 및 키 길이 이용 안내서」(과학기술정보통신부, 2018), 「소프트웨어 암호모듈 검증기준」, 「NIST SP 800-131Ar2」 참고

구분		암호 알고리즘
대칭키 암호 알고리즘		• SEED, HIGHT • ARIA-128/192/256 • LEA-128/192/256 • AES-128/192/256 • 3TDEA
해시 함수	단순해시/ 전자서명용	• SHA-1 / HAS-160 ※ 80비트/112비트 보안강도 제공하지 못하므로, 메시지 인증/키 유도/난수생성용로만 사용 가능함 • SHA-224/256/384/512 • SHA-512/224,SHA-512/256 • SHA3-224/256/384/512 • LSH-224/256/384/512 • LSH-512/224,SHA-512/256
	메시지인증/ 키 유도/ 난수생성용	
공개키 암호 알고리즘	키 공유용	• [이산대수 문제] DH, MQV • [타원곡선] ECMQV, ECDH
	암·복호화용	• [인수분해 문제] RSAES, RSA
	전자서명용	• [인수분해 문제] RSA-SS, RSA • [이산대수 문제] CDSA, DSA • [타원곡선] ECDSA, EC-CDSA, ECDSA

세부 내용 디지털의료기기

√ 취약하거나 안전성이 검증되지 않은 암호 알고리즘(보안강도 112 비트 미만, 비표준 암호 알고리즘 등)은 사용되지 않도록 제거하거나 비활성화하여야 함
· 취약한 암호 알고리즘 : DES, double length, Triple DES, MD-5, SHA-1, checksum, Base64 등
√ 블록 암호를 안전한 방식으로 사용하여야 함
· 평문의 크기가 암호화 블록 크기보다 큰 경우 ECB 모드는 사용하지 않아야 함
· 블록 암호 방식 중 ECB 모드는 같은 데이터를 암호화하면 항상 같은 결과가 나오므로, 데이터 패턴이 그대로 드러나는 보안 취약점이 있기에 디지털의료기기에서는 ECB 모드를 사용하지 않고, GCM과 같은 안전한 암호화 방식을 사용하여야 함
√ 블록 암호 사용시 CBC, CFB 또는 OFB 모드에서는 고정된 IV(초기화 벡터)를 사용하지 않아야 함
· CFB나 OFB 모드에서 IV(초기화 벡터)를 고정해서 쓰면, 같은 데이터가 항상 같은 암호문으로 변환되어 패턴이 드러날 수 있기에 매번 다른 초기화 벡터를 생성하여 사용해야 안전함
√ KISA 또는 NIST에서 배포한 표준 알고리즘의 테스트 벡터값을 활용하여 암호 알고리즘의 구현 정확성을 검증한 이후 사용하여야 함

보안 활동 디지털의료기기

구분		설명
제4항 기준	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 국내·외에서 안전성이 검증된 보안강도 112 비트 이상을 가지는 암호 알고리즘을 사용하여 데이터 암호화 및 보안통신

예시 디지털의료기기

√ 국내·외에서 안전성이 검증된 보안강도 112 비트 이상을 가지는 암호 알고리즘 사용하여 데이터 암호화 기능, 보안통신 기능 제공
√ 데이터 전송 시 TLS 통신에서 Cipher Suite를 AES-128/192/256, SHA-224/256/384/512로 구성함
√ 사용자의 인증정보를 SHA-256 해시 알고리즘을 사용하여 저장
√ 개인정보 저장 시 ARIA-128을 사용하여 암호화 저장

제9조(암호화 키 관리)

디지털의료기기제조업자등은 다음 각 호의 사항을 고려하여 디지털의료기기 및 그 운영 환경의 암호화 키 관리 방안을 마련하여야 한다.

1. 암호화 키와 암호화된 데이터와의 분리 조치 방안, 암호화 키 유효기간 설정 등 암호화 키 보안 조치
2. 암호화 키 보호용 제어 장치 또는 시스템(하드웨어 등) 적용

[의료기기의 사이버보안 허가·심사 가이드라인 관련 요구사항]

- DC-03 안전한 암호화 사용

❑ 암호화 키 관리 방안

○ 암호화 키와 암호화된 데이터와의 분리 조치 방안, 암호화 키 유효기간 설정 등 암호화 키 보안 조치를 고려하여 암호화 키 관리 방안을 마련하여야 한다.

- 디지털의료기기제조업자등은 디지털의료기기에서 사용되는 암호화 키 목록/용도, 저장 및 보호방법, 파기 방법 등에 대한 암호화 키 관리 문서를 ‘전자적 침해행위로부터의 보호조치에 관한 자료’로 제출하여야 한다.

세부 내용 **암호화 키 관리 문서**

√ 중요정보 저장·전송 시 사용되는 모든 암호화 키를 안전하게 관리하기 위한 방법을 문서화하여 제출하여야 한다.

· 암호화 키 목록/용도
· 암호화 키 저장 방법
· 암호화 키 보호 방법
· 암호화 키 파기 방법

보안 활동 **암호화 키 관리 문서**

구분		설명
제9조 전체	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(기록)** 암호화 키 목록/용도, 저장 및 보호 방법, 파기 방법 등에 대한 암호화 키 관리 문서

예시 **암호화 키 관리 문서**

√ 암호화 키 목록/용도: 데이터(개인정보) 암호화 키(DEK)
√ 암호키 저장 방법: 특정 위치에 저장(저장 위치 명시)
√ 암호화 키 보호 방법: 키 암호화 키(KEK, Key Encryption Key*)로 암호화하여 저장
  * 데이터 암호화 표준(DES) 방식의 회선 암호 장치에서 발신, 수신 쌍방이 사용하는 공통의 키 (TTA, 정보통신용어사전)
√ 암호화 키 파기 방법: 사용 기간이 만료되어 암호화 키 삭제 시 0, 1로 3회 덮어쓰기 수행
√ 암호화 키 관리에 사용되는 하드웨어 보안 모듈 모델명 등 기술



HSM(Hardware Security Module)

- 안전성이 검증된 방식을 사용하여 암호화 키를 생성하고, 암호화 키를 안전하게 분배, 저장, 파기해야 한다.

세부 내용 **디지털의료기기**

√ 안전하게 암호화키를 생성하여야 함

※ 암호키 생성 관련 세부 사항은「암호 키 관리 안내서」(한국인터넷진흥원, 2014) 참고

· 암호화 키 생성 방법의 예

- 패스워드 기반 암호키 유도 : PKCS#5 v2.1(RFC 8018), NIST SP 800-132, TTAK.KO-12.0277 등
- 사전 공유된 키로 암호키 유도 : TTAK.KO-12.0272 등
- 난수발생기(RBG)를 이용하여 암호키 생성 : KS X ISO IEC 18031 등

√ 안전성이 검증된 방식을 사용하여 암호키를 안전하게 분배하여야 함

· 사전에 공유된 암호화 키는 키 암호화 키(KEK)를 이용하여 저장하여야 함
· 전송되는 키의 출처를 확인(전자서명 등)하여야 함
· 전송되는 암호화 키의 기밀성이 보장(다른 키로 암호화 전송 등)되어야 함
· 전송되는 암호화 키의 무결성이 보장되어야 함
· 암호화 키 분배 방법의 예

- 사전에 당사자 간 키를 안전하게 공유(대칭키 분배 방식)
- 신뢰된 제3자(키 분배센터)를 통해 키 분배
- 키 교환 알고리즘(DH, ECDH 등)을 이용하여 키 분배
- 공개키 암호화 방법(RSA 등)으로 키 분배

√ 암호화 키를 안전하게 저장하여야 함

· 데이터 암호화 키(DEK)는 키 암호화 키(KEK)를 통해 암호화하여 저장할 수 있음
· 암호화 키 관련 정보(SEED 값 등)를 포함하여 저장된 암호화 키의 기밀성 및 무결성이 보장되는지 확인하여야 함 (공개키는 기밀성 보장을 요구하지 않음)
· 암호화 키를 기기에 하드코딩하여 저장하는 것은 허용되지 않음
· 암호화 키를 물리적 훼손 공격에 내성을 갖는 안전한 하드웨어 영역(하드웨어 보안 모듈 등)에 저장 시 암호키의 안전한 저장 요구사항을 만족한다고 판단함

√ 암호화 키를 안전하게 파기하여야 함

· 사용 기간인 만료(기기 실행 종료, 암호화 키 삭제 함수 호출, 암호 통신 종료 등)된 암호화 키 및 암호화 키 관련 정보를 모두 파기하여야 함
· 암호화 키 파기 시 메모리에 적재된 암호화 키와 핵심 보안 매개변수를 삭제하여야 함
· 다만, 휘발성 메모리 보호 기법을 적용하는 경우 메모리에 로드되는 중요정보 삭제 요구사항을 만족한다고 판단함

√ 암호화 키의 주기적 갱신 및 유효기간 만료 시 교체 절차(예 : 유효기간 만료 시 새로운 키 생성, 기존 키와 병행 사용, 정상 사용 확인, 기존 키 폐기 등)를 포함한 관리 방법을 문서화하여 관리하여야 한다.

보안 활동		디지털의료기기
구분		설명
제9조 전체	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 변조·도난·유출로부터 보호하기 위해 암호화 키를 안전하게 관리

예시	사용자 매뉴얼

√ 암호화 키의 주기적 갱신 및 유효기간 만료 시 교체 절차를 포함한 관리 방법을 명시
- 암호화 키 교체 절차의 예
- 환자용 모바일 앱과 의료기기 간 API 인증 키를 6개월마다 갱신 후 만료 키 자동 폐기
- 외부 검사 장비와 연동 시 사용하는 암호화 키를 주기적으로 교체하고 교차 검증 후 구버전 삭제
- 환자 데이터 백업 파일 암호화 키를 연 1회 갱신하고 복호화 테스트 후 기존 키 안전 파기
- 개발·검증 환경의 암호화 키도 운영 환경과 동일 주기로 교체하고 불필요한 이전 키 즉시 삭제

제10조(유지 관리)

디지털의료기기제조업자등은 다음 각 호의 사항을 고려하여 디지털의료기기 및 그 운영 환경의 유지 관리 방안을 마련하여야 한다.

1. 디지털의료기기 자체 또는 연관 소프트웨어(운영체제, 제3자 소프트웨어, 오픈소스 등) 업데이트 파일에 대한 안전성 및 무결성 검증
2. 디지털의료기기 업데이트 실패에 대한 대응(복구 기능 제공 등) 방안
3. 디지털의료기기 자체 또는 연관 소프트웨어의 비 인가된 변경에 대한 무결성 검증 방안

[의료기기의 사이버보안 허가·심사 가이드라인 관련 요구사항]

- SI-03 보안 기능 검증
- SI-04 소프트웨어 및 정보에 대한 무결성 점검
- SI-08 업데이트
- SI-09 업데이트에 대한 진본성 및 무결성 검증
- SI-11 부트 프로세스 무결성 검증

❑ 유지 관리 방안

○ 디지털의료기기 자체 또는 연관 소프트웨어(예: 운영체제, 제3자 소프트웨어, 오픈소스 등) 업데이트 파일에 대한 안전성 및 무결성 검증사항을 고려하여 유지 관리 방안을 마련하여야 한다. 이러한 검증 절차는 업데이트 과정 전반에서 보안 취약점을 최소화하고, 환자 안전 및 데이터 보호를 위한 장기적이고 신뢰할 수 있는 운영 환경을 보장할 수 있다.

세부 내용 **디지털의료기기**

√ 기기 식별정보(하드웨어 모델 식별정보, 소프트웨어·펌웨어 식별정보)를 보유해야 하고, 사용자에게 기기 식별정보를 확인하는 수단을 제공하여야 함

· 기기 외관 또는 인터페이스(UI)에 식별정보 표시(명칭, 버전정보)

· 기기 식별정보는 사용자가 업데이트 여부를 확인할 수 있도록 버전 관리 체계를 지원해야 한다.



<출처>: 제조사 SCHILLER AG

√ 디지털의료기기 자체, 연관 소프트웨어(운영체제, 제3자 소프트웨어, 오픈소스 등)에 대한 업데이트 기능을 제공하여야 함

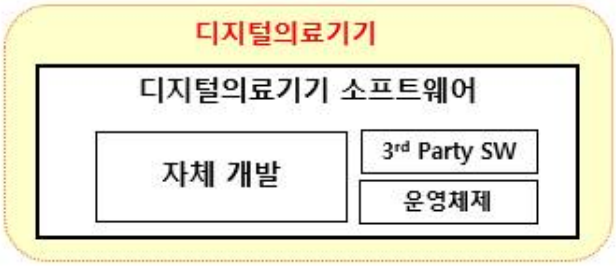
· 업데이트 방법의 예

- 업데이트 파일을 온라인을 통해 설치·적용
- 업데이트 파일을 매체에 저장하여 수동으로 설치·적용

업데이트 방법	요약 설명	사용자 책임
온라인 업데이트	디지털의료기기제조업자등이 제공하는 보안에 안전한 온라인 서비스 및 지원 플랫폼을 통해 업데이트가 적용된다.	사용자 매뉴얼에 따라 온라인 업데이트를 확인해야 한다.
수동 업데이트	디지털의료기기제조업자등이 제공하는 플랫폼으로부터 사용자가 직접 다운로드를 받아 설치할 수 있도록 제공된다.	사용자 매뉴얼에 따라 업데이트를 검색하고 설치해야 한다.
서비스 방문	서비스 시설로 기기를 제공하거나 서비스 직원이 의료서비스제공자 또는 고객에게 방문하여 업데이트를 수행한다.	기기를 서비스 시설에 제공하거나 현장 서비스 방문을 지원한다.

세부 내용 디지털의료기기

√ 업데이트 대상
· 디지털의료기기제조업자등이 직접 개발한 소프트웨어
· 디지털의료기기 소프트웨어에 포함되어 함께 배포되는 연관 소프트웨어(운영체제, 제3자 소프트웨어, 오픈소스 등)



√ 업데이트 수행 전 업데이트 서버를 검증하고, 사용자 인가여부를 확인하여야 함
· 업데이트 수행에 대한 사용자 인가를 받아야 함
· 원격의 업데이트 서버로부터 업데이트 파일을 전송받을 경우 업데이트를 수행하기 전에 업데이트 서버를 검증하여야 함

보안 활동 디지털의료기기

구분		설명
제1항 및 제2항 기준	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등
	보안활동 수행 결과 (output)	**(디지털의료기기)** - 디지털의료기기는 업데이트 기능을 제공하여야 함 - 디지털의료기기는 업데이트 파일에 대한 안전성 및 무결성 검증 기능을 제공하여야 함 **(기록)** 사용자에게 업데이트 알림 등 정보를 제공하여야 함

예시 디지털의료기기

√ 업데이트 수행에 대한 사용자 인가
· 업데이트 시 사용자 인증(아이디/패스워드, 생체인식 등) 수행
· 사용자 인증 후 접속한 관리 화면에서 '자동 업데이트 기능' on으로 설정
  - 안전한 암호통신 채널을 이용한 온라인 업데이트 파일 수신
  - 오프라인 업데이트 기능 이용 시 업데이트 파일에 대한 디지털 서명 검증 후 업데이트 수행
√ 업데이트 서버 검증
· 업데이트 서버에 대한 인증서의 유효성 검증 후 업데이트 서버로부터 파일 수신

❍ 디지털의료기기 업데이트 실패에 대한 대응(예: 복구 기능 제공 등) 방안을 고려하여 유지 관리 방안을 마련하여야 한다.

세부 내용 **디지털의료기기**

√ 업데이트 파일 위·변조 시 탐지할 수 있어야 함
- 온라인 방식의 업데이트 수행 시 안전한 암호통신 채널(예: TLS, VPN, SSH, SFTP, 전용 암호화 터널링 프로토콜 등)을 통해 업데이트 파일을 전송하여 기밀성 및 무결성을 보장하여야 함
- 온라인 또는 수동 방식의 업데이트 수행 시 기기에 업데이트 파일을 설치하기 전에 업데이트 파일의 무결성 검사를 통해 업데이트 파일의 안전성을 검증하여야 함

√ 온라인 또는 수동 업데이트 설치 업데이트 실패 시 안전한 상태인 기존 버전으로 복구할 수 있어야 함
- 온라인 업데이트 실패 시 기존 버전으로 자동으로 복구되거나, 인가된 사용자가 기존 버전을 수동으로 복구하도록 지원할 수 있음
- 수동 업데이트 실패 시 사용자가 기존 버전을 수동으로 복구하도록 지원해야 하며, 이 경우 사용자 인증을 거쳐야 함
- 사용자에 의한 수동 복구를 지원하는 경우 사용자 매뉴얼에 수동 복구 절차를 상세히 기술하여야 함
- 업데이트 실패로 기존 버전으로 복구된 기기는 오류, 서비스 거부 또는 사용자 데이터 손실 없이 정상적인 운영 상태를 유지하여야 함

보안 활동 **디지털의료기기**

구분		설명
제1항 및 제2항 기준	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기는 필수 기능에 영향을 주지 않도록 업데이트 실패 시 대응 기능(복구 기능 제공 등)을 제공하여야 함

예시 **디지털의료기기**

√ 업데이트 파일 위·변조 시 탐지
- 업데이트 파일의 코드 서명 검증을 통한 무결성 검증
- 업데이트 파일의 메시지 인증코드(MAC) 값 검증을 통한 무결성 검증
- 공개된 홈페이지에 해시값을 공개하고, 해당 업데이트 해시값과 비교하여 무결성 검증

√ 업데이트 실 패시 기존 버전으로 자동 복구 기능

예시 **업데이트 위·변조 시 탐지 - 온라인 업데이트**

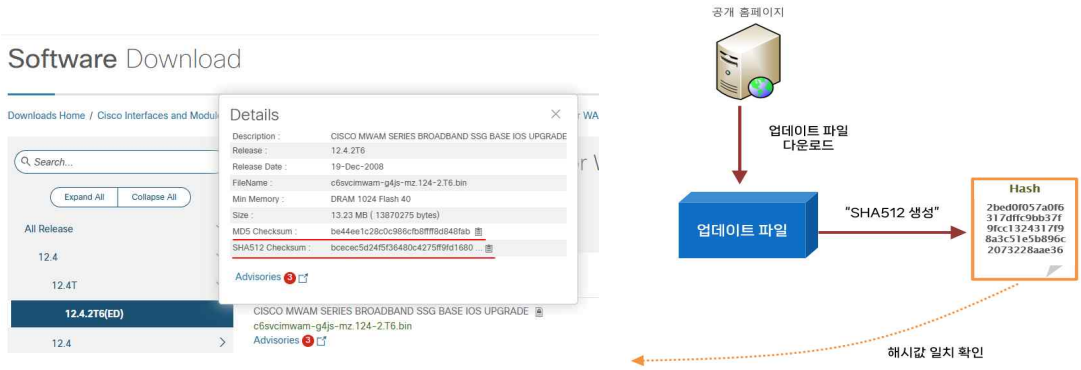
√ 업데이트 서버로부터 수신한 업데이트 파일의 디지털 서명 검증을 통해 위·변조 시 탐지



<출처>: SW 업데이트 체계 보안 가이드라인(국가보안기술연구소)

예시 **업데이트 위·변조 시 탐지 - 수동 업데이트**

√ 공개된 홈페이지에 업데이트 파일에 대한 해시값을 공개하고, 업데이트 파일을 다운로드 받은 사용자는 업데이트 파일에 대한 해시값을 생성한 후 홈페이지와 비교하여 무결성 검증



<출처>: Cisco Software Download Center

예시 **사용자 매뉴얼**

√ 업데이트 실패 시 수동 복구 절차 명시

○ 디지털의료기기제조업자등은 사용자에게 업데이트 알림 등 정보를 제공하여야 한다.

세부 내용 **업데이트 알림**

√ 보안취약점 조치가 완료된 업데이트 파일이 기기에 신속하게 업데이트될 수 있도록 사용자에게 적절한 알림 수단을 통해 정보를 제공하여야 함

· 업데이트 결과로 중요정보(예: 인증정보, 보안·환경 설정값 등)가 초기화되는 경우 사용자에게 알리고 재설정 과정을 수행하는 기능을 제공하여야 한다.

· 업데이트 발생 시 사용자에게 알리는 수단의 예

- 제조사 홈페이지에 업데이트 알림 공지
- 기기 구동 시, 주기적으로 기기 화면에 팝업 알림을 통해 온라인 업데이트 알림
- 사용자에게 이메일, SMS 메시지 발송하여 알림

· 업데이트 결과로 중요정보(인증정보, 보안·환경 설정값 등)가 초기화되는 경우 사용자에게 알리고 재설정 과정을 수행하는 기능을 제공하여야 함

예시 **업데이트 알림**

√ 팝업 알림을 통해 보안 업데이트 안내



<출처>: KISA 보호나라

○ 디지털의료기기는 사용자에게 업데이트 관리 기능을 제공하여야 한다.

예시 **디지털의료기기**

√ 사용자 업데이트 관리 기능 예시

· 자동 업데이트 켜기·끄기

· 업데이트 설치 시작·중지·연기·업데이트 알람 연기

· 업데이트 설치 내역 조회, 설치 결과 조회(성공 또는 실패)

❍ 디지털의료기기 자체 또는 연관 소프트웨어의 비 인가된 변경에 대한 무결성 검증 방안을 고려하여 유지 관리 방안을 마련하여야 한다.

세부 내용 **디지털의료기기**

√ 디지털의료기기 자체 또는 연관 소프트웨어의 무결성 검증 기능을 제공하여야 함
- 디지털의료기기 자체 또는 연관 소프트웨어의 실행 코드(펌웨어, 소프트웨어, 운영체제) 및 설정파일(예: 보안 설정, 설정 및 기타 정보)에 대해 무결성 검증을 수행하여야 함
- 무결성 검사 대상은 디지털의료기기제조업자등이 선택 가능하나 무결성 훼손으로 인한 비정상 상태(오류, 정지 등)로 인해 기기 운영에 영향을 미치는 경우 무결성 검증 대상으로 반드시 포함하여야 함
- 기기가 물리적으로 분리된 여러 개의 요소로 구성되는 경우 모든 구성요소에서 무결성 검증을 수행하여야 함
- 기기 부팅 시 무결성 검증을 필수적으로 수행해야 하며, 그 외(관리자 요청 시 또는 주기적으로)에는 선택적으로 수행할 수 있음
- 무결성 검증에 사용되는 암호 알고리즘 및 암호키 안전성은 제8조(데이터 보안), 제9조(암호화 키 관리)를 만족하여야 함
- 무결성 검증 대상(실행코드, 설정파일)을 변조한 후에 해시를 재계산하여 원본 해시값을 덮어쓰기 할 수 있으므로, 원본 해시값을 안전하게 보호하여야 함

√ 무결성 검증 실패 시 사용자에게 알람을 통보할 수 있음
- 무결성 검증 실패 시 사용자에게 경고 메시지 알림 기능(이메일 발송, SMS 발송, 팝업 메시지 출력, 인터페이스 화면에 출력, 경고음 등)을 제공할 수 있음

√ 무결성 검증 실패 시 적절하게 대응하는 기능을 제공할 수 있음
- 무결성 검증 실패 시 프로그램 실행 중단, 공장초기화 수행, 기능 잠금 및 서비스 중단, 무결성 오류 이전 실행코드/설정파일로 복구 등

보안 활동 **디지털의료기기**

구분		설명
제3항 기준	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기는 자체 또는 연관 소프트웨어에 대한 무결성 검증 기능을 제공하여야 함

예시 **디지털의료기기**

√ 무결성 검증 예시
- 해시값 검증: 소프트웨어·업데이트 파일에 대해 SHA-256 등의 해시를 생성·보관하고, 주기적으로 재계산하여 변조 여부 확인
- 전자서명 검증: 제조사 전자서명 확인을 통해 승인되지 않은 파일·업데이트 설치 차단
- 실행 시 검증: 부팅 또는 동작 시점에 주요 실행 파일의 무결성을 자동 점검
- 대응 절차: 무결성 검증 실패 시 로그 기록·관리자 알림·안전 모드 전환 등 즉각적 조치

√ 디지털의료기기 자체 또는 연관 소프트웨어 무결성 검증 기능

√ 무결성 검증 실패 시 사용자 알람 기능

√ 원본 해시값 보호 방법 예시
- 기기 업데이트 파일의 원본 해시값은 하드웨어 보안 모듈(HSM, Hardware Security Module)에 저장하고, 설치 시 기기가 HSM에서 불러와 검증
- 무결성 검증용 해시는 관리자만 접근 가능한 암호화된 DB에 저장
- 해시값 자체에도 제조사 전자서명을 부여하여, 해시값이 변조되면 즉시 검출

예시 **디지털의료기기**

√ 물리적으로 분리된 여러 개의 요소로 구성되는 기기 예시
- 환자 착용형 심전도 센서와 병동에 설치된 수신 장치가 분리되어 구성되는 경우
- 영상획득 장치(CT, MRI)와 별도의 분석용 워크스테이션으로 나뉘어 동작하는 경우
- 환자용 포터블 혈당측정기와 병원 관리용 PC 프로그램이 연동되는 경우
- 측정 센서 → 게이트웨이 장치 → 클라우드 서버로 데이터가 전달되는 구조

❍ 디지털의료기기 사용 전 부트 프로세스 관련 펌웨어, 소프트웨어 및 설정 데이터에 대한 무결성 검증 기능을 제공하여야 한다.

세부 내용	**의료기기 하드웨어를 포함하는 소프트웨어 내장 디지털의료기기**

√ 디지털의료기기 사용 전 부트 프로세스 관련 펌웨어, 소프트웨어 및 설정 데이터에 대한 무결성 검증 기능을 제공하여야 함

· 기기 부팅 시 BootROM, 부트로더, 커널(운영체제), 파일시스템 등 순으로 실행하여 무결성 검증을 수행하도록 구현할 수 있음

· 기기에 안전한 부팅 메커니즘이 내장된 하드웨어 칩 또는 하드웨어 모듈(TPM, HSM 등)을 탑재한 경우 안전한 부팅을 구현하는 하드웨어 칩 또는 하드웨어 모듈에 대한 안전성을 입증하는 증빙(공인시험기관 등 신뢰할 수 있는 기관이 발급한 증빙자료)을 제출할 경우 요구사항을 만족한다고 판단함

보안 활동		**의료기기 하드웨어를 포함하는 소프트웨어 내장 디지털의료기기**
구분		**설명**
제3항 기준	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기의 부트와 런타임 프로세스에 대한 무결성 검증 기능을 제공하여야 함
적용 예외 사항		소프트웨어 의료기기(SaMD)에는 부트와 런타임 프로세스에 대한 무결성 검증을 적용하지 않음

예시	**의료기기 하드웨어를 포함하는 소프트웨어 내장 디지털의료기기**

√ 디지털의료기기 부팅 시 BootROM, 부트로더, 커널(운영체제), 파일시스템 등 순으로 실행하여 무결성 검증 기능

√ 무결성 검증 예시

· 보안 칩 활용: TPM/HSM 등 안전한 저장소에 기준값을 보관하여 위·변조 방지

제11조(보안 모니터링 및 대응)

① 디지털의료기기제조업자등은 다음 각 호의 사항을 고려하여 디지털의료기기 및 그 운영 환경의 보안 모니터링 및 대응 방안을 마련하여야 한다.

1. 불필요한 서비스(인터페이스) 등 비활성화, 보안 모니터링 기능 구현 등 대응 방안
2. 소스코드 및 주요 운영 데이터 백업 및 복구 방안
3. 컴퓨터 등 최신 버전의 안티 바이러스 소프트웨어 설치 여부
4. 로그 및 백업/복구 등 관리 방안

② 의료서비스제공자는 디지털의료기기 및 그 운영 환경에 대한 보안 모니터링을 수행하고 보안 문제 발생 시 제20조제2항에 따라 디지털의료기기제조업자등에게 알릴 수 있다.

[의료기기의 사이버보안 허가·심사 가이드라인 관련 요구사항]

- RA-01 서비스 거부 방지
- RA-02 의료기기 백업
- RA-03 의료기기 복구 및 재구성
- RA-05 불필요한 기능 비활성화
- SI-02 악성코드로부터 보호
- SI-03 보안 기능 검증
- SI-06 오류 시 사전 결정된 상태로 출력
- SI-07 오류 처리
- UC-04 감사기록 생성
- UC-05 감사 처리 실패 대응
- UC-06 타임스탬프
- UC-07 부인 방지
- TRE-1 감사로그에 대한 비인가된 접근 제한

❑ 보안 모니터링 및 대응 방안

○ 보안 침해에 대응하기 위해 디지털의료기기 및 그 운영환경의 기본 설정에서 불필요한 서비스(인터페이스), 포트 등에 대해 비활성화하고, 보안 모니터링 기능을 구현하여야 한다.

- 디지털의료기기에서 불필요한 열린 포트 및 서비스는 제공되지 않도록 제거하거나 비활성화해야 한다.

세부 내용	디지털의료기기 & 운영환경

√ 디지털의료기기는 불필요한 열린 포트 및 서비스는 제공되지 않도록 제거하거나 비활성화하여야 함
· 불필요한 서비스(Telnet, FTP, SNMP 등) 및 열린(Open) 포트는 제거하거나 비활성화하여야 함
- 기본 구성에서 불필요한 서비스가 비활성화되어야 함
· 디지털의료기기가 설치된 컴퓨팅 장비에서 열린 포트 및 실행 중인 서비스를 식별하고 필요한 사유를 사용자 매뉴얼에 명시하여야 하며 가능한 경우 해당 내용이 매뉴얼에 기재되어 사용자에게 알릴 수 있어야 함
· 컴퓨팅 장비에 설치되어 납품(출고)되는 디지털의료기기의 경우 운용에 불필요한 포트 및 서비스는 비활성화로 설정되어 납품(출고)되어야 하며, 인가된 사용자에 의해서만 활성화 기능이 수행되어야 함

보안 활동	운영환경의 보안설정 및 구성

구분		설명
제1항 기준 (제1호)	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자 (디지털의료기기제조업자등의 설치 담당자)
	보안활동 수행 결과 (output)	**(사용자 매뉴얼)** 설치 담당자 또는 의료서비스제공자가 디지털의료기기에서 불필요한 서비스를 비활성화할 수 있도록 사용자 매뉴얼에 관련 절차를 명시해야 함

예시	사용자 매뉴얼

√ 디지털의료기기의 정상적인 동작을 위해 필수로 개방(Open)되어야 하는 포트, 서비스 목록에 대해 식별하고 있어야 함
√ 그 외의 서비스, 포트 등에 대해서는 거부(Deny)로 설정되어야 하며 포트 스캐닝 도구 등을 통해 불필요한 개방 포트 확인 절차 안내 및 적용, 관리 방안을 명시하여야 함
√ 불필요한 서비스 비활성화 예시
· DICOM 통신을 위해 TCP 104번 포트가 허용되어야 한다는 내용 명시
· 포트 스캐닝(예: nmap) 등을 통해 디지털의료기기로 개방된 모든 포트를 확인하는 절차 명시
· 불필요한 서비스 포트(예 : telnet 23번)에 대해 서비스 포트 확인 후 비활성화 조치하여야 한다는 내용 명시

- 디지털의료기기는 서비스 거부 공격(Denial of Service, DoS)에 오작동하지 않고 필수 기능을 유지하도록 대응하여야 한다.

· 디지털의료기기는 서비스 거부 공격 대응 기능을 제공할 수 있다.

세부 내용	디지털의료기기

√ 디지털의료기기는 서비스 거부 공격(Denial of Service, DoS)에 필수 기능을 유지하도록 대응 기능을 제공하여야 함

· 이는, 본 지침(제7조, 파일 및 입력 유효성)에서 제시하고 있는 입력값 검증을 통해 외부 입력을 받는 기능에 대해 Payload 크기 제한, 입력 빈도수 제한, 반복 요청 등에 대한 차단 등을 적용하여 서비스 거부 공격에 일부 대응할 수 있음

보안 활동	디지털의료기기	
구분		**설명**
제1항 기준 (제1호)	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기는 서비스 거부(Denial of Service, DoS) 이벤트 중에도 필수 기능을 유지할 수 있어야 함

예시	디지털의료기기

√ 서비스 거부 공격 대응 기능의 예

· 자동화된 공격으로 트래픽 폭증 위험을 줄이기 위해 송수신되는 네트워크 트래픽의 양을 제한

· 무선 신호 공격 또는 네트워크 트래픽 과부하 상황에도 핵심 보안기능 및 서비스 실행 유지

· 서비스 거부 공격 발생을 조치할 수 있도록 사용자에게 알림

- 운영환경의 보안설정 및 구성을 통해 디지털의료기기에 대한 서비스 거부 공격을 대응할 수 있다.

세부 내용	운영환경의 보안설정 및 구성

√ 서비스 거부 공격(Denial of Service, DoS)에 대응하도록 디지털의료기기의 운영환경을 구성하여야 함

· DDoS의 경우 공용 네트워크망에 접속하여 디지털의료기기를 실시간으로 제어 또는 환자 생명과 직접적으로 연관될 수 있는 정보를 실시간으로 송수신하는 장비에 적용하여야 함

보안 활동		운영환경의 보안설정 및 구성
구분		설명
제1항 기준 (제1호)	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** 디지털의료기기가 운영환경(방화벽, DDoS 대응 장비 등)으로부터 서비스 거부 공격 대응 기능을 제공 받을 수 있도록 보안설정 및 구성하는 절차를 사용자 매뉴얼에 명시하여야 함

예시	사용자 매뉴얼

√ 서비스 거부 공격에 대응하기 위해 방화벽 설정 또는 DDoS 대응 장비를 구성하는 절차 명시

√ 서비스 거부 공격에 대응하기 위한 실무적 대응 방법 예시

· 디지털의료기기가 설치된 컴퓨팅 장비에서 포트/서비스를 우선 식별하고 필요하지 않은 서비스들은 비활성화 조치하는 절차 명시

· 디지털의료기기가 웹 서비스로 제공되는 경우 WebServer/WAS 설정에서 서비스 요청 빈도를 제한하는 기능 적용

(Apache의 경우 mod_evasive, mod_security 모듈 적용)

(Tomcat의 경우 server.xml 내 maxThreads, connectionTimeout 등으로 연결 제한 설정)

(Nginx의 경우 limit_req_zone 및 limit_conn_zone 등으로 요청 제한 설정)

(Node.js의 경우 expres-rate-limit 미들웨어 적용을 통해 API 요청 수 제한 설정)

- 디지털의료기기는 보안 기능 검증을 위한 자동 검증 기능 또는 수동 검증 절차를 제공하여야 한다.

세부 내용	디지털의료기기

√ 디지털의료기기는 보안 기능 검증을 위한 자동 검증 기능 또는 수동 검증 절차를 제공하여야 함

· 자동 검증 기능을 제공할 경우 보안기능(식별 및 인증, 접근 통제, 시스템 무결성, 데이터 기밀성, 데이터 흐름 통제, 이벤트 적시 대응, 자원 가용성 등)이 의도된 대로 작동되는지 검증하는 기능을 제공하고, 보안기능 동작에 따른 결과(성공, 실패)를 감사기록으로 생성하여야 함

· 수동 검증 절차를 제공할 경우 사용자 매뉴얼에 보안 기능 검증 절차를 명시하여야 함

보안 활동		디지털의료기기
구분		설명
제1항 기준 (제1호)	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기는 보안 기능 검증을 위한 자동 검증 기능 또는 수동 검증 절차를 제공하여야 함

예시	디지털의료기기
√ 자동 검증 기능 · 디지털의료기기는 1시간 단위로 '로그인 기능'을 제공하는 login_process가 실행 중인지 확인한 후 해당 결과를 감사기록을 생성 · 감사기록 '25-08-04 22:00:00 | login_process 정상 동작 | 스케쥴러' √ 수동 검증 기능 · 사용자가 UI에서 '통신 기능 검사' 버튼을 클릭하면 디지털의료기기는 통신 프로세스가 실행 중인지 확인한 후 해당 결과를 감사기록을 생성함 · 감사기록 '25-08-04 22:00:00 | 통신 프로세스 정상 동작 | 관리자ID(admin)'	

- 자동화 프로세스와 연결된 디지털의료기기는 오류 발생 시 사전에 결정된 상태로 출력해야 한다.

세부 내용	자동화 프로세스와 연결된 디지털의료기기
√ 자동화 프로세스와 연결된 디지털의료기기는 오류 발생 시 사전에 결정된 상태로 출력하여야 함 · 사용자 매뉴얼에 사전 결정된 상태의 출력 정보를 명시하여 사전 결정된 상태의 출력 정보가 맞는지 확인할 수 있어야 함 · 자동화 프로세스(예: 자동 판단 알고리즘, 스케줄 기반 동작, 외부 시스템 연동 등)와 연결되지 않는 디지털의료기기는 적용하지 않는다. · 디지털의료기기는 디지털의료기기제조업자등이 정의한 정상 작업상태가 아닌 오류 발생 시 사전 결정된 상태로 동작하여야 함 ※ '사전에 결정된 상태' : 사이버보안 문제로 인해 의료기기 오류 발생으로 정상 동작을 할 수 없는 경우 어떻게 동작할지에 대해 미리 정해놓은 설정 상태	

보안 활동		디지털의료기기
구분		설명
제1항 기준 (제1호)	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기는 오류 발생 시 사전에 결정된 상태로 출력하여야 함 ※ 디지털의료기기가 자동화 프로세스와 연결된 경우에만 적용함

예시	디지털의료기기
√ 자동화 프로세스와 연결된 의료기기 · 디지털의료기기는 1시간 단위로 '로그인 기능'을 제공하는 login_process가 실행 중인지 확인한 후 해당 결과를 감사기록을 생성 · 약물을 일정한 속도로 주입하는 체외용 인슐린 주입기 √ 사전에 결정된 상태 · 체외용 인슐린 주입기의 사전 결정된 상태로 '인슐린 주입 중단 및 사용자 알람 발생'으로 설정한 경우, 제품 오류 발생 시 즉시 인슐린 주입을 중단하고 사용자에게 알람을 울리도록 하여 사용자가 수동으로 인슐린을 주입할 수 있게 조치함	

- 디지털의료기기는 오류 발생 시 공격자에 의해 악용될 수 있는 정보를 제공하지 않는 방식으로 오류 조건을 식별하고 처리하여야 한다.

세부 내용	디지털의료기기 & 운영환경
√ 디지털의료기기는 오류 발생 시 공격자에 의해 악용될 수 있는 정보를 제공하지 않는 방식으로 오류 조건을 식별하고 처리하여야 함 · 사용자 매뉴얼에 사용자에게 반환되는 오류 메시지 목록을 명시하여야 하며, 디지털의료기기에서 출력되는 오류 메시지에는 중요 정보가 포함되어 출력되지 않아야 한다. √ 사용자 매뉴얼에 이상 상황(예: 보안 사건) 감지 시, 가능한 경우에 기기 또는 지원 시스템이 이를 사용자에게 알리는 방법에 관해 명시하여야 함 · 보안 사건 유형의 예 - 비인가자에 의한 구성 변경(Configration Change), 네트워크 이상 현상, 비정상 로그인 시도, 이상 트래픽 탐지 등	

보안 활동		디지털의료기기
구분		설명
제1항 기준 (제1호)	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 디지털의료기기는 오류 발생 시 중요 정보를 유출하지 않아야 함

예시	디지털의료기기
√ 인증 실패 시 상세 정보가 포함된 오류 메시지를 출력하지 않아야 함 · "등록되지 않은 사용자 ID입니다." · "올바르지 않은 비밀번호입니다." √ 의료기기 특정 정보가 포함된 오류 메시지를 출력하지 않아야 함 · "Oracle 23c Account table에 문제가 발생하였습니다." (디지털의료기기가 사용하는 DBMS 및 테이블 정보 출력)	

예시	사용자 매뉴얼
√ 디지털의료기기에서 발생하는 오류 메시지에 대한 서술 √ 오류 메시지 서술 예시 · "인증에 실패하였습니다" : 등록된 ID 또는 비밀번호가 일치하지 않은 경우 · "DBMS에 문제가 발생하였습니다." : 연동되는 DBMS 오류가 발생한 경우 √ 디지털의료기기에서 이상 상황(예: 보안 사건) 감지 시, 사용자에게 알리는 방법 명시 · 특정 보안 사건 발생 시 관리자에게 알릴 수 있도록 관리자 이메일 및 전화번호 등록 · 디지털의료기기에서 알람 발송할 수 있도록 메일 서버 및 SMS 서버 등록 절차	

○ 디지털의료기기제조업자등은 보안 침해에 대응하기 위해 주요 운영 데이터에 대해 백업 및 복구할 수 있는 방안을 마련하여야 한다.

- 디지털의료기기에 대한 주요 운영 데이터에 대한 백업 기능, 복구 및 재구성하는 기능을 제공하여야 한다.

세부 내용 디지털의료기기

√ 디지털의료기기에 대한 백업 기능을 제공하여야 함
· 디지털의료기기의 백업 프로세스가 기기 정상 작동에 영향을 미치지 않아야 함
· 디지털의료기기의 백업 프로세스가 기기 정상 작동에 영향을 미치지 않아야 함
· 백업 데이터에 대한 암호화 키 등 보호가 필요한 정보를 포함하는 경우 제9조(암호화 키 관리)를 만족하여야 함
√ 중단 또는 장애 후 복구 및 재구성하는 기능을 제공하여야 함
· 권한이 있는 사용자가 선택한 백업 또는 인증된 백업을 사용하여 복구하여야 함
· 디지털의료기기가 다시 설치되고 기존 설정으로 구성되어야 함
· 시스템 매개변수(기본값 또는 설정 가능)는 안전한 상태로 구성할 수 있는 값으로 설정할 수 있어야 함
· 디지털의료기기의 보안 패치는 다시 설치할 수 있어야 하며, 보안 관련 구성 설정 또한 다시 설치할 수 있어야 함
· 보안 관련 구성 설정이 다시 설치될 수 있어야 함
√ 사용자 매뉴얼에 백업 기능과 백업 정보, 안전한 상태로 복구하는 방법 등을 명시하여야 함

보안 활동 디지털의료기기

구분		설명
제1항 기준 (제2호)	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** - 디지털의료기기는 실행파일 및 주요 운영데이터에 대한 백업 기능을 제공하여야 함 - 디지털의료기기의 중단 또는 장애 상황 발생 후 안전한 상태로 복구 및 재구성하는 기능을 제공하여야 함

예시 디지털의료기기

√ 백업 기능 제공
√ 중단 또는 장애 후 안전한 상태로 복구하는 기능 제공

· 디지털의료기기가 웹(Web) 기반 제품이거나 별도의 운영 환경 파일 및 설정이 존재하는 경우 운영 데이터 백업 방안 등을 마련하여야 한다.

예시 **주요 백업 데이터**

√ 운영/보안 설정 파일
· 환경 설정 파일(config, env, properties), SSL 인증서
· 암호화 키 관련 파일 등
√ 로그/감사 파일
· audit.log, DB 감사 파일

• 또한, 제품이 소스코드 일부 등을 포함하여 패키징되는 경우에 대해서는 소스코드까지 포함하여 백업 및 복구할 수 있도록 대응하여야 한다.

예시 **소스코드가 포함(일부)된 예시**

√ 해석 가능한 코드 형태가 포함된 경우
· py, js, sh, bat, ini, r 등 해석 가능한 코드
√ HTML, Javascript, CSS 등 웹 서버 형태의 경우
· html, js, css 등의 코드

❍ 디지털의료기기제조업자등은 보안 침해에 대응하기 위해 컴퓨터 등 최신 버전의 안티 바이러스 소프트웨어를 설치하여 디지털의료기기 및 그 운영 환경을 지속적으로 감시하여야 한다.

- 독립형 디지털의료기기 소프트웨어는 운영환경의 보안설정 및 구성을 통해 악성코드로부터 보호되어야 한다.

세부 내용 **운영환경의 보안설정 및 구성 - 독립형 디지털의료기기 소프트웨어**

√ 독립형 디지털의료기기 소프트웨어는 악성코드로 인한 보호 침해에 대응할 수 있도록 운영환경을 구성하고 보안설정을 수행하여야 함

· 호환되는 악성코드 방지 기능을 통해 디지털의료기기를 보호할 수 있도록 명시하여야 함

· 악성코드 방지를 위해 필요한 설정이나 조건이 있는 경우 이를 명시하여야 함

· 주기적인 악성코드 감염 여부를 검사하고 모니터링하도록 명시하여야 함

· 최신 악성코드 예방 탐지를 위해 자동 업데이트 기능 설정 또는 일 1회 이상 업데이트를 수행하여야 함

· 납품 환경이 외부 네트워크가 단절된 폐쇄망인 관계로 온라인 업데이트가 불가능한 경우, USB 등을 활용한 수동 업데이트를 보장하여야 하며 관련 절차 등을 매뉴얼에 명시하여야 함

보안 활동 **운영환경의 보안설정 및 구성 - 독립형 디지털의료기기 소프트웨어**

구분		설명
제1항 기준 (제3호)	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자 또는 사용자
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** 디지털의료기기와 호환되는 악성코드 방지 기능, 악성코드 방지를 위해 필요한 운영환경의 보안설정 및 구성을 명시하여야 함

예시 **사용자 매뉴얼**

√ 운영환경으로부터 악성코드 방지 기능을 제공 받을 수 있도록 구성하는 절차 명시

· 독립형 디지털의료기기 소프트웨어가 설치된 시스템에 안티 바이러스 제품을 설치하여 악성코드 방지 기능을 제공받음





- 내장형 디지털의료기기 소프트웨어는 악성코드로부터 보호하는 기능을 제공하여야 한다.

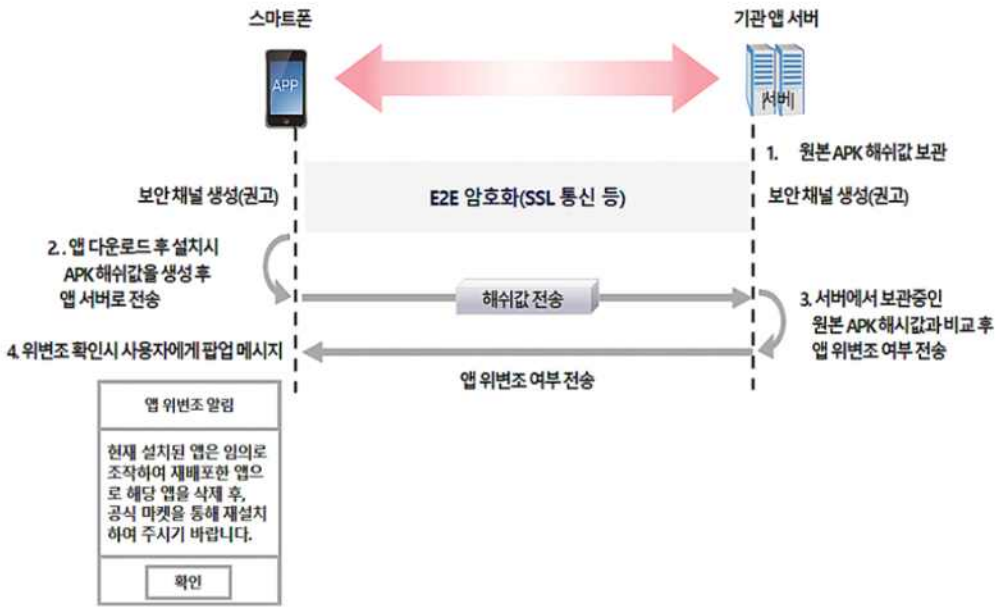
세부 내용	내장형 디지털의료기기 소프트웨어

√ 내장형 디지털의료기기 소프트웨어는 악성코드로부터 보호하는 기능을 제공하여야 함
· 악성코드로부터 보호하기 위해 승인되지 않은 소프트웨어의 설치 및 실행을 방지하는 기능을 제공해야 함
· 승인되지 않은 소프트웨어의 설치 및 실행 방지 기능의 예
- 탐지 기술: 바이너리 무결성, 속성 모니터링, 해싱, 서명 기술
- 방지 기술: 이동식 미디어 제어, 샌드박스 기술, 특정 컴퓨팅 플랫폼 기능(예-제한된 펌웨어 업데이트), 실행 금지(NX) 비트, 데이터 실행방지(DEP), 주소 공간 레이아웃 무작위화(ASLR), 스택 손상 탐지, 필수 접근 통제, 프로세스 화이트리스트 및 이와 유사한 기능 등

보안 활동	내장형 디지털의료기기 소프트웨어	
구분		**설명**
제1항 기준 (제3호)	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** 인가되지 않은 소프트웨어(악성코드를 포함할 수 있음)의 설치 및 실행으로부터 보호하는 기능을 제공하여야 함

예시 **바이너리 무결성**

√ 승인되지 않은 소프트웨어의 설치 및 실행 방지하기 위해 바이너리의 해시값을 비교하여 무결성 검증



<출처>: 모바일 전자정부서비스 앱 소스코드 검증 가이드라인 - 앱 위변조 탐지 프로세스

○ 디지털의료기기제조업자등은 보안 침해에 대응하기 위해 로그 관리 방안, 백업 및 복구 관리 방안을 마련하여야 한다.

- 디지털의료기기 운용 과정에서 발생한 보안이벤트에 대한 감사기록을 생성하여야 한다.

세부 내용 **디지털의료기기**

√ 디지털의료기기는 보안이벤트에 대한 감사기록을 생성하여야 함

· 다음과 같은 보안 유형과 관련된 감사기록을 생성하는 기능을 제공하여야 함

분류	감사사건(이벤트)
식별 및 인증	사용자 로그인/로그아웃
	기본 인증정보 변경
	반복된 인증시도 제한
업데이트 및 기술 지원	업데이트 수행 및 결과
백업 및 복구	백업 수행 및 결과
	복구 수행 및 결과
기타	기기 시작 및 종료

· 다음과 같은 기능을 제공할 경우 감사기록을 생성하는 기능을 제공하여야 함

분류	감사사건(이벤트)	추가적인 감사정보
식별 및 인증	사용자 등록, 변경, 삭제	-
	인증시도 한계치 도달 시 대응행동	-
	패스워드에 대한 모든 변경	-
	기기 설정 변경 내역	변경된 데이터
	사용자 세션 잠금 또는 종료	잠금 또는 종료된 사용자
감사기록	감사기록 저장 실패 시 대응 행동	-
보안 모니터링 및 대응	무결성 검증 결과	실패한 실행코드, 설정파일
	비인가된 소프트웨어 설치·실행 차단	-
	자체시험 수행 결과	-

√ 감사기록에 필수 정보를 포함하고, 민감한 정보를 포함하지 않아야 함

· 감사기록에는 사건 일시, 사건 유형, 사건 결과(성공 또는 실패) 관련 감사정보를 반드시 포함하여야 함

· 사용자(사람)가 특정 행동(의료기기 사용, 설정 변경 등)을 하여 생성된 감사기록에는 사용자를 식별할 수 있는 정보를 포함하여야 함(부인방지)

· 신뢰된 시간 정보(NTP 서버 동기화, OS 시간 정보 등)을 이용해서 감사기록을 생성하여야 함

· 감사기록에는 인증정보(패스워드 등), 개인정보(주민등록번호 등), 암호키 등 감사기록 내에 필요 이상의 정보 또는 중요정보가 포함되지 않아야 하며, 불가피한 경우 마스킹 처리하여 생성하여야 함

보안 활동		디지털의료기기
구분		설명
제1항 기준 (제4호)	보안활동 영역	디지털의료기기제조 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** - 운용 과정에서 발생한 보안 이벤트에 대한 감사기록을 생성하고, 안전하게 보호하여야 함 - 감사기록 처리 실패에 대한 대응 기능을 제공하여야 함

- 감사기록을 안전하게 보호하여야 하고, 감사기록 처리 실패에 대한 대응 기능을 제공하여야 한다.

세부 내용	디지털의료기기 & 운영환경
√ 감사기록을 안전하게 보호하여야 함 · 감사기록에 대해 인가된 사람 또는 도구만 읽기 전용으로 접근할 수 있으며, 비인가자의 접근을 통제하여야 함 · 인가된 사용자라도 감사기록을 삭제·변경할 수 있는 인터페이스(UI, 명령어 등)가 제공되지 않아야 함 · 감사기록을 기기 외부의 로그서버에 저장하는 경우 안전한 암호통신을 통해 전송해야 하고, 암호 통신에 사용하는 암호 알고리즘 및 암호키 안전성은 제8조(데이터 암호), 제9조(암호화 키 관리)를 만족하여야 함 √ 감사기록 처리 실패에 대한 대응 기능을 제공하여야 함 · 감사기록 처리 실패 시 필수 서비스 또는 기능의 손실이 없어야 함 · 감사기록 처리 실패에 대응하여 적절한 작업을 지원하는 기능을 제공하여야 함 · 감사기록 저장용량 포화 시 사용자에게 통보해야 하고, 감사기록이 손실되지 않도록 적정한 방법으로 저장 실패에 대응	

예시	디지털의료기기
√ 감사기록 처리 실패 시 대응 기능의 예 · 화면 팝업 메시지를 통해 사용자에게 알람 · 등록된 사용자 이메일로 알람 메일 전송 · 등록된 사용자 휴대폰으로 SMS 전송 √ 감사기록 저장용량 포화 시 대응 기능의 예 · 가장 오래된 감사기록 덮어쓰기 · 감사기록 압축 저장 · 안전한 암호통신을 통해 외부의 로그 서버로 감사기록 전송	

❑ 의료서비스제공자의 보안 모니터링 및 알림 권고 사항

○ 의료기관 또는 의료서비스를 제공하는 기관은 디지털의료기기와 그 운영 환경에서 발생할 수 있는 보안 문제(이벤트)를 탐지하여 이를 디지털의료기기제조업자등에게 알릴 수 있다.

- 의료서비스제공자는 디지털의료기기제조업자등이 안내한 보안 모니터링 방안에 대해 의무적인 역할이 아닌 협력적인 역할로서 디지털의료기기 및 그 운영 환경에서의 보안 문제를 함께 해결할 수 있도록 한다.
- 의료서비스제공자가 인지할 수 있는 보안 문제는 디지털의료기기제조업자등이 정의한 내용을 준수하며, 디지털의료기기제조업자등은 협력을 위해 사용자 매뉴얼 또는 관련 문서 등을 통해 공동 대응의 중요성을 강조할 수 있도록 안내한다.

보안 활동		**보안 모니터링**
구분		**설명**
제2항 기준	보안활동 영역	의료서비스제공자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** - 보안 모니터링 절차를 명시하고, 관련 보안 활동을 권고하여야 함 - 의료서비스제공자가 보안 모니터링 중 보안 문제 발생 시 이를 통보할 디지털의료기기제조업자등의 담당부서 및 연락처

예시	**보안 모니터링**
√ 의료서비스제공자에게 안내할 수 있는 보안 이벤트에 대한 예시 · 제품 사용 도중 로그인이 수시로 풀리거나, 정상적으로 로그인이 수행되지 않는 경우 · 제품 업데이트 도중 알 수 없는 오류(무결성, 서명 불일치 등)가 발생하는 경우 · 정상적인 권한을 가진 사용자이나, '권한 없음' 등의 오류 메시지가 발생하는 경우 · 이전까지 정상적으로 사용했던 기능들을 갑자기 사용할 수 없는 경우 · 기존에 저장되던 로그 파일 등이 삭제되거나 확인할 수 없는 경우	

예시 **보안문제 공동 대응 방안**

√ 보안을 준수하기 위한 공동 대응 유도 방안 예시

· 보안 모니터링을 준수하기 위해 관련 내용을 고객에게 인도되는 문서(예 : 사용자 매뉴얼 등)에 추가적으로 기재하여 의료서비스제공자에게 안내함

· 의료서비스제공자가 수행할 수 있는 보안 모니터링 및 대응 방안에 대해 고객에게 인도되는 문서에 기재하여 준수할 사항에 대해 안내

· 가능한 경우, 장비 고장 또는 기능 오류, 보안 알림, 데이터 누락 등의 이벤트가 발생할 경우 고객에게 인도되는 문서에 대응할 수 있는 해결 방안에 대해 명시하고, 해결되지 않을 경우 자사 고객센터(홈페이지, 이메일, 전화 등) 정보 표시를 통해 연락할 수 있도록 안내 유도

· 가능한 경우, 신고/보고 과정에서의 불이익이 없음을 알려주는 문구를 기재

· 제품 이상 보고에 포함되어야 하는 정보(문제 발생 시점, 문제를 인지한 사용자 계정, 관련 이벤트 증적 등)를 포함하도록 안내

제12조(인공지능 보안)

디지털의료기기제조업자등은 다음 각 호의 사항을 고려하여 디지털의료기기 및 그 운영 환경의 인공지능 보안 방안을 마련(인공지능기술이 적용된 디지털의료기기에 한한다)하여야 한다.

1. 데이터 중독 공격, 회피 공격 등과 같은 데이터 공격에 대한 방어 수단
2. 학습 데이터 수집, 구축 및 보관 과정에서의 데이터 변형, 데이터 조작 등의 위변조 행위에 대한 방어 수단
3. 반복된 질의 조회 차단, 적대적 공격 판단 모델 구현 등 인공지능 모델 추출/회피 공격 대응 방안
4. 인공지능 시스템 운영 중 문제 발생 시 피드백 제공 화면 전환, 이용자 안내 메시지 제공, 인공지능 기술이 적용된 주요 기능의 중단 등 운영 대응 방안

❑ 인공지능 보안 방안

○ 디지털의료기기제조업자등은 인공지능 보안 방안을 마련하여야 한다.

보안 활동		디지털의료기기
구분		설명
제3항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** - 인공지능 방어 수단을 마련하여야 함
적용 예외 사항		- 디지털의료기기에 인공지능 기술이 적용되지 않는 경우는 해당하지 않음 ※ 디지털의료기기의 정의(진단/치료 등)에 부합하는 사용 목적을 구현하기 위해 사용되는 인공지능 기술을 제공하는 소프트웨어는 디지털의료기기 범위에서 포함되어야 함 ※ 디지털의료기기 범위를 사전에 식품의약품안전처로부터 확인 받는 것을 권고함

○ 디지털의료기기제조업자등은 데이터 중독 공격, 회피 공격 등과 같은 데이터 공격에 대해 방어하기 위한 수단을 마련하여야 한다.

< 데이터 관리의 중요성 >

Data management is also an important means of identifying and mitigating bias. The characterization of sources of bias is necessary to assess the potential for AI bias in the AI-enabled device. AI bias is a potential tendency to produce incorrect results in a systematic, but sometimes unforeseeable, way due to limitations in the training data or erroneous assumptions in the machine learning process.

<Artificial Intelligence-Enabled Device Software Function: Lifecycle Management and Marketing Submission Recommendations (Draft Guidance for Industry and Food and Drug Administration Staff, 2025.1.7.>

세부 내용 **인공지능 데이터 공격 방어**

√ 데이터 중독 공격에 대한 방어 수단을 제공하여야 함

· 학습용 데이터는 AI/ML 시스템의 성능 뿐만 아니라 보안성과 편향성에 직접적인 영향을 미치므로 데이터 조작이나 유출 등에 대한 보호 조치가 매우 필요함

· 데이터 중독, 유출 등의 공격에 대해 방어하기 위해 학습 데이터 무결성 검증, 접근 통제, 암호화 처리, 로그 기록 관리 등을 고려하는 것이 좋으나, 현실적으로는 어려운 조치들이 많으므로 실무적으로 적용할 수 있는 조직에서 최소한으로 수행할 수 있는 방어 전략을 수립하고 이를 수행하여야 함

※ 데이터 중독 공격 : 학습 데이터에 악성 데이터를 주입하여 AI 모델을 오염시키는 공격

√ 데이터 회피 공격에 대한 방어 수단을 제공하여야 함

· 회피 공격의 예시

- 뇌졸중 진단 AI가 MRI 이미지를 분석하는데, 공격자가 정상 MRI 영상에 육안으로는 구분하기 어려운 미세한 노이즈를 추가하여 AI가 뇌졸중으로 오판할 수 있음

※ 데이터 회피 공격 : AI 모델의 예측을 회피하거나 오도하기 위해 입력 데이터에 미세한 변화를 주는 공격

예시 **인공지능 데이터 공격 방어**

< 데이터 공격 및 방어 기법 예시 >
√ 데이터 중독 공격의 종류 : 라벨 플리핑, 백도어, 클린라벨, 그래디언트 매칭 등
√ 데이터 회피 공격의 종류 : FGSM, C&W, ZOO/HSJA 등
√ 대표 방어 기법 : 적대적 학습(adversarial training), Gradient Masking, Feature Squeezing

< 학습용 데이터의 안전과 보안을 위한 활동 예시 >

1) 학습용 데이터 중독, 유출 등의 공격에 대한 방어

→ 예시) 학습 데이터가 무단 변경 및 유출되지 않도록 데이터가 저장된 시스템 또는 스토리지에 대해 접근 제어(ID/PW 기반, IP 기반 등 인증 방식 적용)가 필요하며 데이터 접근에 대한 로그를 기록할 수 있도록 보안을 강구할 것 (데이터 백업 과정도 포함하는 것을 권고함)

- 수집 데이터 출처 명시 및 메타데이터 기록 및 관리
- 신규 데이터 샘플 중 일부 추출 및 라벨링(레이블링) 교차 확인
- 데이터 변경 이력 발생 시 기록 관리 (버전 관리 포함)
- 데이터 저장소 접근 통제 관리 (로그 관리 포함)
- 데이터 보관 디렉토리 별 해시값 검증 등

2) 학습용 데이터의 편향성 완화

→ 예시) 데이터가 특정 그룹에 편중되어 있지 않는지 데이터 분석 등을 통해 파악하여야 하며, 필요한 경우 데이터를 보완하거나 가중치 조절 등의 기법을 통해 편향성을 완화하여야 함

- 학습 데이터 내 정보(연령, 성별, 질환 단계 등) 분석 및 분포도 확인
- 특정 그룹 데이터 부족에 대한 보완 수집 시도
- 그룹별 모델 성능 차이 비교 (남성과 여성과의 정밀도 성능 분석 등)
- 라벨링(레이블링) 기준 정의에 따라 라벨링(레이블링) 교차 검증 수행 등

<2023 신뢰할 수 있는 인공지능 개발 안내서, 의료분야 편>

예시 **인공지능 데이터 공격 방어**

< 적대적 공격에 대한 방어 기법 예시>

√ 적대적 학습 : 가장 직관적으로 쉽게 떠올려볼 수 있는 알고리즘이다. 모델을 학습시킬 때, 적대적 사례로 활용할 수 있는 모든 경우의 수를 미리 고려하여 학습 데이터셋에 포함. 그러나 충분한 수와 다양성이 보장된 적대적 데이터를 생성하는 과정 없이는 적대적 학습은 그 성능을 보장하기 어려움

√ Gradient Masking/Distillation : 대부분의 적대적 공격은 모델 추론 과정에서의 경사(gradient)를 보고 공격이 이루어짐. 그러므로 학습 모델의 경사가 그대로 노출되는 것을 방지하거나(gradient masking), 정규화 방법 등을 통해 경사가 두드러지지 않게 하여 적대적 공격에 방어할 수 있는 방법(distillation)들이 제안되었음

√ Feature Squeezing : 적대적 공격을 막기 위한 방법으로는 본래의 학습 모델과 별도로, 주어진 입력이 적대적 사례인지 아닌지를 판단하는 학습 모델을 추가하는 방법이 있음. 그 외에 다수의 학습 모델을 조합하여 시스템을 구성하면 특정 모델에 대한 화이트박스 공격을 피할 수 있으며, 특정 모델에 적용되는 적대적 공격이 불가능해지므로 좋은 방어법이 된다는 연구 결과가 제시되었음

<2023 신뢰할 수 있는 인공지능 개발 안내서, 의료분야 편>

○ 디지털의료기기제조업자등은 학습 데이터 수집, 구축 및 보관 과정에서의 데이터 변형, 데이터 조작 등의 위변조 행위에 대해 방어할 수 있는 수단을 마련하여야 한다.

- 학습 데이터 수집, 구축 및 보관 과정에서의 데이터 변형, 데이터 조작 등의 위·변조 행위에 대한 방어 수단을 제공하여야 한다.

세부 내용	인공지능 학습 데이터 위·변조 방어

√ 학습 데이터 수집 과정에서의 데이터 위변조 행위에 대한 방어 수단을 제공하여야 함

< 데이터 수집 및 전송 단계의 위·변조 예시 >

· 여러 병원에서 익명화된 환자 심전도 데이터를 수집하여 중앙 학습 서버로 전송하는 과정에서 데이터가 가로채이거나 조작할 수 있음

· 인공지능이 나중에 실제 환자를 진단할 때 치명적인 오진을 유발할 수 있음

< 데이터 수집 및 전송 단계의 위·변조 행위 방어 수단 예시 >

· 종단 간 암호화 : 데이터가 생성되는 시점부터 저장소에 도착할 때까지 모든 전송 구간을 암호화(HTTPS, VPN 등)

· 디지털 서명 및 해시 검증 : 데이터를 전송하기 전에 디지털 서명을 하고 수신 측에서 해당 서명과 데이터 해시값을 검증하여 데이터의 위·변조 여부 확인

· 안전한 통신 프로토콜 강제 : 모든 데이터 통신은 보안이 강화된 프로토콜(예 : SFTP, FTPS 등)만 사용하도록 시스템을 구성

√ 학습 데이터 구축 및 보관 과정에서의 데이터 위변조 행위에 대한 방어 수단을 제공하여야 함

< 데이터 구축 및 보관 단계에서의 위·변조 예시 >

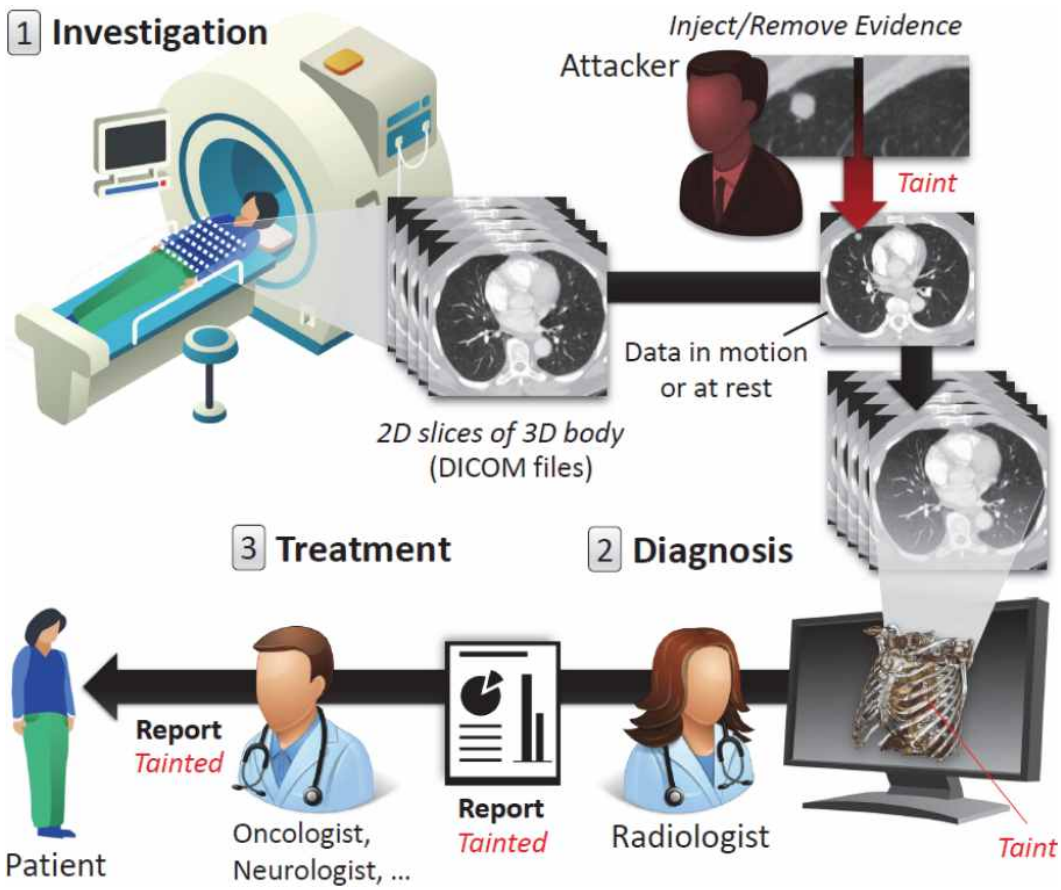
· 학습 데이터셋을 구축하기 위해 데이터를 정제하고 레이블링하는 과정에서 인가받지 않은 사용자가 접근하여 데이터를 고의로 잘못 분류하거나, 저장된 데이터 파일 자체를 변경할 수 있음

< 데이터 구축 및 보관 단계의 위·변조 행위 방어 수단 예시 >

· 엄격한 접근 제어 및 최소 권한 원칙: 학습 데이터 저장소 및 데이터 처리 시스템에 대한 접근 권한을 '최소 권한의 원칙'에 따라 설정

  - 감사 추적(Audit Trail) 및 활동 로깅: 학습 데이터에 대한 모든 접근, 수정, 삭제 이력을 상세하게 감사 기록하고, 이러한 감사 기록을 정기적으로 검토하여 비정상적인 활동을 탐지
  - 버전 관리 및 변경 이력 관리: 학습 데이터셋의 모든 변경 사항을 버전 관리 시스템으로 추적하고, 이전 버전(보안취약점이 없는 안전한 버전)으로 쉽게 롤백(rollback)할 수 있도록 함
  - 데이터셋 변경 시에는 반드시 승인된 절차를 거치도록 함
  - 데이터 암호화 및 무결성 검사: 미사용 데이터는 암호화된 저장소에 보관하고, 주기적으로 데이터 무결성 검사를 수행하여 데이터 손상이나 변형을 탐지함

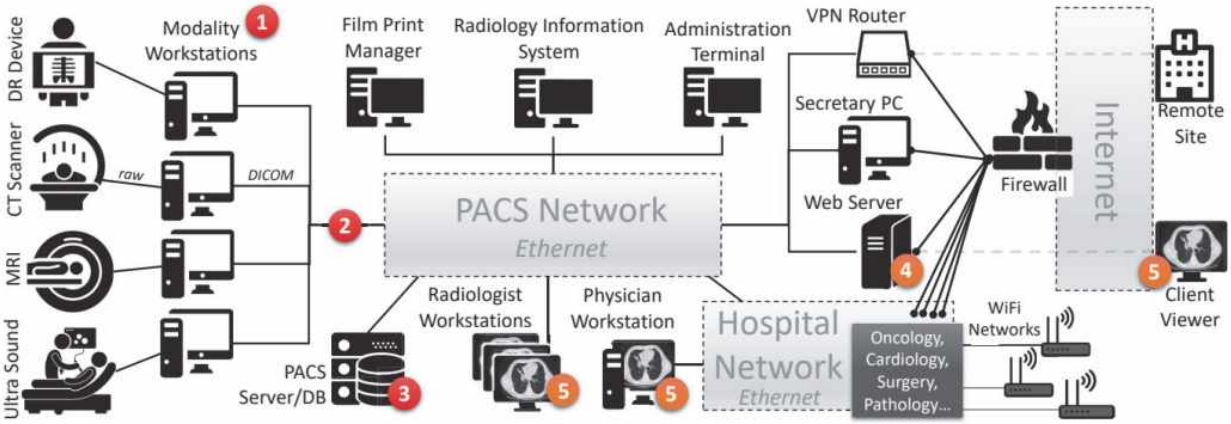
< 의료 CT 촬영 데이터를 대상으로 하는 데이터 위변조 공격 시나리오 >



→ **(데이터 중독 공격 시점) 조사(1)**와 **진단(2)**의 중간 단계에서 의료 이미지를 변조하여 전문의 및 의사 모두 공격자가 설정한 오류를 믿는 사례

<2023 신뢰할 수 있는 인공지능 개발 안내서, 의료분야 편>

< PACS 네트워크 상에서의 데이터 중독 공격 시나리오 >



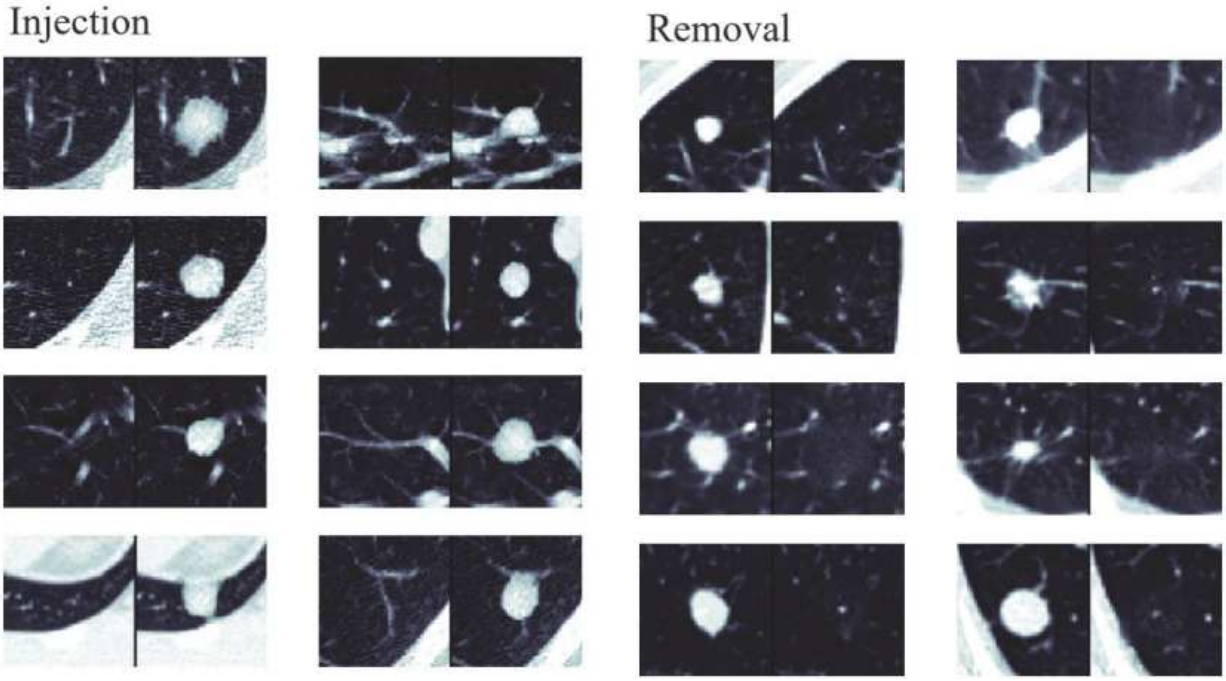
→ 공격자는 1~3 위치에서 모든 데이터을 변조할 수 있으며, 4~5지점에서 데이터 하위 집합을 조작할 수 있음

√ 의료 CT 촬영 데이터 공격 시나리오

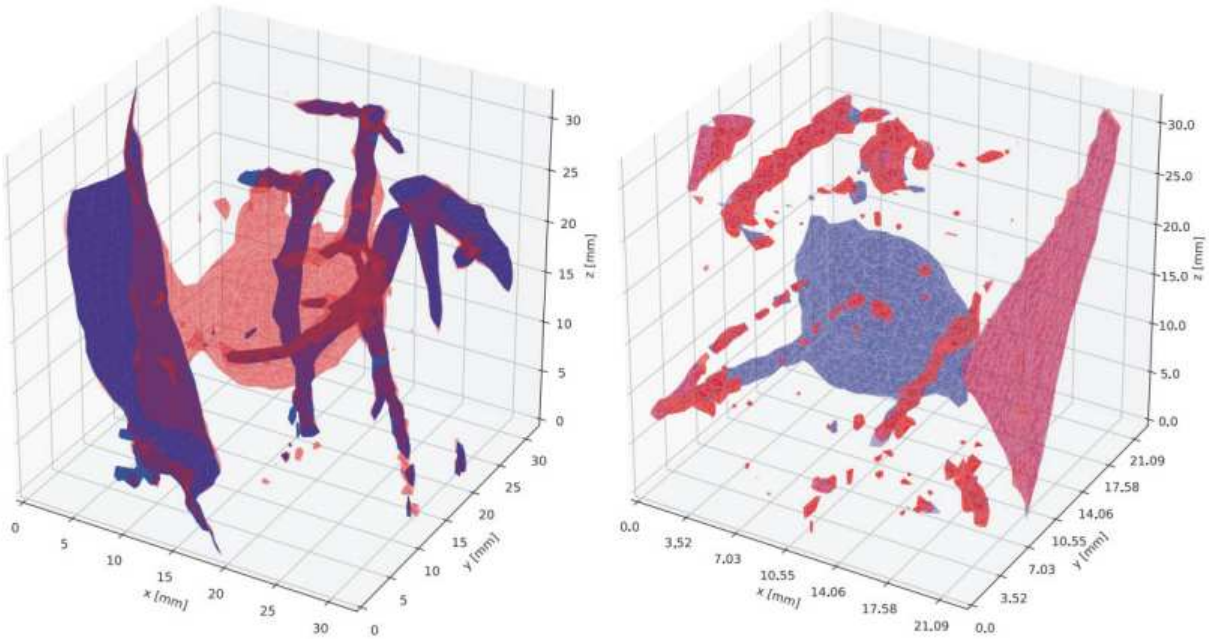
1) PACS 네트워크를 사용하는 병원을 가정하여 공격자는 방사선 전문가가 진단을 수행하기 전에 저장 데이터 또는 이동 데이터를 대상으로 CT 스캔 내용을 변경할 수 있음
2) 이동 데이터는 PACS 서버 또는 방사선 전문의의 개인 컴퓨터에 저장된 DICOM 파일을 나타냄
3) 때에 따라 DICOM 파일을 DVD 등 외장 미디어에 저장한 이후 다음 환자 또는 외부 의사가 병원으로 전송함

<2023 신뢰할 수 있는 인공지능 개발 안내서, 의료분야 편>

< CT-GAN 기법을 활용한 의료 CT 촬영 데이터 공격 (1/2) >



→ 샘플 주입(Injection) 및 제거(Removal), 각 이미지에 대해 주입(왼쪽)이 변조 전, 제거(오른쪽)이 변조 후 이미지임



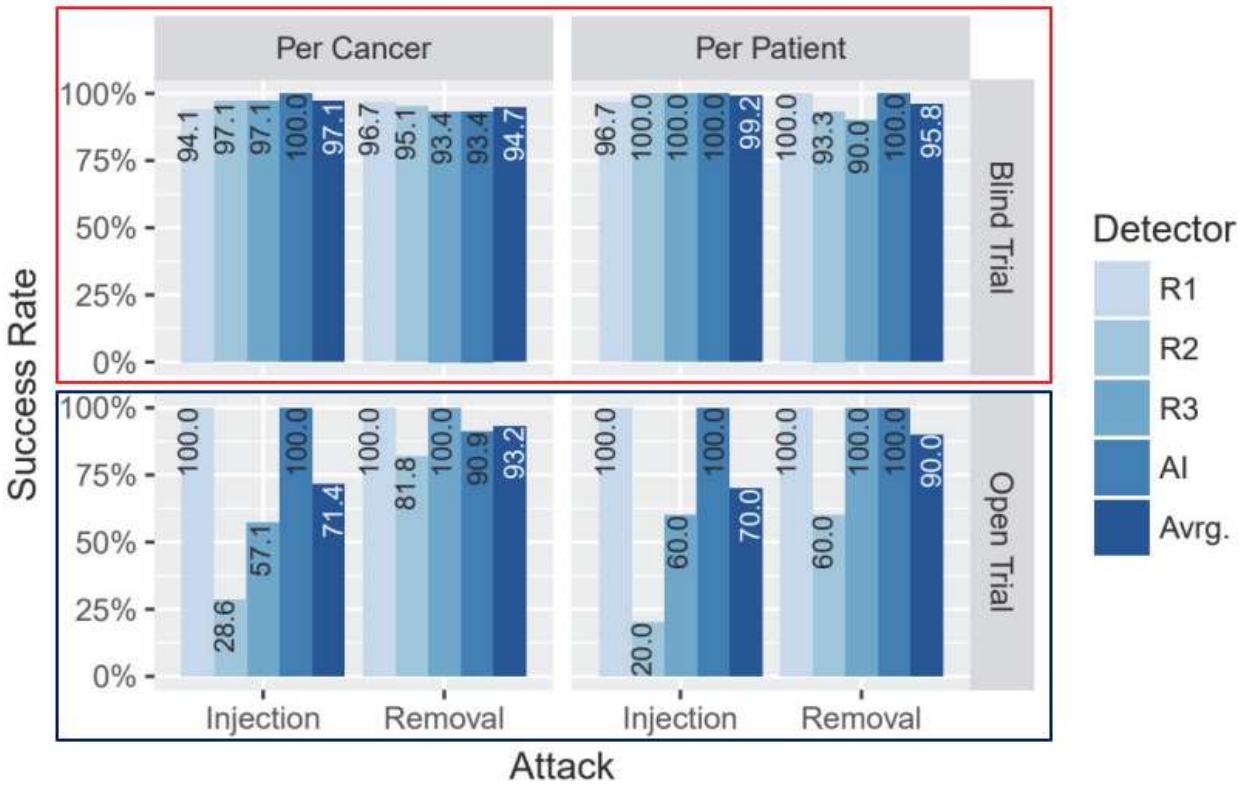
<데이터 중독(변조) 공격 결과>

→ 2년, 5년, 7년의 경험이 있는 3명의 방사선 전문의를 모집하고, 80개의 완전한 폐 CT 스캔을 진단하도록 한 뒤, 공격(변조) 여부는 모른 채 스캔 결과를 분석하도록 요청

→ 공개적으로 진행한 결과에서는 공격(변조)에 대한 정보를 제공하고, CT 스캔 이미지에서 가짜, 실제 및 제거된 결절을 식별하도록 요청

<2023 신뢰할 수 있는 인공지능 개발 안내서, 의료분야 편>

< CT-GAN 기법을 활용한 의료 CT 촬영 데이터 공격 (2/2) >



<데이터 중독(변조) 공격 성공 결과>

→ 위의 붉은색 박스에 기재된 블라인드 테스트 결과 공격 성공률, 암 주입은 평균 99.2%, 암 제거는 평균 95.8% 평균 성공률을 보였음

→ 해당 데이터에서 인공지능 모델은 중독된 데이터를 구분하지 못함
(파란색 박스에 기재된 오픈 테스트, 공격 정보를 제공했을 때 공격 성공률)

<2023 신뢰할 수 있는 인공지능 개발 안내서, 의료분야 편>

○ 디지털의료기기제조업자등은 반복된 질의 조회 차단, 적대적 공격 판단 모델 구현 등 인공지능 모델에 대한 추출/회피 공격에 대응할 수 있는 수단을 마련하여야 한다.

세부 내용 **인공지능 모델 추출/회피 공격 방어**

√ 인공지능 모델에 대한 반복된 질의 조회 요청될 경우 또는 질의 자체의 반복적인 패턴이 파악되는 경우 이에 대한 대응 방안을 제공하여야 함

※ 반복된 질의 조회 차단: 공격자가 인공지능 모델에 수많은 질의를 보내고 그 응답을 분석하여 모델의 내부 로직이나 학습 데이터를 추론하는 공격

< 반복된 질의 조회의 예시 >

- 클라우드 기반의 AI 의료 진단 API 서비스에 공격자가 짧은 시간 안에 비정상적으로 많은 수의 쿼리를 보내 모델의 동작 방식을 파악하려는 시도

< 반복된 질의 조회 차단 방어 수단의 예시 >

- API 사용량 제한: 특정 IP 주소나 사용자 계정에서 일정 시간 동안 허용되는 API 호출 횟수를 엄격하게 제한, 제한을 초과하면 해당 요청을 차단하거나 지연시킴
- 쿼리 패턴 분석 및 이상 감지: AI 모델에 대한 질의 패턴을 실시간으로 분석하여 모델 추출 공격의 특징적인 패턴(예: 무작위 질의, 미세한 입력 변화를 주는 반복 질의)을 감지하고, 의심스러운 접근을 자동으로 차단하거나 관리자에게 알림을 보냄
- 워터마킹 및 응답 난독화: AI 모델의 응답에 미세한 워터마크를 삽입하여 모델 추출을 시도하는 공격자를 식별하거나, 응답 데이터를 부분적으로 난독화하여 모델의 내부 구조를 파악하기 어렵게 만듦

√ 적대적 공격 판단을 위한 모델을 구현하여 추론 단계에서의 회피 공격에 방어할 수 있어야 함

< 적대적 공격 판단 모델 구현의 예시 >

- 환자의 MRI 영상이 AI 시스템에 입력되기 전, 공격자가 해당 영상에 미세한 노이즈를 추가하여 AI가 오진을 내리게 만들 경우, AI 시스템 스스로가 이 입력이 '조작된' 것임을 판단하여 오진을 예방

< 추론 단계에서의 회피 공격 방어 수단의 예시 >

- 입력 유효성 검증 및 적대성 평가 모듈: 주 AI 모델 앞에 별도의 보안 모듈을 두어 입력 데이터를 평가함이 모듈은 입력 데이터의 통계적 특성, 노이즈 패턴, 알려진 적대적 공격 시그니처 등을 분석하여 '적대적'이거나 '비정상적인' 입력으로 판단되면 AI 모델로의 입력을 차단하거나, 경고를 발생시킴
- 모델의 불확실성 추정 및 활용: AI 모델이 예측 결과와 함께 그 예측에 대한 '불확실성' 또는 '신뢰도' 점수를 제공하도록 구현함
- 불확실성 점수가 높게 나오거나 신뢰도가 낮은 예측 결과는 자동으로 추가 검토가 필요함을 의료진에게 알리거나, AI 기능 사용을 보류하도록 안내함
- 이는 적대적 공격이 모델의 불확실성을 높이는 경향이 있기 때문에 효과적인 방어 수단이 될 수 있음

○ 디지털의료기기제조업자등은 인공지능 시스템 운영 중 문제 발생 시 피드백 제공 화면 전환, 이용자 안내 메시지 제공, 인공지능 기술이 적용된 주요 기능의 중단이 가능하도록 방안을 마련하여야 한다.

- 인공지능 기술이 적용된 주요 기능에 대해 문제 발생 시 피드백 제공 화면 전환, 이용자 안내 메시지 제공 등 대책을 마련하여야 한다.

세부 내용 **인공지능 시스템 오류 대응 방안**

√ 인공지능 기반 이미지 분석 기능 사용 중 분석에 실패하거나 알고리즘의 이상으로 인한 오류가 발생할 경우, 사용자에게 적절한 피드백 메시지가 제공되어야 함

√ 인공지능 기술이 적용된 기능 사용 중 시스템 CPU 사용률이 임계값을 초과하거나 데이터 처리 과정에서의 연결 오류 등으로 인해 문제가 발생할 경우 사용자에게 해당 사항에 대해 알림이 제공되어야 함

예시 **인공지능 시스템 오류 대응 방안**

< 인공지능 시스템 운영 중 문제 발생 예시 >

√ 인공지능 기반의 약물 상호작용 분석 시스템이 일시적인 네트워크 오류로 인해 외부 데이터베이스에 접근하지 못하여 정확한 분석 결과를 제공할 수 없음

< 대응 방안의 예시 >

√ 명확한 상태 메시지 제공: 시스템 UI/UX에 "현재 AI 분석에 문제가 발생하여 정확한 결과를 제공할 수 없습니다. 수동으로 약물 상호작용을 확인해 주십시오." 또는 "AI 기능이 일시적으로 중단되었습니다. 잠시 후 다시 시도해 주십시오."와 같이 사용자가 상황을 명확히 인지할 수 있는 안내 메시지를 즉시 표시

√ 대안 제시 및 수동 모드 전환 유도: AI 기능이 중단되더라도 환자 진료나 치료에 지장이 없도록 수동으로 처리할 수 있는 대안을 제시하거나, 필요한 경우 수동 입력/확인 절차로 전환하도록 안내

√ 간편한 피드백/신고 기능: 사용자가 오류 상황이나 비정상적인 동작을 즉시 개발팀이나 관리자에게 보고할 수 있는 간편한 피드백 기능을 제공하여 신속한 문제 해결을 도와야 함

- 인공지능 기술이 적용된 주요 기능에 대해 문제 발생 시 긴급 중단 매커니즘이나 긴급 중단 이후 데이터 손실을 방지하기 위한 대책을 마련하여야 한다.

예시	디지털의료기기

< 인공지능 기술이 적용된 주요 기능의 중단 및 안전 모드 전환의 예시 >

√ AI 기반 수술 로봇 보조 시스템이 외부 해킹 시도, 소프트웨어 버그 또는 센서 오작동 등으로 인해 통제 불능 상태에 빠지거나, 환자에게 위해를 가할 가능성이 감지되는 비상 상황

< 대응 방안의 예시 >

√ 페일세이프(Failsafe) 메커니즘 구현: AI 시스템에 치명적인 오류나 보안 위협이 감지되면, 자동으로 AI 기반의 핵심 기능을 즉시 중단시키고, 로봇 팔 움직임을 멈추거나, 수동 제어 모드로 전환하는 '페일세이프' 기능을 설계

· 시스템 문제 발생 시 기능 정지 및 피드백 제공 화면 전환

· 시스템 문제 발생 시 서비스 제공 초기 화면 혹은 상태로 복구

· 인공지능 판단 결과의 불확실성이 높거나 문제 발생 가능성이 높은 경우 이에 대한 의사 결정을 회피하거나 사용자에게 상황에 대한 안내 제공

· 사용자의 악의적인 의도를 파악하고 이에 대한 입력을 거절

· 자동 및 자율 운영 중 시스템에 문제 발생 시 사람의 개입 유도

· 예상되는 사용자 오류에 대해 안내 및 대응 제공

√ 비상 정지 버튼 및 원격 제어: 물리적인 '비상 정지(Emergency Stop)' 버튼을 장치에 설치하고, 관리자가 원격으로 AI 기능을 비활성화하거나 시스템을 종료할 수 있는 보안 제어 채널을 마련

√ 관리자 즉시 알림: AI 기능 중단이나 비정상적인 상황 발생 시, 담당 의료진 및 시스템 관리자에게 SMS, 이메일, 전용 모니터링 시스템을 통해 즉각적으로 알림 전송

√ 상세 로그 기록 및 사후 분석: 문제 발생 시점의 모든 시스템 로그, AI 모델의 입력/출력 데이터, 내부 파라미터 값 등을 상세히 기록하여 사고 원인 분석 및 재발 방지 대책 마련에 활용

❑ 인공지능 보안을 위한 추가 대응 방안

○ 학습용 및 검증용 데이터에 대한 수집 및 출처를 관리할 수 있어야 한다.

세부 내용	데이터 수집 및 출처 관리

√ 학습 및 검증(평가)에 사용되는 데이터에 대해 수집, 출처 기록, 보관, 활용 등에 대한 정책을 보유하고 있어야 하며, 특히 데이터 수집 경로(예 : AI Hub, 데이터 안심존, 협력 병원 등)에 대해 외부 출처를 명확히 기록하고 반입/반출에 대해 관리하여야 함

√ 인공지능 모델 학습에 오픈소스 데이터셋을 사용한 경우 학습 시점에는 발견되지 않았던 오류나 편향된 결과가 나올 수 있음

√ 오픈소스 데이터셋을 사용하는 경우 관련 라이선스 조건에 대해 파악하고 관련 준수사항에 대해 인지하여야 하며, 확보된 데이터의 명확한 출처 및 관련 정보를 관리하여야 함

○ 학습에 필요한 데이터 수집 및 가공 시 발생할 수 있는 편향을 인식하고 이를 제거하는 방안을 마련하여야 한다.

세부 내용 **데이터 편향**

√ 데이터 수집 과정에서 발생하는 편향을 확인하여야 하며, 학습을 위한 특성을 선택하거나 데이터 라벨링(레이블링) 및 샘플링, 데이터 증강, 합성 데이터 생성 등의 과정에서도 편향이 발생할 수 있으므로 이를 제거하는 방안을 확보하는 것을 권고

예시 **데이터 편향**

< 의료 데이터 편향의 예시 >

√ 급성 신부전을 진단하는 모델이 주로 남성 환자에게서 수집된 데이터를 통해 학습되면 데이터셋 자체의 성비 불균형으로 인해 여성 환자들에 대한 임상적 유효성이 낮을 수 있음

√ 흉부 X-Ray 데이터를 통한 학습 시에 남성 데이터가 여성 데이터보다 현저히 많으면 여성 환자에 대한 진단 성능이 떨어질 수 있음

√ 유색 인종에 대해 저산소 혈증이라고 잘못 진단할 확률이 높거나 맥박 산소 포화도 측정 시 인종이나 피부색에 따라 진단 정확도에 차이가 발생할 수 있음

√ 의료비는 인종, 국가, 소득 수준 등에 따라 불가피한 차이를 보이므로 단순히 과거 의료비 자료만으로 미래 의료 기술에 대한 수요 예측을 시도하면 알고리즘상 인종 편향이 발생함

<2023 신뢰할 수 있는 인공지능 개발 안내서, 의료분야 편>

○ 자체적인 조직으로 데이터 라벨링(레이블링)(labeling) 작업을 수행하는 경우, 전문 인력을 통해 수행할 수 있어야 한다.

세부 내용 **데이터 라벨링(레이블링)**

√ 라벨링(레이블링) 작업은 데이터 종류에 따라 작업 대상, 범위, 상세 절차 및 라벨링(레이블링) 도구 등에 따라 달라질 수 있으며, 작업 절차에 따라 작업자 대상 교육과 가이드 문서를 확보하도록 권고

< 라벨링(레이블링) 작업 절차 >

- 데이터 획득 및 정제 : 원시 데이터 획득 및 데이터 정제 작업 진행
- 라벨링(레이블링) 작업 대상과 범위 정리 : 원시 데이터 내의 어떤 항목들을 라벨링(레이블링) 하는지 대상과 범위를 정의한다. 특히, 데이터 종류에 따라 세부적인 기준을 마련해야 한다.
- 라벨링(레이블링) 방법 및 절차 수립 : 라벨링(레이블링) 할 정보에 따라 자동/반자동/수동 등의 작업 방식을 결정하고, 작업의 배분 및 데이터별 라벨링(레이블링) 기준 등 상세한 작업 기준을 마련한다.

<2023 신뢰할 수 있는 인공지능 개발 안내서, 의료분야 편>

√ 전문 인력을 통해 라벨링(레이블링) 수행

· 데이터 라벨링(레이블링) 작업은 인공지능 모델을 학습하기 위한 원시 데이터의 주석(정답) 작업에 해당하며, 특정 질환을 진단하는 과정을 전문적이고 세밀하게 가공해야 하므로 이 역시 전문 의료진의 참여가 필수적임

· 전문의 확보 등이 어려워 데이터 라벨링(레이블링)을 자체적으로 수행한 경우, 조직 내부 규정 등을 통해 관련 자격 등 기준을 수립하여 이에 해당되는 인력이 수행하도록 하는 것을 권고

· 의료 영상 라벨링(레이블링) 관련 교육 20시간 이수 등과 같은 자격 요건을 문서화하여 이에 해당되는 자가 수행하도록 하는 것을 권고

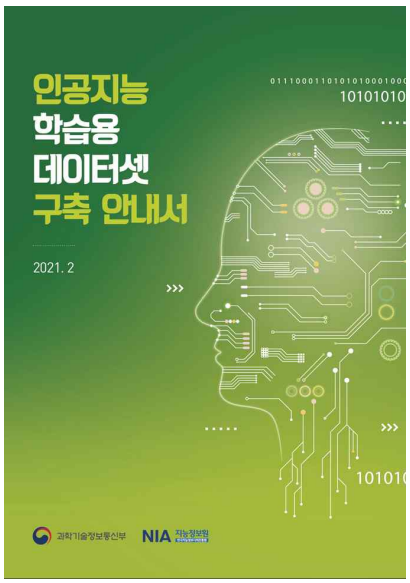
· 라벨링(레이블링) 작업자의 특정 의도, 실수로 인한 특성 누락, 무의식적인 판단으로 인한 편향이 발생할 수 있으며, 라벨링(레이블링) 작업자 구분(전문 의료진, 크라우드워커)에 따라 편향이 발생할 수 있음

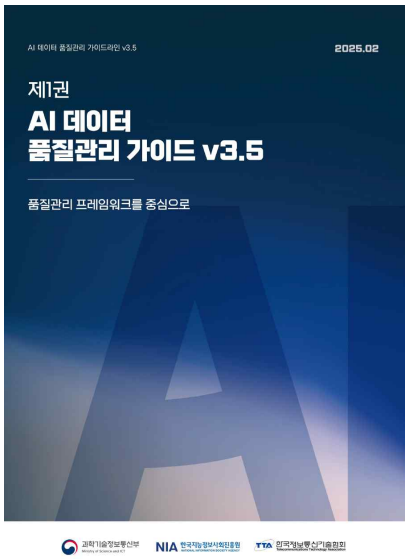
· 라벨링(레이블링) 작업자가 발생시킬 수 있는 편향의 잠재적 원인을 사전에 파악하고 라벨링(레이블링) 작업 기준의 교육, 전문 검수자 확보 등을 통해 편향을 방지하여야 함

예시 **데이터 라벨링(레이블링)**

< 인공지능 학습용 데이터셋 라벨링(레이블링) 안내 >

√ 인공지능 학습용 데이터셋 구축과 관련하여 방안 및 품질관리에 대한 가이드는 '인공지능 학습용 데이터셋 구축 안내서(2021.2)', '인공지능 학습용 데이터 품질관리 가이드라인 v3.5(2025.2)' 등을 참고하는 것을 권고





○ 신뢰할 수 있는 실행 환경(컴퓨팅 환경)을 검증하고, 데이터에 대한 블러링 처리, 인공지능 시스템에 대한 보안강화를 위한 보안 기법 등을 적용할 수 있어야 한다.

세부 내용 **신뢰된 운영환경**

√ 신뢰할 수 있는 실행 환경(컴퓨팅 환경) 요구사항을 정의하고 운영 환경에 대해 검증할 수 있어야 함

· 인공지능 모델이 포함된 디지털의료기기가 실행되는 시스템의 하드웨어 사양(CPU, GPU, RAM 등)에 대해 문서화된 기준에 따라 실행되도록 하여야 하며, 특정 소프트웨어 사양(예 : Python 3.8 이상, CUDA 11.0 이상 등)도 확인하여야 함

√ 연구 목적과 관련이 없는 학습 및 검증용 데이터에 대한 블러링 처리를 통해 안전하게 데이터를 사용할 수 있어야 함

· 학습 및 검증 데이터 내에 연구 목적과 관련 없는 신체 정보, 학습 미대상 신체 부위, 개인 고유 식별 번호 등에 대해 파악될 경우 블러링 처리 등을 통해 비식별화하여야 함

· 의료 영상 데이터 샘플을 확인하여 환자의 이름, ID, 촬영일자 등 개인 식별 정보가 식별 불가능한 수준인지 검증할 수 있어야 하며 필요 시, 자동화 도구를 통해 특정 영역에 대해 블러링 처리를 수행하거나 수동으로 진행하여야 한다.

√ 인공지능 시스템의 보안 강화를 위한 보안 기법을 적용

· 대부분 의료기기가 환자 데이터의 교환, 수집 및 저장 등을 위해 원격지 또는 네트워크로 연결된 병원 내 서버, 환자 단말기 등으로 데이터를 전송하므로 일반적인 인터넷 환경에서 발생 가능한 보안 위험과 인공지능 시스템을 고려한 보안 기법을 적용하여야 함

< 인공지능 시스템의 보안 기법 예시>

- 격리 : 의사결정에 활용되는 주요 기능을 모듈 단위로 분리하고 모듈 간 접근제어 기법을 설정하여 인공지능 시스템에 대한 보안성을 확보할 수 있음
- 탐지 : 인공지능 시스템(네트워크 등 운영 환경 포함)에 대한 공격을 지속적으로 모니터링하여 네트워크 보안 상태를 종합적으로 분석하고 현재의 위험 수준을 측정할 수 있다.

<2023 신뢰할 수 있는 인공지능 개발 안내서, 의료분야 편>

제13조(위험 관리 활동)

① 디지털의료기기제조업자등은 다음 각 호의 사항을 포함하여 제품 개발 전주기에 걸쳐 위험 관리 활동을 수행하여야 한다.

1. 제품 수명 주기 전반적인 위협 모델링
2. 위협 및 취약점에 대한 식별 및 위험 평가
3. 보안 위험 완화를 위한 위험 통제 조치 설계, 구현 및 검증
4. 잔여 위험 평가 및 평가 보고서 작성
5. 시판 후 위협 및 취약점 모니터링

② 의료서비스제공자는 제품 사용 도중 확인된 위협 및 취약점에 대해 디지털의료기기 제조업자등과 협력하여 위험 관리 활동을 지원할 수 있다,

❑ 제품 수명 주기 전반적인 위협 모델링 수행

○ 디지털의료기기제조업자등은 제품 개발 전주기에 걸쳐 위험 관리 활동을 수행하여야 한다.

보안 활동	위협 모델링
구분	**설명**
보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
보안활동 주체	디지털의료기기제조업자등의 개발자
보안활동 수행 결과	**(위험관리문서)** - 위험관리(Risk Management) 프로세스의 결과를 위험관리문서에 기록하여야 함

○ 디지털의료기기제조업자등은 제품의 설계, 개발, 시험, 배포 및 운영 전 단계에 걸쳐 위협 모델링 기법을 적용하여 위협 요소를 식별하고 이를 정량적으로 평가하는 활동을 수행하여야 한다.

세부 내용 **위협 모델링**

√ 제품 수명 주기 전반적으로 걸쳐 위협 모델링(STRIDE, DREAD 모델링 등)을 적용하여 위협 요소를 식별하고 각 위협에 대한 피해 가능성 및 피해 범위를 정량적으로 평가할 수 있어야 함

< STRIDE Model >

1) 스푸핑 (Spoofing)
2) 변조 (Tampering)
3) 부인 (Repudiation)
4) 정보 유출 (Information disclosure)
5) 서비스 거부 (Denial of service)
6) 권한 상승 (Elevation of privilege)

√ 위협 및 취약점(잠재적 위험 포함)을 체계적으로 식별하고 이에 대한 위험 평가를 수행하여야 하며 심각도와 발생 가능성을 종합한 위험 평가를 수행하여야 함

· 식별된 취약점은 제품 수명주기 전반에 걸쳐 지속적으로 평가되어야 하며 각 취약점에 대해 심각도와 발생 가능성을 종합한 위험 평가를 수행하여야 함

√ 보안 위험을 완화하기 위한 위험 통제 조치를 설계하고 해당 통제 전략의 실행 여부 및 유효성 검증 결과를 기록으로 관리하여야 함

√ 잔여 위험(Residual Risk)에 대한 평가와 함께 위험 평가 보고서 등 위험 관리 산출물을 체계적으로 관리하고 운영하여야 함

※「의료기기의 사이버보안 적용방법 및 사례집(2022)」과「의료기기 소프트웨어 허가·심사 가이드라인(2023)」을 참조하여 작성할 수 있음

√ 제품 출시 이후에 새롭게 발견할 수 있는 보안 취약점에 대응하기 위하여 취약점 모니터링 체계 및 대응 절차를 수립하고 관련 기록을 보유하여야 함

√ 의료서비스제공자가 제품 사용 중 위협 또는 취약점을 확인하고 이에 대한 협력을 요청하는 경우 디지털의료기기제조업자등은 관련 위험 관리 활동을 지원할 수 있어야 함

예시 **위협 모델링**

√ 제품 개발 초기에 설계 문서에 위협 모델링 기법(예 : STRIDE)을 적용한 위협 항목 도표를 작성하고 주요 위협과 기능(자산)을 연결

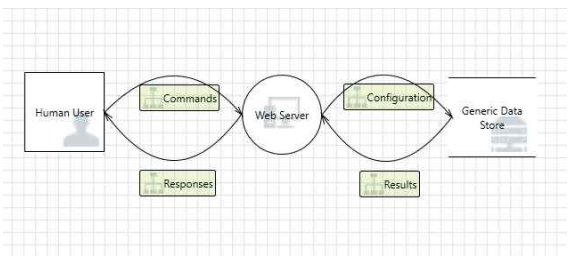
√ FMEA, CVSS 등을 활용하여 위협 우선순위를 정렬하고 이를 위험 관리 문서, 파일 등에 포함

√ 제품 기능 별로 공격자 관점의 시나리오 예시를 도출하여 취약 경로를 식별

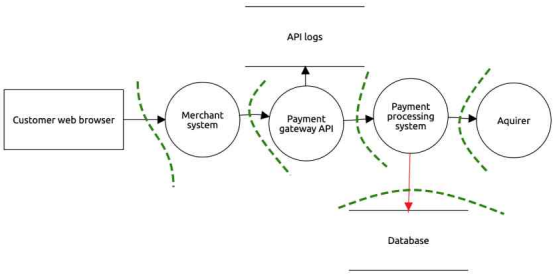
√ 주요 위협에 대한 유형, 피해 예상 정도, 관련 기능(자산), 대응 방안 등을 파악

예시 **STRIDE 기반 위협 모델링 도구(예시)**

구분	내용
Microsoft Threat Modeling Tool	- 마이크로소프트에서 제공하는 위협 모델링 도구로서 STRIDE 분석을 위한 대표적 도구 - 데이터 흐름 다이어그램(DFD)을 작성하고, 컴포넌트에 대한 잠재적 위협을 식별 - 주요 기능 · 데이터 흐름 다이어그램 작성 · 위협 식별 이후 STRIDE 카테고리 분류 · 위협 완화를 위한 권장 조치 제시 · 보고서 생성 등
OWASP Threat Dragon	- OWASP(Open Web Application Security Project)에서 제공하는 웹(Web) 기반 위협 모델링 도구 - 주요 기능 · 데이터 흐름 다이어그램 작성 · STRIDE 기반 위협 분석 · 다수 사용자 협업 기능 · 보고서 생성 등



<Microsoft Threat Modeling Tool 가이드(예시)>



<OWASP Threat Dragon 가이드(예시)>

예시 **STRIDE 기반 위협 모델링(예시)**

기능/자산	STRIDE	위협시나리오	발생(악용) 가능성 (1 : 낮음, 2 : 보통, 3 : 높음)	영향도 (심각도) (낮음/ 보통/ 높음)	대응 방안
로그인 인증	Spoofing	공격자가 의사의 계정을 탈취하여 로그인 시도	2	높음	사용자 ID/PW 정책 강화, 2차 인증 등 적용
DICOM 영상 전송	Tampering	DICOM 파일이 전송 중 중간자 공격을 통해 변조됨	2	높음	전송 경로 암호화, 해시값 무결성 확인
영상 요청/조회 기록	Repudiation	의료진이 자신이 요청한 기록을 부정하여 감사 회피	1	보통	감사 로그 관리
영상 파일 서버 저장	Information Disclosure	해커가 파일 서버에 침입하여 환자 데이터 유출	1	높음	저장소 암호화, 접근권한 세분화 등
PACS 서버 서비스	Denial of service	공격자가 대량의 요청을 보내 PACS 서버 다운 시도	2	높음	요청 시도 횟수 제한, 공격자 IP 탐지 및 차단
관리자 권한 설정	Elevation of Privilege	일반 사용자가 시스템 취약점을 통해 관리자 권한 획득	1	높음	권한 강화 및 분리 등

< STRIDE 기반 위협 모델링 도표(예시) >

< 위협 모델링 관련 ISO 81001-5-1 >

IEC 81001-5-1:2021에서는 **'위협 모델링'**에 대해 많은 것을 설명하고 있다.

위협 모델링을 활용해 취약성(Vulnerabilities)을 식별하고 이에 따른 위협(Threats)을 추정 및 평가하며 이들을 통제하고 위험 통제 조치의 효과성을 모니터링해야 한다고 명시하고 있으며,

위협 모델(Threat Model)은 정확성과 이해도를 보장하기 위해 개발 팀에 의해 검토 및 검증되어야 한다고 명시되어 있으며 출시된 제품에 대해서도 주기적으로(최소 연 1회) 검토하며 설계 변경이 없더라도 제품에 대한 새로운 위협이 발생하면 업데이트되어야 한다고 명시하고 있다.

또한, Annex C를 통해 위협 모델링에 대한 일반사항, 관련 기법들에 대해 설명하고 있다.

<출처>: IEC 81001-5-1:2021

❑ 위협 및 취약점에 대한 식별 및 위험 평가

○ 제품과 관련된 모든 취약점(잠재적 위험 포함)을 체계적으로 식별하고, 발생 가능성과 심각도를 기반으로 위험을 평가하여야 한다.

예시 **위협 모델링 및 점수 산정(예시)**

√ 제품의 주요 기능별로 취약점을 파악할 수 있는 CWE 체크리스트 등을 활용하여 항목별 검토를 수행할 수 있다.

CWE ID	취약점 유형	설명	점검 항목
CWE-79	크로스 사이트 스크립팅 (XSS)	사용자 입력값이 HTML 또는 스크립트로 처리되어 클라이언트에서 악성코드 실행	사용자 입력 필드에 대한 특수문자 필터링 적용
CWE-89	SQL 인젝션 (SQL Injection)	사용자 입력값이 쿼리 문자열에 삽입되어 의도치 않은 SQL 실행	사용자 입력에 대해 DB 쿼리가 직접 삽입되지 않도록 조치
CWE-352	사이트 간 요청 위조 (CSRF)	사용자가 로그인된 상태에서 공격자가 의도한 요청을 대신 수행하게 함	중요한 요청에 CSRF 토큰 적용
CWE-416	해제 후 사용 (Use After Free)	해제된 메모리 참조로 인한 시스템 충돌 유도	메모리 해제 후 포인터 초기화

< CWE 기반 취약점 체크리스트(예시) >

√ 또한, CVE(Common Vulnerabilities and Exposures) 기반의 위협 탐지 방안 및 CVSS(Common Vulnerability Scoring System) 등을 활용하여 주요 취약점의 점수(Score)를 파악하여 위험 우선순위를 산정하고 이를 문서화한다.

< CVE 기반 위험 관리 예시>

1) 소프트웨어 구성 요소 식별 (SBOM 저작 도구를 통해 추출하거나 설계 단계에서 구성 요소 식별)

2) NVD(National Vulnerability Database) 또는 CVE 데이터베이스를 활용하여 취약점 파악

- NVD : https://nvd.nist.gov/

3) 해당 DB에서 파악된 취약점에 대해 CVSS 스코어*를 확인하여 위험 수준 평가

* 기본 스코어 메트릭(Base Score Metrics), 시간 스코어 메트릭(Temporal Score Metrics), 환경 스코어 메트릭(Environmental Score Metrics)에 따라 점수를 산정함 (CVSS Version 3.1 기준)

- CVSS User Guide : https://www.first.org/cvss/user-guide

4) 평가 결과에 따른 대응 조치 수행 및 이력 관리

√ 또는 OWASP Top 10 등의 공개 문서 등을 활용하여 취약점 분석 범위를 확대한다.

❑ 보안 위험 완화를 위한 위험 통제 조치 설계, 구현 및 검증

○ 식별된 보안 위험을 최소화하기 위한 통제 조치를 설계하고 해당 조치가 유효하게 작동하는지 검증하여야 한다.

예시 **위험 통제 조치 설계, 구현 및 검증(예시)**

√ 로그인 기능에서의 보안 위험을 완화하기 위해 비밀번호 작성 규칙(예: 영문자/숫자/특수문자 조합 8자리 이상 등)과 인증 횟수 제한 기능 등을 구현하거나 입력값 필터링, 검증 등을 적용함

√ 위험 통제 조치는 소프트웨어적으로도 구현할 수 있고 문서 또는 운영적 조치로도 구현할 수 있으며 구현된 조치는 검증이 가능하여야 함

위협 유형 (CWE-ID)	통제 조치	실행 방안	검증 방법
인증 우회 (CWE-306)	소프트웨어	- ID/PW 기반 로그인 구현 - 2차 인증 적용 - 로그인 시도 횟수 제한 기능 구현	- 로그인 우회 테스트 - 비인가자 로그인 시도 기록 확인
	문서/운영	- 사용자 계정 승인 절차 수립 - 접근 권한 관리표 작성	- 접근 권한 관리표 기록 확인
크로스 사이트 스크립트 (CWE-79)	소프트웨어	- 사용자 입력 시 HTML 이스케이프 처리 - CSP 헤더 설정	- XSS 삽입 테스트 결과 확인
	문서/운영	- 인터페이스 설계 단계에서 입력 필터링 포함하여 설계	- 설계 보고서 확인
....			

❑ 잔여 위험 평가 및 평가 보고서 작성

○ 통제 이후에도 존재하는 잔여 위험에 대해 발생 가능성과 심각도를 고려하여 위험을 평가하고, 허용 가능한지 여부를 검토하기 위한 평가 보고서 등을 작성하여야 한다.

예시 **잔여 위험 평가**

√ 통제 이후의 위험 수준을 평가하여 위험 관리 파일 등에 기록하고 허용 기준과도 비교함

√ 잔여 위험과 더불어 위험에 대한 전반적인 평가 결과에 대해 보고서(위험 관리 보고서 등)로 작성하여 승인/검토 과정을 거치고 관련 이해관계자 등에게 전달함

√ 또한, 제품 출시 이후에도 보안 취약점을 지속적으로 모니터링하여야 하며, 취약점 발견 시 『디지털의료기기 전자적 침해행위 보안지침』 제20조 및 제22조에 따라 조치 및 대응하여야 하며 관련 절차와 책임 체계를 갖추어야 함

· 정기적인 보안 모니터링 수행 및 보안 관련 로그 수집
· 취약점 감시/공개/조치 절차 문서화
· 식별한 취약점은 정의된 공개 절차 등을 통해 통보
· 취약점 내용, 심각도, 영향, 대응 방안 등을 포함하여 보고
· 필요한 경우, 홈페이지 등에 취약점 공지
· 취약점 공개 시 상세 내용 및 대응 방안 포함
· 공개 시점은 식품의약품안전처와 협의하여 조정
· 취약점 패치, 업데이트 등의 조치 방안 마련
· 취약점 조치 이후에도 지속적인 보안 모니터링 실시

√ 관련 절차와 더불어 디지털의료기기제조업자등에서 정의한 부서/담당자 별 책임과 역할 등을 절차서 등에 명시하며 승인/검토 과정을 거친다.

√ 의료서비스제공자는 제품 사용 도중 확인된 위협이나 취약점에 대해 파악할 경우 디지털의료기기제조업자등에게 알리고, 제조업자등에서 협력 요청 시 위험 관리 활동을 지원할 수 있다.

· 위협의 경우 전자적 침해행위 등을 포함하며 취약점의 경우 제품 자체에서 발생한 취약점에 대해 의료서비스제공자는 제조업자 등의 대응 협조 요청이 있을 경우 지원할 수 있다.

제14조(개발 및 검증 활동)

① 디지털의료기기제조업자등은 보안 코딩 표준, 보안 설계, 보안 테스트, 취약점 테스트 등 보안 요구사항을 고려하여 제품을 개발 및 검증하여야 한다.

② 디지털의료기기제조업자등은 검증 활동에 사용하는 테스트 도구에 대한 유효성을 확인하여야 한다.

③ 디지털의료기기제조업자등은 필요한 경우 제1항 내지 제2항의 개발 및 검증 활동에 대한 문서를 의료서비스제공자에게 제공할 수 있다.

❑ 보안을 고려한 개발 및 검증 활동

○ 디지털의료기기제조업자등은 보안 위협으로부터 제품이 안전하게 동작할 수 있도록 코딩 표준, 보안 설계, 보안 테스트, 취약성 테스트 등 보안 요구사항을 고려하여 제품을 개발 및 검증하여야 한다.

- 소프트웨어 설계·개발 단계에서 소프트웨어 개발보안 관련 표준 가이드를 준수하여 소스코드에 대한 보안약점이 존재하지 않도록 시큐어 코딩을 적용하여야 한다.

세부 내용	디지털의료기기

√ 소프트웨어 설계개발 단계에서 보안 취약점을 방지하기 위해 개발 보안 관련 표준 가이드(OWASP Secure Coding Practices, CERT C/C++, Misra-C/C++ 등)를 준수하여 코딩하여야 함



< 시큐어 코딩 관련 개발 가이드 예시 >

<시큐어 코딩 규칙 참고 자료>

- 소프트웨어 개발보안 가이드(행정안전부/한국인터넷진흥원, 2019)
- JAVA 시큐어코딩 가이드(행정자지부, 2012)
- C 시큐어코딩 가이드(행정자지부, 2012)
- Android-JAVA 시큐어코딩 가이드(안전행정부, 2011)
- JavaScript 시큐어코딩 가이드(과학기술정보통신부, 2023)
- Python 시큐어코딩 가이드(과학기술정보통신부, 2023)
- ISO/IEC TS 17961:2013(C Secure coding rules)

√ 소스코드 보안 약점 분석 도구를 사용하여 보안 약점을 확인하고 점검 결과를 문서화하여야 함

<소스코드 보안약점 분석 도구 예시>

- 국내 소스코드 보안약점 분석 도구 예시
  · 국내 공통평가기준(CC) 인증제품
  접근 방법: 국가사이버보안센터(https://ncsc.go.kr/) '보안적합성검증' → 안전성 검증필 제품목록'소스코드 보안약점 분석도구' 검색
- 국외 소스코드 보안약점 분석 도구 예시
  · NIST 홈페이지 공지 (https://nist.gov)

세부 내용	디지털의료기기

√ 소스코드 상에서 디버깅·시험용 코드·주석 등 제품 개발 및 검증 과정에서 불필요한 기능 및 코드는 제거하여야 함

· 기기 운용에 불필요한 기능 및 코드를 제거하여야 함

· 불필요한 기능 및 코드의 예

- 디버깅 용도로 개발된 소스코드
- 테스트 용도로 개발된 소스코드
- 개발자만 사용 가능한 Shell 인터페이스(/bin/dash, /bin/bash, /bin/ash, /bin/zsh 등)
- 개발자만 사용 가능한 명령어
- 사용되지 않는 소스코드(주석처리 코드 등)
- 설치파일 또는 펌웨어 이미지에 포함된 불필요한 코드)

보안 활동	디지털의료기기	
구분		**설명**
제1항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(디지털의료기기)** - 소스코드 보안약점 및 취약점 제거 **(기록)** - 소스코드 보안약점 진단 도구를 이용한 점검 결과

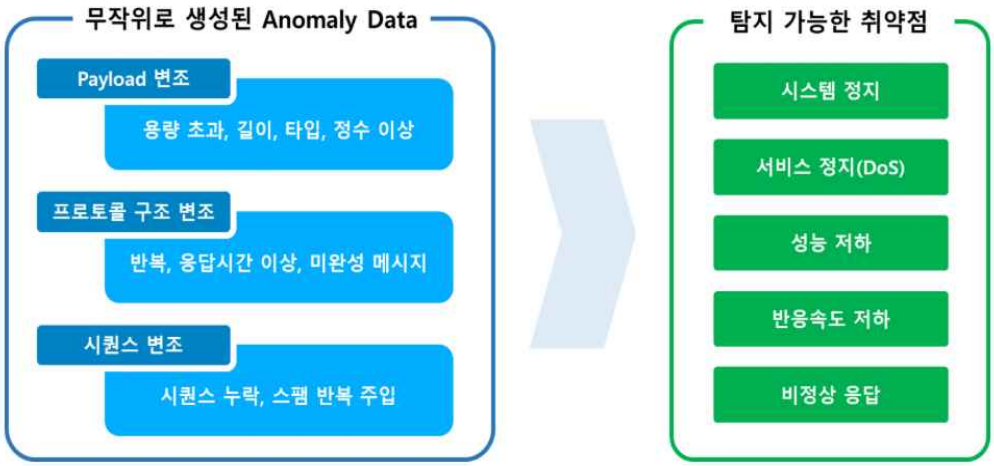
- 다양한 보안 테스트, 취약점 테스트 등을 수행하여야 하며 그 결과를 제품 개발 및 검증에 반영하여야 한다.

세부 내용	보안 테스트 & 취약점 테스트

√ 정적 분석, 침투 테스트(퍼즈테스트 포함), 메모리 보안 테스트, 입력 값 검증 테스트, SQL Injection 테스트 등 다양한 보안 시험을 수행하여야 하며 그 결과 및 수행 이력에 대해 문서화해야 함

· 정적 분석 도구, 퍼즈테스트 도구, 성능 시험 도구 등 보안 및 품질 시험 도구에 대해 시험 대상, 시험 환경, 시험자, 검토자 및 승인자, 시험 절차, 시험 결과, 유효성 확보 기준 등의 항목들을 포함하여 도구에 대한 유효성 검증 기록을 보유해야 함

· 퍼즈(Fuzz) 테스트



<출처>: 아우토크립트(AUTOCRYPT)

보안 활동	보안 테스트 & 취약점 테스트	
구분		설명
제1항 기준	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 결과 (output)	**(기록)** - 침투시험 결과(수동 시험 또는 취약점 점검 도구를 이용한 시험) **(디지털의료기기)** - 침투시험 결과를 반영하여 취약점 제거

○ 디지털의료기기제조업자등은 제품 검증 결과를 신뢰할 수 있도록 검증 활동에 사용하는 테스트 도구에 대한 유효성을 확인하여야 한다.

- 검증 활동에 사용된 모든 테스트 도구(예: 상용 소프트웨어, 구성 가능한 패키지, 고유 개발 시스템 등)의 유효성을 확인하여야 한다.

세부 내용 **테스트 도구 유효성 확인**

√ 테스트 도구에 대한 유효성 확인을 수행해야 함
· 각 테스트 도구를 식별하고, 각 도구의 용도와 역할, 잠재적 위험을 명확히 정의해야 함
· 각 도구에 대해 어떤 유효성 확인 활동을 수행할 것인지, 합격 기준이 무엇인지를 포함하는 계획을 수립해야 함
· 정의된 계획에 따라 도구를 테스트하고, 그 결과가 합격 기준에 부합하는지 유효성 확인을 수행함

√ 보안 및 품질 시험 도구에 대한 유효성 검증 기록을 보유해야 함
· 시험 대상, 시험 환경, 시험자, 검토자 및 승인자, 시험 절차, 시험 결과, 유효성 확보 기준 등의 항목을 포함

예시 **테스트 도구 유효성 확인 방법**

√ 도구 공급업체 정보를 활용하여 유효성 확인 수행
· 공급업체의 품질관리시스템(QMS)를 통해 도구의 개발 프로세스가 잘 관리되고 있음을 입증, 공급업체가 제공하는 유효성 확인 보고서 등을 검토
· 외부의 신뢰된 기관으로부터 받은 인증서(예 : CC 인증서) 등

√ 직접 유효성 확인 수행
· 도구가 의도한 기능을 오류 없이 올바르게 수행하는지 확인하기 위해 주요 기능에 대해 식별
· 식별된 주요 기능에서 발생하는 입력에 대해 정상/비정상 값을 통해 예상되는 기대 출력과 실제 출력이 동일한지 검증
· 도구가 일관된 성능을 유지하며 반복적으로 사용해도 안정적으로 동작하는지 확인
· 비교테스트 : 동일한 기능을 수행하는 다른 검증된 도구 또는 수동 방식과 비교하여 결과 확인

○ 개발 및 검증 활동 내용을 문서로 작성하여 보관하고, 의료서비스제공자 요청 시, 개발 및 검증에 대한 문서를 제공할 수 있다.

- 안전성과 신뢰성을 평가하는 데 활용할 수 있도록 충분한 정보와 그에 대한 근거를 포함하여야 한다.

제15조(레거시 디지털의료기기 관리 활동)

① 디지털의료기기제조업자등은 전자적 침해행위에 대비하여 디지털의료기기를 개발하는 경우 지원 종료 이후 보안 위험을 최소화하도록 디지털의료기기를 설계 및 구현하여야 한다.

② 디지털의료기기제조업자등은 제품 출시 이후 예상 지원 종료 일정과 수명 종료 이후 예상 지원 계획 등에 대해 의료서비스제공자에게 제공하여야 한다.

③ 디지털의료기기제조업자등은 의료서비스제공자에게 제품 수명 종료 단계 내에서 위험 및 취약점이 발견되는 경우 의료서비스제공자와 협력하여 이를 해결하기 위한 방안을 마련해야 한다.

④ 제3항의 방안에는 다음 각 호의 사항이 포함되어야 한다.

1. 위험 식별, 분석, 평가 등 위험 관리 방안
2. 제품 또는 컴포넌트 패치
3. 제품 보안 문서

⑤ 디지털의료기기제조업자등은 의료서비스제공자에게 안전하게 개인정보 등을 제거하기 위한 방법을 제공하여야 한다.

❑ 지원 종료 이후 디지털의료기기 관리 활동

○ 보안 위험을 최소화하기 위해 보안을 고려한 설계 및 구현(예: 시큐어 코딩, 보안 설계, 보안 테스트 등)하여야 한다.

○ 레거시 디지털의료기기에 대한 관리 활동을 수행하여야 한다.



< 소프트웨어 수명주기 >
<출처>: Principles and Practices for Medical Device Cybersecurity

구분	내용
수명 종료 (EOL, End of Life)	- 제조사나 공급업체가 제품의 생산, 판매 및 마케팅 활동을 완전히 중단하는 시점 - 생산 및 판매 중단 : 제품이 더 이상 제조되지 않으며, 공식 채널을 통한 신규 구매 불가능 - 제한적인 기술 지원 : EOL 이후 문제가 발생했을 때 제조사나 공급업체로부터 제한적인 기술 지원만 받을 수 있음
지원 종료 (EOS, End of Support)	- 제조사나 공급업체가 제품에 대한 모든 서비스 지원(기술지원) 활동을 중단하는 시점 - 업데이트나 패치 중단 : 버그 수정, 성능 개선, 새로운 기능 추가, 보안 취약점 패치가 제공되지 않음 - 기술지원 중단 : EOS 이후 공식적인 기술지원(전화, 이메일, 온라인 도움 등)을 받을 수 없음

< 지원 종료 시점에 따른 디지털의료기기 외의 관리 범위>

본 보안지침에서는 디지털의료기기 자체에 대한 수명 종료(EOL) 이후의 제한된 지원 범위를 고객(의료서비스제공자 및 사용자 등)에게 안내하고, 지원 종료 예상 시점을 안내하여야 함을 명시되어 있다. 또한, 디지털의료기기 범위 내에 운영체제 및 DBMS, 3rd Party 제품들이 포함된 경우 이를 모두 고려하여 적용하여야 하며 의료서비스제공자 및 사용자에게 예상 지원 종료 시점 및 지원 범위 등을 공지하여야 한다.

- 수명 종료에 따른 디지털의료기기 관리 활동을 수행하여야 한다.

세부 내용	수명 종료 이후 디지털의료기기 관리

√ 수명 종료 일정, 수명 종료 이후 지원 계획, 예상 지원 종료 일정 등을 의료서비스제공자 및 사용자에게 제공하여야 함
· 수명 종료 일정의 경우, 제품 출시일을 기준으로 예상하여야 하며 수명 종료 이후의 제한된 지원 범위(예: 보안 패치만 제공, 보안 관련 기술 지원 등), 조치 사항(예: 최신 버전 업그레이드 유상 지원 등) 등에 대한 구체적 사항을 명시하여야 함
· 여러 채널을 활용하여 수명 종료 일정과 수명 종료 이후 제공되는 제한적인 지원 계획, 예상 지원 종료 일정 등 관련 정보를 통지해야 함

√ 수명 종료 이후 지원 종료 시점까지 신규 위험 및 보안 취약점이 발견될 경우 이를 대응하기 위한 방안을 마련해야 함
· 위험 식별, 분석, 평가 등 위험 관리 방안, 제품 또는 구성요소 패치, 제품 보안 문서 등을 의료서비스제공자 또는 사용자에게 제공해야 함
· 보안 위험 및 취약점 해결을 위한 방안을 포함하여 안내 조치를 전달할 수 있음

예시	통지 방법

√ 공식 웹사이트 및 제품 지원 페이지
√ 이메일을 통한 직접 전달
√ 제품 내 알람, 시작 화면 메시지, 설명 메뉴 내 공지 등
√ 영업 및 기술 지원팀을 통한 안내
√ 서비스 계약서 및 라이선스를 통한 고지

- 지원 종료에 따른 디지털의료기기 관리 활동을 수행하여야 한다.

세부 내용	지원 종료 이후 디지털의료기기 관리

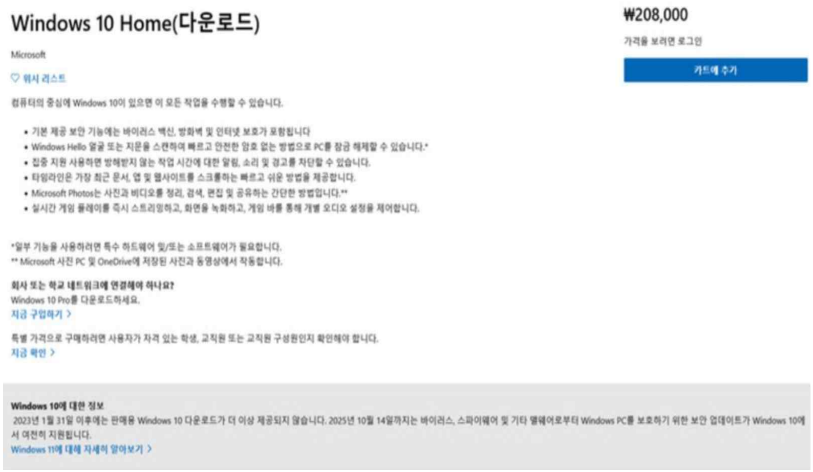
√ 지원 종료 일정을 의료서비스제공자 및 사용자에게 알려야 함
· 지원 종료 일정에 가까워졌을 때 지원 종료 날짜 이후에는 해당 기기가 지원되지 않는 레거시 상태로 전환됨을 알려야 함
· 지원 종료 날짜 이후 기기 보안 및 지속적인 사용에 대한 위험 부담에 대한 책임은 의료서비스제공자 및 사용자에게 있음을 알려야 함
· 의료서비스제공자 및 사용자가 레거시 기기의 사용을 중지하고 안전한 기기로 교체하기 위한 충분한 시간을 확보할 수 있도록 지원 종료 날짜를 계속 전달해야 함

예시 **레거시 디지털의료기기 관리 활동**

<공식 웹사이트 – Windows 10 지원 종료>

[수명종료 통지 내용]

- 수명 종료일 : 2023년 1월 31일 (MS 웹사이트를 통해 판매 중단)
- 지원 종료일 : 2025년 10월 14일까지 보안 업데이트 지원

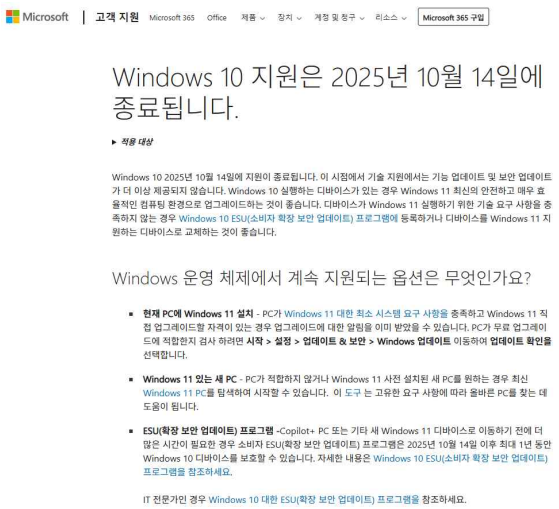


<출처>: Microsoft 홈페이지

[지원종료 통지 내용]

- 지원 종료일 : 2025년 10월 14일
- 기능 업데이트 및 보안 업데이트 중단
- ESU(소비자 확장 보안 업데이트 프로그램) 등록 또는 Windows 11 교체

  * ESU: 사용자 비용 지불 시 2028년 10월 10일까지 보안 업데이트 제공



<출처>: Microsoft 홈페이지

❍ 개인정보를 안전하게 제거하기 위한 방법(예: RDBMS 테이블 내 데이터 완전 삭제 스크립트 실행 방법 제공, 파일 DB 및 디스크 완전 삭제 방법 제공 등)을 의료서비스제공자에게 제공하여야 한다.

세부 내용 **개인정보의 안전한 제거**

√ 의료서비스제공자가 개인정보를 안전하게 제거할 수 있도록 사용자 매뉴얼에 해당 방법을 명시해야 함
· 개인정보 복구가 불가능하도록 완전하게 삭제하는 방법을 제공해야 함
· 법적 요구사항에 따라 개인정보를 파기할 경우, 안전한 조치를 제공해야 함
√ 안전하게 개인정보를 제거하기 위한 도구를 제공할 수 있음

보안 활동 **개인정보의 안전한 제거**

구분		설명
제5항 기준	보안활동 영역	의료서비스제공자 또는 사용자 영역에서 보안활동이 수행됨
	보안활동 주체	의료서비스제공자
	보안활동 수행 입력 (input)	**(사용자 매뉴얼)** 의료서비스제공자에게 안전하게 개인정보를 제거하기 위한 방법을 제공해야 함 **(도구)** 디지털의료기기제조업자등이 제공하는 개인정보 제거 도구

예시 **개인정보의 안전한 제거 방법**

√ 저장매체의 중요정보 저장영역을 '0', '1'로 3회 덮어쓰기
√ 전체 저장매체를 암호화하고 암호키만 완전 삭제

제16조(소프트웨어 구성요소 명세서 관리 활동)

① 디지털의료기기제조업자등은 디지털의료기기 내 취약점 발견, 보안 및 침해사고 및 이를 해결하기 위한 활동을 수행하는 데 소프트웨어 구성요소 명세서를 활용할 수 있다.

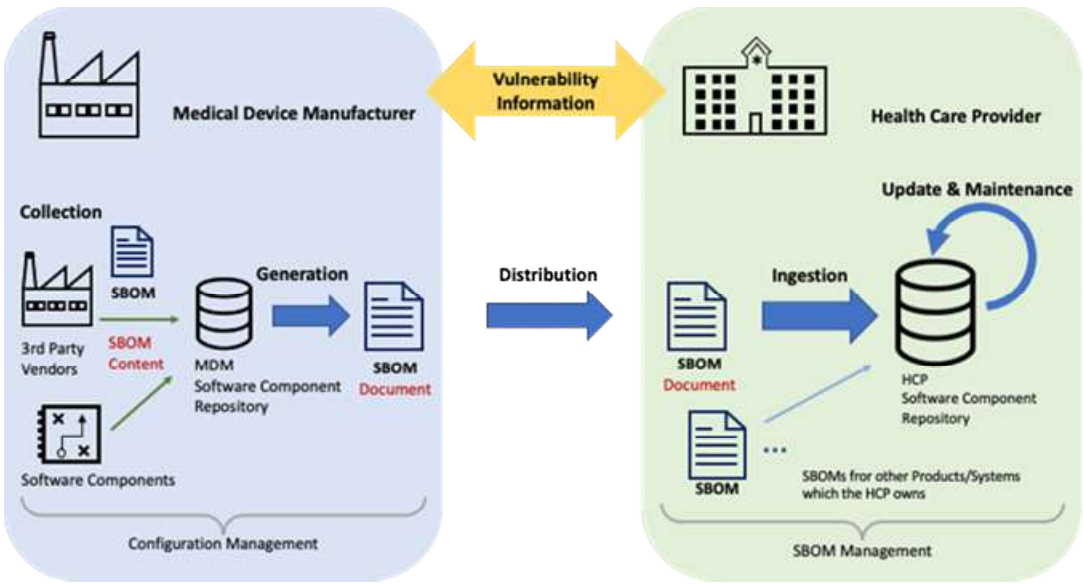
② 의료서비스제공자는 디지털의료기기에 대해 디지털의료기기제조업자등이 작성한 소프트웨어 구성요소 명세서를 구매 및 설치 이전에 확인하는 것을 고려할 수 있다.

③ 소프트웨어 구성요소 명세서 정보는 보호되어야 하며 소프트웨어 구성 요소 명세서의 생성, 저장, 송수신 등의 과정에서 데이터 보안을 고려할 수 있다.

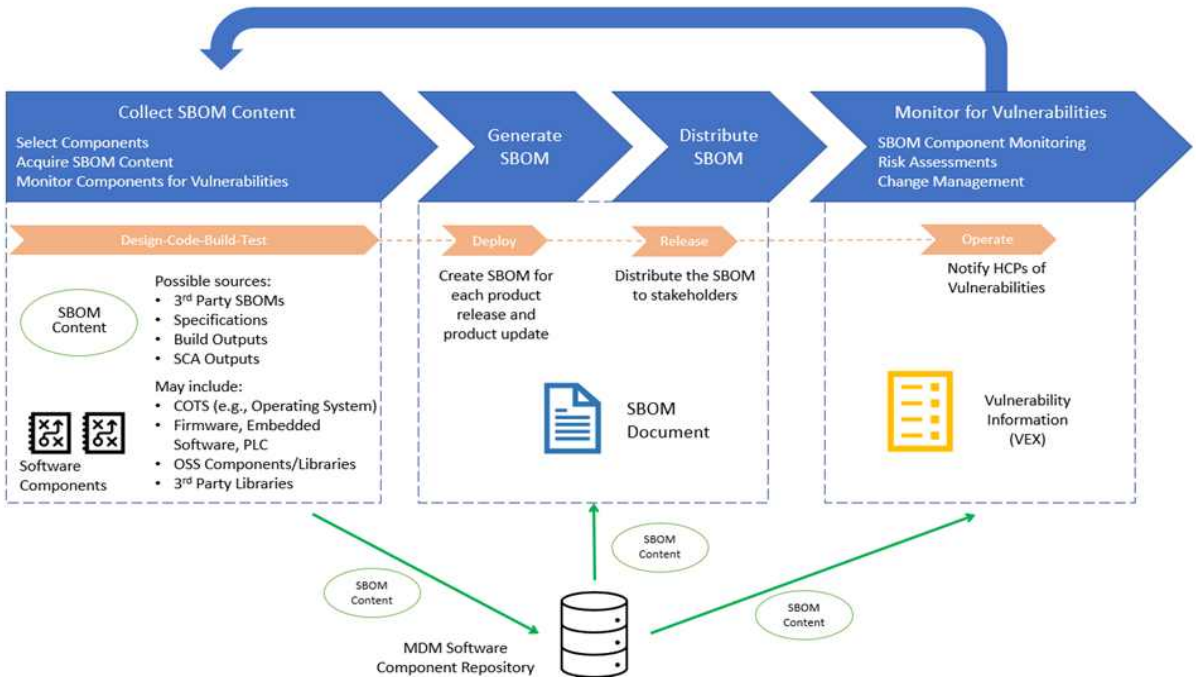
❑ 소프트웨어 구성요소 명세서 관리 활동

○ 디지털의료기기에 탑재되는 공개·상용 소프트웨어는 알려진 보안취약점이나 결함이 존재하지 않는 보안패치가 적용된 안전한 버전을 사용하여야 한다.

- 디지털의료기기에서 최신의 보안패치가 적용된 안전한 버전의 공개·상용 소프트웨어를 사용하기 위해 소프트웨어 구성요소 명세서를 활용할 수 있다.



< 의료기기 시장 내 SBOM 활용을 위한 프레임워크 (출처 : IMDRF, 2022.6.) >



< 소프트웨어 개발 수명 주기(SDLC, Software Development Life Cycle) 전반에 걸친 SBOM 관리 방안 (출처 : IMDRF, 2022.6) >

세부 내용 **SBOM**

√ 디지털의료기기의 안전한 버전의 공개·상용 소프트웨어 적용에 대한 증빙 자료로 소프트웨어 구성요소 명세서를 활용할 수 있음

· 적합성이 검증된 소프트웨어 구성요소 명세서 점검 도구를 이용하여 소프트웨어 구성요소 명세서를 생성하여야 함

- 소프트웨어 구성요소 명세서는 표준 형식(예 : SPDX, CyclonDX 등)으로 작성하도록 권고함

· 소프트웨어 구성요소 명세서를 통해 디지털의료기기 내 모든 소프트웨어 구성요소(예: 운영체제, 라이브러리, 오픈소스 등)에 대한 보안 취약점이 발견될 경우 이를 대응하기 위한 방안(패치, 교체 등)을 수행할 수 있음

· 소프트웨어 구성요소 명세서는 제품 개발 단계별로 정기적으로 업데이트되며, 주요 변경사항 발생 시 이를 반영하여 최신 상태로 유지해야 함

※ 소프트웨어 구성요소 명세서 생성 및 활용 방법은「SW공급망 보안 가이드라인」참고

보안 활동		SBOM
구분		설명
제16조 전체	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등의 개발자
	보안활동 수행 입력 (output)	**(기록)** - 소프트웨어 구성요소 명세서(SBOM) **(디지털의료기기)** - 소프트웨어 구성요소 명세서를 통해 알려진 보안취약점을 확인하고, 최신의 보안패치가 적용된 안전한 버전의 공개·상용 소프트웨어를 사용하여 디지털의료기기 개발

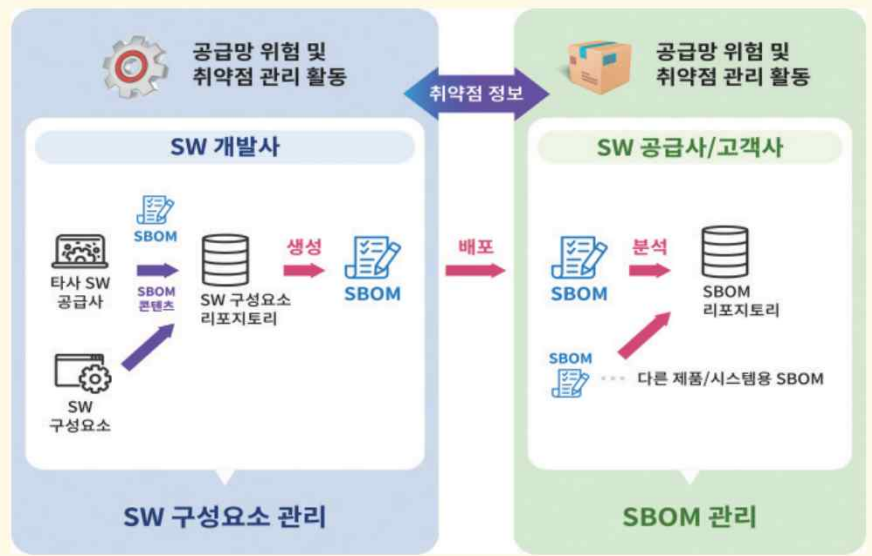
예시	SBOM 도구
√ Labrador SCA √ Synopsys Black Duck Software √ Sparrow Enterprise SCA	

○ 의료서비스제공자가 요구하는 경우, 소프트웨어 구성요소 명세서를 제공할 수 있다.

- 디지털의료기기 판매 시, 구매 및 설치 이전에 의료서비스제공자에게 제공하기 위한 소프트웨어 구성요소 명세서의 표준 형식, 명세서 정보 제공 절차, 구성요소 변경 시 업데이트 방안 등이 문서화하는 것을 고려할 수 있다.

예시 **SBOM 생성 및 배포**

√ 소프트웨어 구성요소 명세서를 생성하여 보안 취약점을 모니터링하고 취약성 정보를 알림



<출처>: SW공급망보안 가이드라인(2024.05)

○ 소프트웨어 구성요소 명세서의 생성, 저장, 송수신 전반적 과정에서 발생할 수 있는 보안 위험에 대응하기 위해 데이터 보안을 고려할 수 있다.

세부 내용 **SBOM 데이터 보안**

√ 소프트웨어 구성요소 명세서의 생성, 저장, 송수신 전반적 과정에서 발생할 수 있는 보안 위험에 대응하기 위해 다음과 같은 보안 조치를 마련할 수 있음

· 소프트웨어 구성요소 명세서를 암호화하여 보호

· 저장된 소프트웨어 구성요소 명세서에 대한 접근 권한 최소화하고 접근 통제를 수행하여 보호

· 소프트웨어 구성요소 명세서에 대한 접근 및 수정 이력에 대한 감사기록을 생성하고 감사기록을 관리

· 소프트웨어 구성요소 명세서 전송 시 신뢰된 암호통신 프로토콜(TLS 등)을 사용하여 기밀성·무결성을 보장

- 데이터 위변조를 방지하고 진위 여부를 검증하기 위한 해시값 또는 디지털 서명 등의 무결성 검증 절차를 마련할 수 있음
- 전송 구간에는 주기적인 업데이트 및 취약점 점검이 필요할 수 있음

제17조(침해행위 대응 계획 등)

① 디지털의료기기제조업자등은 디지털의료기기 자체 또는 제품을 사용하는 운영 환경을 고려하여 전자적 침해행위에 대응하기 위한 계획을 수립하여야 한다.

② 제1항의 대응 계획에는 다음 각 호의 사항이 포함되어야 한다.

1. 침해행위 신고 방안
2. 침해행위 조치 방안
3. 침해행위 식별, 분석, 평가 등 위험 관리 방안
4. 침해행위 대응팀 구성
5. 제품 사용의 연속성을 보장하기 위한 계획
6. 침해행위 대응을 위한 테스트 및 훈련 방안 등

③ 디지털의료기기제조업자등은 침해행위 발생에 대응하기 위해 대응 인력과 대응 훈련 방안을 마련하여야 한다.

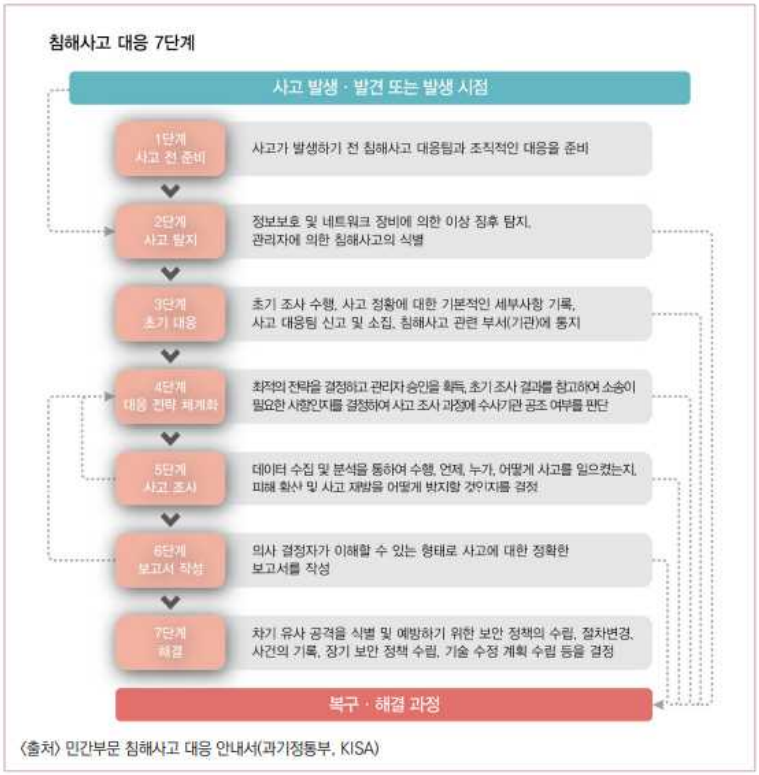
❑ 전자적 침해행위 대응 계획

○ 침해행위 발생 시 신속하고 효과적으로 대응할 수 있도록 계획을 수립하여야 한다.

보안 활동 **침해행위 대응 계획**

구분		설명
제17조 전체	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등
	보안활동 수행 결과 (output)	**(정책문서)** 전자적 침해행위 대응 계획서, 절차서 등 **(조직구성)** 침해행위 발생 시 대응 인력/팀 구성 **(기록)** 전자적 침해행위 대응 모의훈련 결과

예시 **침해사고 대응 7단계**



<출처>: 민간부문 침해사고 대응 안내서(과기정통부, KISA)

○ 침해행위 대응 계획에는 다음의 사항들이 포함되어야 한다.

- **(신고 방안)** 디지털의료기기제조업자등 내·외부를 고려하여 신고 경로와 체계를 정의하고 신고 기준을 수립하여 기준에 따라 신고 여부를 결정하여 보고 절차에 따라 신고를 수행하여야 한다.
- **(조치 방안)** 침해행위 감지 시 초기 대응 절차(예 : 시스템/네트워크 분리, 시스템 운영 중단 등)에 대해 정의하여야 하며, 복구하기 위한 조치(예 : 시스템 현재 또는 이전 버전으로의 복구, 침해 경로 차단 등)에 대해 정의하여야 한다.
- **(위험 관리 방안)** 침해행위 원인과 영향을 분석하기 위한 사고 식별 기준(예 : 네트워크 이상 트래픽 과다 발생, 불특정 다수의 로그인 시도, 인증 우회 시도, 비정상적인 질의 요청 등)을 정의하고 로그 분석, CVE, NVD 등 취약점 매칭, 공격 분석 도구 활용 등을 통한 분석 체계 구성, 위험 평가 기법, 사고 유형에 따른 대응 시나리오에 대해 정의되어야 한다.

- **(침해행위 대응팀 구성)** 보안 침해 대응을 위한 전담 담당자 구성, 구성원 별 역할 및 책임, 정기 교육 방안, 사고 대응 훈련 계획 수립, 필요 시 외부 전문가 또는 사고 대응 협력 기관/팀에 대한 체계를 정의하여야 한다.
- **(연속성 보장 계획)** 침해행위로 인한 장비 또는 시스템 이상 시, 대체 장비 또는 백업 시스템 가동 등을 통한 제품 사용의 연속성을 보장하기 위한 계획을 수립하여야 하며, 중요 데이터 백업 및 복구 절차에 대해서도 정의되어야 한다.
- **(테스트 및 훈련 방안)** 침해행위 대응 계획의 실효성 검증을 위한 테스트 및 모의 훈련 절차, 훈련 수행 이후 사후 평가 절차, 개선 조치 반영을 위한 피드백 체계 등이 정의되어야 한다.

예시 **침해사고 유형 및 위험 관리 방안/대응 시나리오**

침해사고 유형	설명	위험 관리 방안(예시)	대응 시나리오(예시)
DDoS 공격	시스템/서버 등에 대량의 트래픽 요청을 보내 시스템을 불능 상태로 만드는 공격	**(위험 식별)** 대량의 트래픽 요청 발생 → 시스템 이용 불가 **(위험 분석)** 의료기관 진료 지연, 사용자 불만, 진단 불가로 인한 환자 위험 발생 등 **(위험 평가)** 가용성 손상, 환자 서비스 차질로 인한 위험 수준 (상) **(위험 통제/완화)** 네트워크 분리, DDoS 대응 장비 운영, 서버 이중화, 트래픽 차단 등	① 탐지 1분당 1,000건 이상 요청 감지 ② 초기대응 방화벽, DDoS 대응 장비로 차단 네트워크 분리 등 ③ 복구 시스템 이중화 또는 보조 시스템 구동 ④ 사후 방안 공격 유형 분석 후 방화벽/DDoS 대응 장비에 공격 패턴 적용 등
무분별한 로그인 시도	관리자 또는 사용자 계정에 대해 자동화된 로그인 시도	**(위험 식별)** 다수의 로그인 실패 로그 확인 **(위험 분석)** 관리자 권한 탈취, 비인가자 접근으로 인한 데이터 유출 등 **(위험 평가)** 무결성 손상 우려 (상) **(위험 통제/완화)** 로그인 실패 횟수 제한(5회), 로그인 실패 대상 시스템 IP 차단 등	① 탐지 1분에 50회 이상 로그인 실패 기록 확인 ② 초기대응 계정 잠금, IP 차단 ③ 사용자 알림 계정 보안 위험 알림 및 재인증 유도 ④ 사후 방안 비밀번호 정책 강화, 주기적 비밀번호 변경 정책 적용

예시 **침해사고 유형 및 위험 관리 방안/대응 시나리오**

침해사고 유형	설명	위험 관리 방안(예시)	대응 시나리오(예시)
악성코드 발견	파일 업로드/스크립트 등에 의한 시스템 내 악성코드 유포	**(위험 식별)** 안티 바이러스 소프트웨어 등을 통한 확인, 시스템 자원을 과도하게 소모하는 프로세스 확인 등 **(위험 분석)** 환자 데이터 유출/조작, 시스템 전체/일부 불능 등 **(위험 평가)** 무결성 손상 우려 (상) **(위험 통제/완화)** 파일 확장자 제한, 스크립트 실행 차단 등	① 탐지 스캔 기능을 통한 악성코드 확인 ② 초기대응 해당 프로세스 격리, 실행 차단 ③ 조사 바이러스, 악성코드 패턴 분석, 악성코드 신고 ④ 사후 방안 보안 업데이트 배포
비정상적 질의 요청	반복된 질의로 인한 시스템 리소스 소진 또는 학습 공격 발생	**(위험 식별)** 다수의 반복된 질의, 유사 질의 확인, 시스템 리소스 소진 파악 **(위험 분석)** 부정확한 진단 유도, 의사결정 오류 등 **(위험 평가)** 신뢰성 손상, 환자 위해 가능성 우려 (상) **(위험 통제/완화)** 질의량 제한(초당, 동일 /유사 질의 당 제한 등) 조치	① 탐지 동일 계정 또는 불특 계정에서의 동일/유사 질의 반복 ② 초기대응 해당 세션, 질의 차단 ③ 조치 질의 임시 차단 ④ 사후 방안 질의 로그 분석, 질의량 제한
…	…	…	…

예시 **침해행위 대응 계획서**

· 전자적 침해행위 대응 절차서(계획서)
· 전자적 침해행위 보고서 및 결과보고서 양식

구분	내용
침해행위 식별, 분석, 평가 등 위험 관리 방안	· 침해사고의 정의 및 범위(해킹 사고, 서비스거부공격, 개인정보 유출 사고 등) · 침해사고 유형 및 중요도 · 위험 평가 기법 적용 모델, 침해사고 유형별 분석 및 대응 시나리오 포함
침해해위 신고 방안	· 침해사고 선포 절차 및 방법 · 비상 연락망 등의 연락 체계 · 침해사고 탐지, 보고 절차 및 승인 체계 · 침해사고 발생 시 기록, 보고 절차 · 침해사고 신고 및 통지 절차(식품의약품안전처 등 관계기관, 의료서비스 제공자 및 사용자 등)
침해행위 조사 방안	· 침해사고 탐지 시 초기 대응 절차 · 침해사고 보고서 작성
침해행위 대응팀 구성	· 침해사고 대응 조직이 구성, 책임 및 역할 · 필요 시 외부 전문가 또는 협력 기관 정의
제품 사용의 연속성을 보장하기 위한 계획	· 제품의 가용성과 연속성 확보를 위한 전략 · 데이터 백업 및 복구 절차 정의 · 대체 제품 또는 서비스 제공 안내 절차
침해행위 대응을 위한 테스트 및 훈련 방안 등	· 침해사고 대응 및 복구 모의 훈련, 훈련 시나리오

❍ 침해행위 발생에 대응하기 위해 대응 인력과 대응 훈련 방안을 마련하여야 한다.

세부 내용 **침해행위 대응 모의 훈련**

√ 침해행위 대응 계획에 따라 실효성 검증을 위한 모의 훈련을 실시하여야 함
· 최신 침해사고 사례, 해킹 동향, 기기 및 운영환경 특성 등을 반영하여 현실적이고 실질적인 모의훈련 시나리오를 마련해야 함
· 모의훈련 시행 후 결과보고서를 작성하고 내부에 보고해야 함
· 훈련 이후 사후 평가를 수행하고, 훈련 결과를 반영하여 대응체계를 개선해야 함

예시 **침해행위 대응 모의 훈련 계획**

√ 훈련 대상자 선정
· 침해사고 대응에 직접 관여하거나 연관된 업무를 수행하는 자는 훈련에 대한 교육을 이수하여야 하며, 훈련 대상자(는 내부 직원 뿐만 아니라 기술지원, 협력사 등 외부 인력까지 포함함
√ 훈련 계획 수립
· 디지털의료기기제조업자등은 정기적인 일정(예: 연 1회)을 정하여 정기 훈련 계획을 수립하여야 하며 훈련 대상자, 훈련 과정명, 훈련 시기, 운영 방식 등의 내용을 포함하여 계획을 수립하고 이를 문서화
√ 훈련 내용 정의
· 훈련 내용은 외부 전문 보안 강의(예: 사이버보안 침해 대응 교육, 취약점 분석 교육 등) 또는 침해사고에 대한 대응 방법, 재발 방지 절차 등의 내용을 포함하여 자체적으로 훈련 과정 개설
√ 훈련 관리
· 훈련 이후 훈련 대상자의 이수 여부를 확인하고 이수 기록(예: 훈련 이수자, 일시, 과정, 이수 결과 등)을 기록 및 보관

예시 **침해행위 대응 모의 훈련 결과(기록)**

· 전자적 침해 대응 조직도 및 비상 연락망
· 전자적 침해행위 대응 모의훈련 계획서
· 전자적 침해행위 대응 모의훈련 결과서

제18조(침해행위 신고)

① 디지털의료기기제조업자등은 디지털의료기기 자체 또는 그 운영 환경에서 전자적 침해행위가 발생한 것을 인지한 경우 이를 즉각 식품의약품안전처장과 의료서비스제공자 및 제품을 이용하는 사용자에게 알려야 한다.

② 의료서비스제공자는 디지털의료기기 자체 또는 그 운영 환경에서 전자적 침해행위가 발생하는 경우 이를 즉각 식품의약품안전처장과 디지털의료기기 제조업자등에게 알릴 수 있다.

❑ 전자적 침해행위 발생으로 인한 신고

○ 디지털의료기기제조업자등은 전자적 침해행위를 인지한 즉시 사전에 정의된 절차에 따라 식품의약품안전처장, 의료서비스제공자 및 사용자에게 이를 신속히 통보하여야 한다.

세부 내용 **침해행위 신고**

√ 전자적 침해행위 발생을 인지한 경우 법적 통지 및 신고 의무를 준수해야 함

√ 디지털의료기기제조업자등은 전자적 침해행위 발생을 인지한 경우 정의된 대응 절차에 따라 신속하게 보고해야 함

· 인지한 때부터 24시간 이내(권고) 식품의약품안전처장에게 다음의 사항을 신고해야 함

1. 침해사고 발생일시, 원인 및 피해내용
2. 침해사고에 대한 조치사항 등 대응 현황
3. 침해사고 대응 업무를 담당하는 부서 및 연락처

· 신고한 후 전자적 침해행위가 추가로 확인되는 사실이 있는 경우에는 확인한 때부터 24시간 이내(권고) 신고해야 함

· 신고 양식 예시 등을 참고하여 자체 신고 양식을 작성, 침해행위 발생 인지 시 식품의약품안전처로 신고해야함.

· 의료서비스제공자 및 제품을 이용하는 사용자에게도 통지해야 함

√ 식품의약품안전처의 요구에 따라 통보 내용의 보완, 추가 정보 제공, 후속 조치 계획 제출 등을 수행할 수 있어야 함

보안 활동	침해행위 신고	
구분		**설명**
제18조 전체	보안활동 영역	의료서비스제공자 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등, 의료서비스제공자, 사용자
	보안활동 수행 입력 (input)	**(정책문서)** - 전자적 침해행위 대응 계획서, 절차서 등 **(조직구성)** - 침해행위 발생 시 대응 인력/팀 구성 **(사용자 매뉴얼 또는 홈페이지)** - 침해사고 발생 시 디지털의료기기제조업자등의 담당부서 연락처 등 신고 방법 명시
	보안활동 수행 결과 (output)	**(기록)** - 침해사고 발생을 인지한 시점에서의 내부 보고서 - 침해사고 발생을 인지한 시점에서의 식품의약품안전처 신고 내역 - 침해사고 발생을 인지한 시점에서의 의료서비스제공자 및 제품을 이용하는 사용자 통보 내역 - 개인정보 유출 신고서 등

예시 **침해행위 신고 양식**

* 필수항목

구 분		내 용
기업정보*		– 기업명 :
		– 사업자번호 :
		– 업종 :
		– 규모 : □ 대기업 □ 중견기업 □ 중소기업 □ 비영리 □ 기타
		– 회사주소 :
신고자 정보*		– 이름(소속부서) :
		– 메일 :
		– 연락처 : *※ 항시 연락 가능 번호 기재 요망*
침해 행위 현황	제목*	
	발생시간*	□ 00년 00월 00일 00시 00분 □ 확인불가
	인지시점*	□ 00년 00월 00일 00시 00분
	침해내용 (원인 등)*	*(자유롭게 작성)* *※ 예시 : 직원 사칭메일 발송, 해킹경유지로 악용, 기업서버에서 특정 포트로 비인가된 접근 시도*
	침해사실 인지 전 이상징후	*※ 예시 : 웹페이지 접속 불가, 피해 장비 성능 저하, 모름 등*
	침해 IP*	□ 000.000.000.000 □ 확인불가 □ 해당없음
	침해 도메인*	□ www.xxx.co.kr □ 확인불가 □ 해당없음
	서버 물리적 위치*	*※ 예시 : 서울특별시 송파구 OO IDC, 전라남도 나주시 등 또는 클라우드(AWS 등)*
	※ 관련 로그, 악성코드 등 침해사고 관련 파일을 신고서와 함께 보내주십시오. ※ 대응현황 자료, 내부보고자료, 증상(화면 캡처 등)	
대응 현황	조치사항*	① *(자유롭게 작성)* ② *※ 예시 : 피해 대상 네트워크 분리, 복구업체를 통한 복구시도 중*

○ 의료서비스제공자는 전자적 침해행위 발생을 인지한 경우 식품의약품안전처장과 디지털의료기기제조업자등에게 알릴 수 있다.

- 의료서비스제공자가 침해사고를 신고할 수 있도록 사용자 매뉴얼 또는 홈페이지에 디지털의료기기제조업자등의 담당부서 연락처 등 신고 방법을 명시하여야 한다.
- 통보는 의료기관 내 사전에 마련된 보안 사고 대응 절차 또는 정보보안 지침에 따라 수행될 수 있다.

예시 **침해행위 신고 방법**

√ 디지털의료기기제조업자등은 의료서비스 제공자가 침해행위 발생 인지시 신고할 수 있도록 홈페이지 등에 담당 부서 연락처 등 신고 방법을 명시
√ 홈페이지에 침해사고 발생 시 디지털의료기기제조업자등의 담당 부서 연락처 등 신고 방법을 명시
√ 전자적 침해행위의 파급효과로 환자의 생명 또는 안전에 영향을 미칠 수 있다고 판단되는 경우, 식품의약품안전처로 신고해야함

제19조(침해행위 발생 이후의 조치)

① 디지털의료기기제조업자등은 전자적 침해행위가 발생한 원인과 대응 방안을 수립된 계획에 따라 조치해야 한다.

② 디지털의료기기제조업자등은 전자적 침해행위의 원인을 분석하고 재발 방지 대책을 수립하고 식품의약품안전처장과 의료서비스제공자에게 이를 알려야 한다.

③ 의료서비스제공자는 전자적 침해행위의 원인 분석 등을 위해 디지털의료기기제조업자등과 협조할 수 있다.

❑ 전자적 침해행위 발생 이후 조치

○ 제품 자체 또는 그 운영 환경에서의 전자적 침해행위가 발생했을 경우 이에 대한 인지, 신고, 조치와 같은 대응 방안을 마련하고, 이 계획에 따라 조치하여야 한다.

보안 활동 **침해사고 대응**

구분		설명
제19조 전체	보안활동 영역	의료서비스제공자 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등, 의료서비스제공자
	보안활동 수행 입력 (input)	**(정책문서)** - 전자적 침해행위 대응 계획서 **(조직구성)** - 침해행위 발생 시 대응 인력
	보안활동 수행 결과 (output)	**(기록)** - 침해사고 보고서 - 침해사고 결과보고서

- **(인지 단계)** 전자적 침해행위의 인지는 전체 대응의 속도와 정확성을 좌우할 수 있어, 인지 단계에서는 전자적 침해행위를 신속히 감지하여야 한다.

세부 내용 **침해사고 대응 - 인지 단계**

√ 디지털의료기기제조업자등은 의료서비스제공자 및 식품의약품안전처로부터 전자적 침해행위 발생을 통보 받은 경우 정의된 대응 절차에 따라 신속하게 대응해야 함

√ 침해사고 및 개인정보 유출의 징후 또는 발생을 인지한 경우 정의된 침해사고 대응 절차에 따라 신속하게 대응해야 함

· 의료서비스제공자로부터 협조를 받아 제17조(침해행위 대응 계획 등)의 대응 절차에 따라 대응하여야 함

· 침해사고를 인지한 후 초기 대응 및 증거를 보존하도록 조치하여야 함

· 침해사고 보고서를 작성하여 내부에 보고하여야 함

예시 **침해사고 대응 - 인지 단계**

√ 초기 대응 및 증거 보존 방법

· 침해가 의심되는 정보시스템의 접속 권한 삭제·변경 또는 접속차단 조치

· 네트워크, 방화벽 등 대내외 시스템 보안점검 및 취약점 보완 조치

· 사고 조사에 필요한 외부의 접속기록 등 증거 보존 조치

· 로그 분석 등을 통한 개인정보 및 중요정보 유출 여부 확인 등

√ 침해사고 보고서의 포함 내용

· 침해사고 발생일시

· 보고자와 보고일시

· 사고 내용(발견 사항, 피해 내용 등)

· 사고대응 경과 내용

· 사고대응까지의 소요시간 등

- **(신고 단계)** 내부 인지 이후 식품의약품안전처, 사용자 등 관계자에게 정보를 신속하게 전달함으로써 침해 확산을 방지하고 공동 대응 기반을 마련할 수 있다.

※ 제18조(침해행위 신고) 내용 참조

- **(조치 단계)** 신고 후에는 사고 원인 분석, 기능 복구, 보안 강화 등의 조치를 통해 기기의 신뢰성을 회복하고, 유사 사고 재발을 방지하는 것이 중요하다.

세부 내용	침해사고 대응 - 조치 단계

√ 침해사고가 처리되고 종결된 후 이에 대한 사고 원인에 대한 분석을 수행하고 유사 사고가 재발하지 않도록 대책을 수립하여야 함

· 침해사고 정보와 발견된 취약점 및 원인, 조치방안 등을 포함한 침해사고 결과보고서를 작성하여야 함

· 침해사고 분석을 통하여 얻은 정보를 활용하여 유사 사고가 재발하지 않도록 대책을 수립하고 필요한 경우 대응 절차를 변경하여야 함

· 식품의약품안전처와 의료서비스제공자에게 원인 분석 및 재발 방지 대책 등이 포함된 침해사고 결과보고서를 제공해야 함

예시	침해사고 대응 - 조치 단계

√ 침해사고 결과 보고서

· 침해사고 정보

· 발견된 취약점 및 원인

· 조치 방안

√ 침해사고 결과보고서 제공 이력

❍ 디지털의료기기제조업자등은 침해행위의 원인 분석과 재발 방지 대책(예: 보안 패치, 설계 개선, 대응절차 마련 등)을 수립하여, 식품의약품안전처장과 의료서비스제공자에게 알려야 한다. 이는 향후 유사 사고 예방 및 안전성 강화를 위한 근거로 활용될 수 있다.

❍ 의료서비스제공자는 전자적 침해행위 발생 이후 원인 분석 및 향후 대응체계 강화를 위하여 디지털의료기기제조업자등과의 긴밀한 협조를 통해 안전성 확보, 재발 방지 및 사후관리 조치 등을 수행할 수 있다.

제20조(취약점 감시)

① 디지털의료기기제조업자등은 디지털의료기기의 취약점 감시를 위해 정기적인 보안 모니터링, 로그 분석 등의 감시 활동을 계획하고 감시, 공개 및 조치 절차에 대해 문서화하여 보관하여야 한다.

② 의료서비스제공자는 디지털의료기기에서 취약점을 확인할 경우 즉시 디지털의료기기제조업자등에게 알릴 수 있다.

③ 디지털의료기기제조업자등은 디지털의료기기에서 취약점을 확인할 경우 즉시 식품의약품안전처장과 의료서비스제공자에게 알릴 수 있다.

④ 디지털의료기기제조업자등은 제3항의 취약점을 식품의약품안전처장에게 알릴 경우 취약점에 대한 상세 내용, 심각도, 영향, 대응 방안 등을 포함하여야 한다.

⑤ 의료서비스제공자는 보고된 취약점에 대한 분석 및 해결을 위해 디지털의료기기제조업자등이 지원을 요청할 경우 이에 협조할 수 있다.

❑ 취약점 감시 활동

○ 디지털의료기기제조업자등은 디지털의료기기에 대한 보안 취약점을 체계적으로 감시하고 사전에 식별할 수 있도록 정기적인 보안 감시 활동 계획을 수립하여야 한다.

세부 내용	취약점 감시

√ 취약점 감시, 분석, 보고 및 대응을 포함하는 통합적인 관리 체계를 정의하고 이를 문서화하여야 함

※ 취약점(Vulnerability): 하나 이상의 위협에 의해 악용될 수 있는 자산 또는 통제 약점 (ISO/IEC 27000:2018)

- 취약점 감시 활동에 대한 계획을 수립하여야 함
- 취약점 발견 시 취약점 발견자로부터 정보를 수집하고, 완화 및 개선 전략을 개발하는 절차를 수립하여야 함
- 취약점의 존재와 완화 또는 개선 접근 방식을 이해관계자(식품의약품안전처, 의료서비스제공자 등)에게 공개하기 위한 공식화된 절차를 수립하여야 함

보안 활동	취약점 감시	
구분		설명
제20조 전체	보안활동 영역	디지털의료기기 제조 영역 및 의료서비스제공자 영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등
	보안활동 수행 결과 (output)	**(정책문서)** - 취약점 감시 절차 **(기록)** - 취약점 분석 결과서

- **(감시 체계 구성)** 감시 활동은 디지털의료기기에서 발생할 수 있는 보안 이상 징후, 취약점 발생 가능성 등을 식별하기 위한 체계로서 감시 주기(월 1회, 분기별 1회), 감시 대상, 감시 방법(로그 분석) 등을 고려하여 계획하여야 한다.
- **(감시 체계 구축)** 취약점 감시, 식별, 대응 및 공개에 이르는 전 과정을 관리하기 위한 체계를 구축하고 내부 담당 디지털의료기기제조업자등, 책임자, 관련 도구 및 절차 등이 포함되어야 한다.
- **(분석 활동)** 디지털의료기기에서 수집된 보안 관련 로그(인증 로그, 접근 로그, 시스템 이벤트 로그 등)를 정기적으로 분석하여 의심 이벤트나 위협 징후를 조기에 식별할 수 있어야 하며 로그 분석 절차를 문서화하여야 한다.

❍ 알려진 보안취약점 공개영역 조사를 통해 디지털의료기기의 보안취약점을 확인하여야 한다.

세부 내용	보안취약점 공개영역
√ 알려진 보안취약점 공개영역 조사를 통해 디지털의료기기에 존재하는 보안취약점을 확인하여야 함 · 공개영역 조사를 통해 디지털의료기기 유형, 사용 중인 프로토콜, 라이브러리, 오픈소스 또는 제3자 제공 소프트웨어, 운영체제에 해당되는 보안취약점이 존재하는지 확인하여야 함	

예시 **보안취약점 공개영역**

보안취약점 공개영역	내용
https://www.fda.gov	의료기기에 대한 사이버보안 취약점 공개
https://owasp.org	웹, Mobile App 관련 취약점 공개
http://www.cve.mitre.org	미국 NIST 공개 취약성 DB
http://cwe.mitre.org	미국 NIST 공개 취약성 DB
http://www.securityfocus.com	취약점 공개 사이트
http://www.exploti-db.com	취약점 공개 사이트
http://secunia.com	취약점 공개 사이트
http://www.packetstorm.com	취약점 공개 사이트
http://www.krcert.or.kr	CERT 사이트(한국인터넷진흥원)
http://www.kiisc.or.kr	한국정보보호학회 학회지, 논문지
http://cseric.or.kr	국가지정 컴퓨터 연구정보센터 논문지
제3자 제공 소프트웨어 정보	(예시) openSSL, openSSH 등 홈페이지

○ 보안취약점 점검 도구를 통해 디지털의료기기의 보안취약점을 확인할 수 있다.

세부 내용 **보안취약점 점검 도구**

√ 보안취약점 점검 도구를 통해 기기에 존재하는 보안취약점을 확인할 수 있음

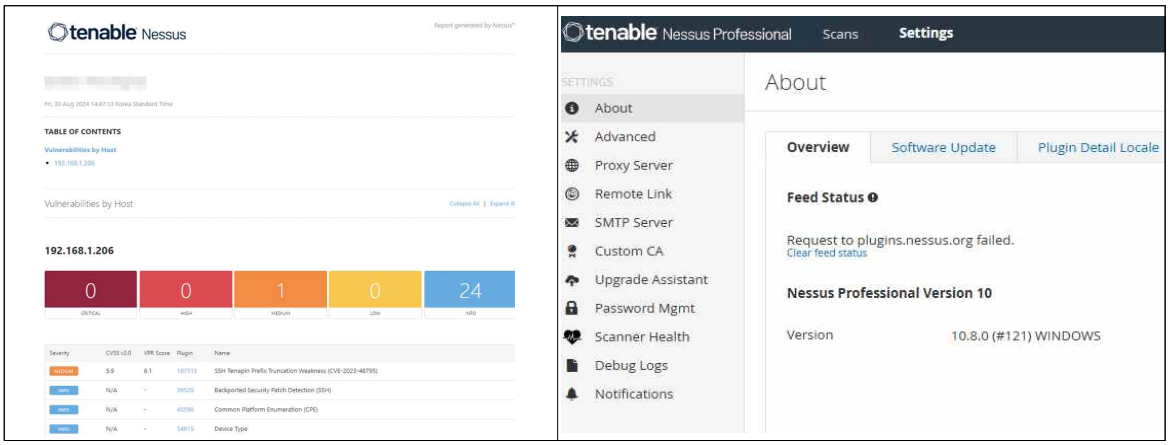
· 신뢰할 수 있는 상용 또는 공개용 보안취약점 점검 도구를 이용하여 기기에 보안취약점이 존재하는지 확인할 수 있음

구분	보안취약점 점검 도구	점검 대상
시스템 및 네트워크 취약점 점검 도구	Nmap, nessus, Nexpose 등	운영체제, WAS, DB등 CCE, CVE 점검
웹 취약점 점검 도구	OWASPZAP, Nikto, acunetix, HCL AppScan등	HTML, JavaScript 등의 언어로 구현된 웹
퍼징도구	Peach Fuzzer, AFL, wfuzz,OSS-Fuzz 등	파일 포맷, 웹 서비스/API, 네트워크 프로토콜 등
소스코드 보안약점점검 도구	Sparrow, Fortify, CodeRay등	JAVA, C/C++, Python, JSP, HTML5 등 소스코드

예시 **보안취약점 점검 도구**

√ 시스템 취약점 점검 도구

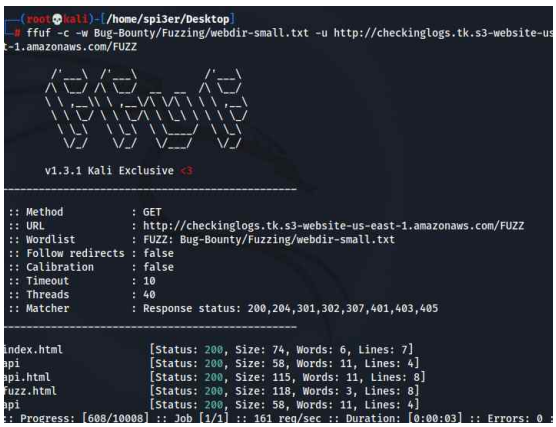
· 소프트웨어 결함, 패치 누락, 악성코드, 잘못된 설정 등을 탐지



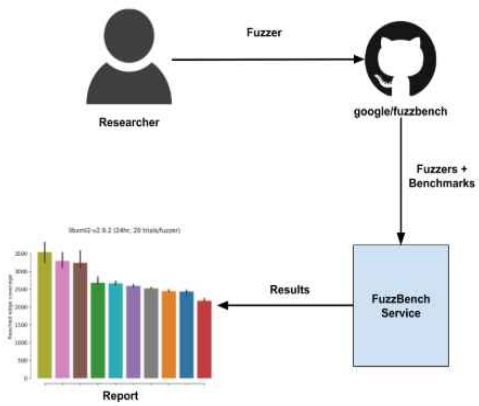
<출처>: Tenable 홈페이지(Nessus)

√ 퍼징 도구

· 인터페이스, 프로토콜, 파일 포맷 등 무작위 입력값을 통해 소프트웨어 결함 분석 및 탐지



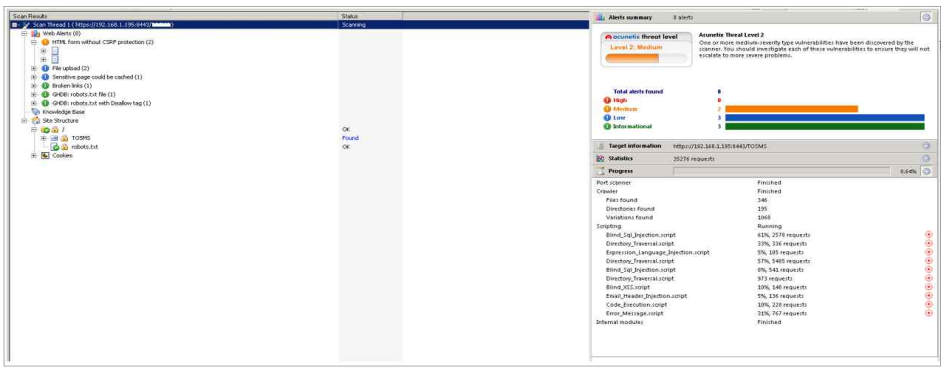
<출처>: Github(MIT License) - FFuF



<출처>: Github(Google) - FuzzBench

√ 웹 취약점 점검 도구

· SQL 인젝션, 크로스사이트 스크립팅(XSS, Cross-site scripting), 서버측 요청 위조(SSRF, Server-side request forgery) 등 웹 취약점을 탐지



<출처>: Acunetix

○ 디지털의료기기제조업자등은 제품 출시 이후에 발생할 수 있는 취약점에 대한 모니터링 방안과 대응을 위한 절차 또는 기록 등의 절차를 마련하여 취약점 감시 활동을 수행하여야 한다.

- 취약점 감시 방안, 시판 후 위험 관리 절차 제시, 취약점 발생 시 패치 제공 및 사용자 알림 등 대응 절차 마련 등을 마련하여야 한다.

○ 취약점이 식별된 경우, 해당 취약점에 대한 조치와 공개 여부를 포함하여 대응 전반에 대한 절차를 사전에 정의하고 조치 이력 및 결과를 체계적으로 기록·관리할 수 있는 체계를 수립하고 이를 보관하여야 한다.

- **(취약점 조치 기록 절차 수립)** 보안 취약점 조치 기록의 경우 다음의 사항들을 포함하려 절차를 수립하여야 한다.

< 취약점 조치 기록에 포함되어야 하는 항목>
- 취약점 상세 내용 및 기술적 특성
- 취약점 발생 위치(제품 구성요소, 라이브러리 등) 및 영향 범위
- 심각도 평가 결과 및 위험 분석 내용
- 조치 방안(보안 패치, 업데이트, 구성 변경, 임시 조치 등)
- 조치 일자, 소프트웨어 적용 버전, 검증 결과
- 내부 승임 및 외부 보고 여부
- 재발 방지 조치 이행 여부

- **(공개 및 통지 기준 수립)** 확인된 취약점에 대해 공개 여부 판단 기준을 사전에 정의하고 이를 기반으로 공개 절차를 수립하여야 한다.

- **(취약점 공개 절차 정의)** 취약점 공개가 결정된 경우, 공개 시점, 공개 채널, 공개 항목 등을 포함하여 절차를 문서화하여야 한다.

- **(기술적 조치 실행 및 관리)** 식별된 취약점에 대해서는 보안 패치, 소프트웨어/펌웨어 업데이트, 구성 변경 등 조치 방안을 명확히 수립하여야 하며 즉각적인 조치가 어려울 경우 위험 완화를 위한 임시 조치를 고려하여야 한다.

- **(사후 문서화 및 추적성 확보)** 취약점 조치 및 공개 이후에도 해당 이력이 추적할 수 있도록 기록되어야 하며 기록 항목에는 보고 시점, 대응 일정, 내부 검토 및 외부 통지 여부 등을 포함할 수 있다.

○ 의료서비스제공자가 기기 사용 중 취약점을 식별할 경우, 관련 정보(예: 증상, 발생 조건, 기기 환경 등)를 디지털의료기기제조업자등에게 알릴 수 있다.

- 의료서비스제공자는 사전 정의된 대응 프로세스에 따라 취약점 대응이 구조화될 수 있도록 지원하는 역할을 한다.

세부 내용	의료서비스제공자 취약점 감시
√ 의료서비스제공자는 디지털의료기기에서 취약점을 확인한 경우 즉시 디지털의료기기제조업자등에게 알릴 수 있음 · 의료서비스제공자는 보고된 취약점에 대한 분석 및 해결을 위해 디지털의료기기제조업자등이 지원을 요청할 경우 이에 협조할 수 있음	

- 분석 및 해결 과정에서 필요한 로그, 사용 이력, 환경 정보 등은 의료서비스제공자 보유하고 있으므로, 사전 정의된 협조 절차에 따라 관련 데이터를 디지털의료기기제조업자등에게 제공할 수 있다.

○ 디지털의료기기제조업자등은 디지털의료기기 취약점이 환자의 생명 또는 안전에 영향을 미칠 수 있다고 판단될 경우 즉시 식품의약품안전처와 의료서비스제공자에게 알릴 수 있다.

- 취약점 보고 시에는 사전에 정의된 항목(예: 취약점 설명, 심각도 등급, 영향 범위, 대응 계획 등)을 포함해야 하며, 이 보고 내용은 조치 이력과 함께 문서화하여야 한다.
- 이러한 보고는 식품의약품안전처가 해당 취약점에 대해 적정한 조치 여부를 판단하고, 유사 사례 예방에 활용할 수 있도록 한다.

세부 내용

√ 디지털의료기기제조업자등은 디지털의료기기에서 취약점을 확인한 경우 즉시 식품의약품안전처장과 의료서비스제공자에게 알릴 수 있음

· 의료서비스제공자로부터 협조를 받아 취약점을 분석하여 취약점 상세 내용, 심각도, 영향, 대응 방안 등을 취약점 분석 결과서로 작성하여야 함

· 식품의약품안전처와 의료서비스제공자에게 취약점 분석 결과서를 제공할 수 있음

제21조(취약점 공개)

① 디지털의료기기제조업자등은 제20조제3항의 취약점을 확인할 경우 이를 홈페이지 등에 공개할 수 있다.

② 디지털의료기기제조업자등은 제1항의 취약점 공개 시 보고된 취약점에 대해 상세 내용, 영향, 대응 방안 등을 포함한 자료를 준비하여 홈페이지 등에 공개할 수 있다.

③ 디지털의료기기제조업자등은 취약점에 대해 해결 여부와 심각도 등을 고려하여 공개 시점을 늦출 필요가 있다고 판단될 경우 식품의약품안전처장과 협의를 통해 그 공개 시점을 정할 수 있다.

❑ 보고된 취약점 공개에 관한 사항

○ 취약점 공개는 자사 홈페이지 또는 외부 취약점 공유 포털, 이메일 등 적절한 채널을 통해 공개할 수 있다.

보안 활동		**취약점 공개**
구분		**설명**
제21조 전체	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등
	보안활동 수행 결과 (output)	**(취약점 공개)** 자사 홈페이지, 외부 취약점 공유 포털, 이메일 등 공개 채널을 이용하여 취약점 공개

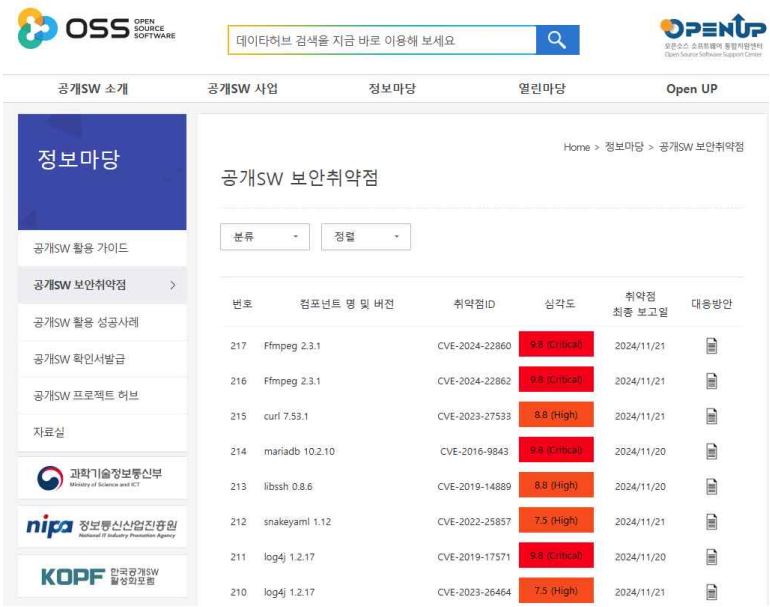
○ 감시 활동을 통해 식별된 취약점에 대해 다음과 같은 항목들을 포함하여 홈페이지 등과 같은 적절한 채널을 통해 공개가 이루어질 수 있다.

- 취약점 상세 설명, 심각도, 영향 분석 결과
- 취약점 식별 일자 및 경로
- 조치 방안(패치, 업데이트, 임시 조치 등), 적용 일정 및 버전
- 대응 결과 및 검증 내역
- 관련 이해관계자 보고/통지 여부

○ 취약점 공개 여부는 심각도, 위험성, 영향 범위 등을 토대로 환자의 생명 또는 안전에 영향을 미칠 수 있는지를 고려하여 판단되어야 하며 공개 시점(예: 패치 후 등), 공개 대상, 예외 조건 등을 포함한 공개 절차를 수립하여 공개 여부를 정할 수 있다. 만약 공개 시점을 연기해야 하는 경우에는 식품의약품안전처 등과 협의를 통해 그 공개 시점을 늦출 수 있다.

예시 **홈페이지 취약점 공개 예시**

√ 오픈소스 소프트웨어 통합지원센터(OpenUP) 공개SW 보안취약점 페이지



제22조(취약점 조치)

① 디지털의료기기제조업자등은 보고된 취약점을 해결하기 위한 패치, 업데이트 등의 조치 방안을 마련하여야 한다.

② 디지털의료기기제조업자등 및 의료서비스제공자는 취약점 조치 이후에도 지속적인 모니터링을 통해 취약점이 발생되지 않는지 확인하여야 한다.

❑ 보고된 취약점 해결을 위한 방안 마련

○ 디지털의료기기제조업자등은 보고된 취약점을 해결하기 위한 조치 방안을 마련하여야 한다.

세부 내용	취약점 조치

√ 제20조(취약점 감시)를 통해 기기에 존재하는 보안취약점을 확인하여 제거 등의 조치를 수행하여야 함
- 디지털의료기기 및 그 운영 환경에 해당되는 보안취약점을 제거하여야 함
- 보고된 취약점에 대한 대응으로 기기의 지속적인 안전성 및 성능을 유지하기 위해 소프트웨어를 업데이트하는 방법 또는 기타 개선 조치를 수행하여야 함

√ 관리 기준에 따라 제품 패치 또는 모듈, 컴포넌트 등의 일부 패치 방안을 마련하고 3rd Party, 오픈소스 등의 자사 제품이 아닐 경우 그에 따른 별도의 패치 방안을 강구하여야 함

√ 보안취약점이 있는 구버전의 소프트웨어로 롤백(rollback)하는 기능은 지원하지 않아야 함

√ 디지털의료기기제조업자등은 취약점 조치 준비가 완료된 경우 이를 충분히 테스트할 수 있어야 하며 관련 증적(취약점 조치 결과서)을 보유하여야 함

보안 활동		취약점 조치
구분		설명
제22조 전체	보안활동 영역	디지털의료기기제조영역에서 보안활동이 수행됨
	보안활동 주체	디지털의료기기제조업자등
	보안활동 수행 결과 (output)	**(디지털의료기기)** 보고된 취약점을 해결하기 위한 패치, 업데이트 **(기록)** 취약점 조치 결과서

< 취약점 보고 및 해결을 위한 기한의 권고>

Postmarket Management of Cybersecurity in Medical Devices Guidance(FDA, 2016)에서는 취약점을 인지한 경우, 가능한 빨리, 늦어도 30일 이내에 고객과 사용자 커뮤니티에 소통하여야 함을 명시하고 있으며, 취약점을 인지한 후 늦어도 60일 이내에 취약점을 수정하고 변경 사항을 검증하고 잔여 위험을 허용 가능한 수준으로 낮추는 배포 가능한 수정본을 배포하여야 함을 명시하고 있음

다만, 취약점을 늦어도 60일 이내에 수정본을 배포하는 것은 현실적인 어려움이 있기 때문에 디지털의료기기제조업자등에서 정하는 일자에 맞춰 대응하는 것을 권고함

붙임 1 디지털의료기기 전자적 침해행위 보안지침 절차서 샘플

전자적 침해행위 보안지침 절차서

본 문서는 주식회사 ○○○○○의 대외비이므로 담당자가 공식적인 허가 없이 제3자에게 복사하여 주거나 내용을 공개하는 것을 금지합니다.

문서번호 : SG01-01
제정일 : 2025.00.00
개정일 : -
개정번호 : 0

구분	일자	직책	성명	서명
작 성	2025.00.00	팀원	홍길동	
검 토	2025.00.00	팀장	홍길순	
승 인	2025.00.00	대표이사	홍길원	

목 차

1. 목적 ····· 00

2. 적용 범위 ····· 00

3. 용어 정의 ····· 00

4. 책임 및 권한 ····· 00

5. 업무 절차 ····· 00

5.1. 물리적 보안체계 절차 ····· 00

5.2. 기술적 보안체계 절차 ····· 00

5.3. 위험 관리 ····· 00

5.4. 전자적 침해행위 대응 ····· 00

5.5. 취약점 감시 및 대응 ····· 00

6. 관련 문서 및 양식 ····· 00

제·개정 번호	제·개정일	제·개정 페이지	제·개정 이력 사항
00	2025.00.00	-	디지털의료제품법 시행에 따른 자사 제품에 대한 전자적 침해행위를 예방하기 위한 업무·역할 등을 정의한 절차서 신규 제정

1. 목적

<예시>

본 지침은 당사의 제품이 디지털의료제품법, 디지털의료기기 제조 및 품질관리기준, 디지털의료기기 전자적 침해행위 보안지침 및 관련 표준에 따라 개발, 제조, 설치, 운용, 유지보수 및 폐기에 이르는 전 공정에 걸쳐 전자적 침해행위로부터 제품과 그 운영 환경을 안전하게 보호하기 위한 기본 원칙과 업무 절차 등을 규정하는 것을 목적으로 한다.

2. 적용 범위

<예시>

본 절차서는 다음에 해당하는 보안 활동 전반적으로 적용됨

- *디지털의료기기의 설계, 제조, 설치, 운용, 유지보수 및 폐기 등 TPLC(Total Product Life Cycle) 전 공정*

또한, 적용 대상은 다음과 같음

- *제품 자체 및 제품이 운용되는 물리적·기술적 보안 환경*
- *…*

3. 용어 정의

1) 데이터 중독 공격

인공지능을 활용한 디지털의료기기를 훈련하는 과정에서 훈련 데이터셋에 악의적인 데이터를 주입하여 인공지능 모델이 부정확하거나 왜곡된 학습을 하도록 유도하는 공격을 말한다.

2) …

4. 책임 및 권한

<예시>

4.1 보안책임자

전체 보안 계획 수립 및 사고 대응 총괄, 내부 교육 주관 등

4.2 제품 개발 부서

소프트웨어 보안 설계 및 개발, 제4조, 제5조 및 제7조에서 제12조까지의 보안을 고려한 개발 담당

4.3 품질 담당 부서

소프트웨어 보안 검증, 제4조, 제5조 및 제7조에서 제12조까지의 보안을 고려한 검증 담당

4.4 …

5. 업무 절차

5.1. 물리적 보안체계 절차

< 항목 설명 > 디지털의료기기와 그 운영 환경에서의 물리적 보안을 점검하기 위한 체계 및 절차에 대해 정의한다.

< 작성 예시 >

5.1.1 물리적 보안 체계 절차
조직의 제품 설치 담당자는 제품이 설치될 운영 환경에서 다음과 같은 사항에 대해 물리적 보안 구성 및 조치를 확인한다.

① 설치 및 운용 위치 관련 보안 구성

② 출입 권한, 출입 기록 시스템, CCTV 등 접근 통제 관련

③ 설치 현장에 대한 기술적 보안 구성 요건 확인

<설치 현장에 대한 물리적 보안 구성 요건 확인 점검표(예시)>

번호	***점검 항목***	***점검 기준***	***확인 결과 (O/X)***
1	*설치 공간이 비인가자의 접근으로부터 보호되는가?*	*출입통제 시스템 여부 확인(예 : 카드키, CCTV 등)*	
2	*장비 주변에 물리적 장애물 또는 도난 방지를 위한 수단이 존재하는가?*	*고정장치, 잠금장치 여부 확인*	
3	*장비 위치가 환기, 온습도, 낙하 등 환경 조건을 충족하는가?*	*기준 환경에 부합하는지 확인*	
4	*제품 및 관련 시스템의 USB 포트 등에 대해 접근이 제한되어 있는가?*	*커버/봉인 여부 등 사용 안내 문구 부착*	
5	*제품 납품 시, 병원/의료기관 내 보안 관련 담당자의 승인을 받았는가?*	*담당자 승인 서명란 포함*	

5.1.2 제품 특성 보안 절차
디지털의료기기의 보안 통신 및 권한 및 인증 방안은 다음과 같이 정의하였으며 각 항목에 대한 유효성 검증은 기술문서 등에 명시한다.

① 유·무선 네트워크 사용 시, 디지털의료기기 및 그 운영 환경의 네트워크 보안 설정

② 이동식 저장매체(USB 등)에 대한 물리적 제한

…

< 관련 산출물 >
- 물리적 보안 체계 지침서, 소프트웨어 유효성 확인 절차서/보고서 등

5.2. 기술적 보안체계 절차

< 항목 설명 > 디지털의료기기와 그 운영 환경에서의 기술적 보안을 점검하기 위한 체계 및 절차에 대해 정의함

< 작성 예시 >

5.2.1 기술적 보안 체계 절차
조직의 제품 설치 담당자는 제품이 설치될 운영 환경에서 다음과 같은 사항에 대해 기술적 보안 구성 및 조치를 확인한다.

① 설치 및 운용 위치 관련 보안 구성

② 방화벽, DDoS 대응 장비, 웹 방화벽 등 기술적 보안 대응 관련

③ 설치 현장에 대한 기술적 보안 구성 요건 확인

<설치 현장에 대한 기술적 보안 구성 요건 확인 점검표(예시)>

번호	***점검 항목***	***점검 기준***	***확인 결과 (O/X)***
1	*설치 공간이 방화벽, 보안 장비 등으로 보호되어 있는 공간인가?*	*서버실 네트워크 계통도 등*	
2	*내부망과 외부망이 물리적으로 또는 논리적으로 분리되어 있는가?*	*내부망/외부망 네트워크 계통도, 망연계 시스템 등*	
3	*외부에서 원격으로 접속할 수 없는 환경인가?*	*내부망 여부, 방화벽 정책 등*	
4	*외부에서 DDoS 등 트래픽 공격을 하더라도 방어가 가능한 장비가 구축되어 있는가?*	*방화벽 장비, DDoS 대응 장비 등*	

5.2.2 제품 특성 보안 절차
디지털의료기기의 데이터 보안 및 인공지능 보안 방안은 다음과 같이 정의하였으며 각 항목에 대한 유효성 검증은 기술문서 등에 명시한다.

① 개인정보에 대한 암호화 등 데이터 비식별화 조치

② 국내·외 암호화 알고리즘 사용 시, 널리 권고되는 암호화 및 해시 알고리즘 사용

…

< 관련 산출물 >
- 기술적 보안 체계 지침서, 소프트웨어 유효성 확인 절차서/보고서 등

5.3. 위험 관리

< 항목 설명 > 제품 개발 및 운영 전 과정에서 보안 위협을 체계적으로 식별 및 평가하고 위험수준을 관리하기 위한 절차에 대해 정의함

< 작성 예시 >

5.3.1 위험관리 활동
위험 관리 수행을 위한 인원 및 조직 등에 대해 정의하고, 위협 모델링 적용 기법, 위협·취약점에 대한 식별 및 위험 평가, 보안 위험 완화 조치 등의 위험 관리 활동에 대한 설명과 수행 주체에 대해 정의한다.

…

5.3.2 개발 및 검증 활동
보안을 고려한 개발 및 검증 활동을 위한 인원 및 조직 등에 대해 정의하고, 시큐어 코딩 적용 여부, 보안을 고려한 아키텍처(설계), 보안 테스트(정적/동적 등), 취약성 테스트, 침투 테스트 기법 등에 대한 설명과 수행 주체에 대해 정의한다. 또한, 제품 개발 시 사용한 테스트 도구에 대한 유효성 확인 방법도 문서화 한다.

…

5.3.3 레거시 디지털의료기기 관리 활동
레거시 소프트웨어의 적합성을 증명하기 위해, 현행 표준([별표 3])을 전면 적용하여 문서를 현행화 하거나, 다음에 기술된 레거시 위험관리 절차를 수행한다.

① 지원 종료 이후 보안 위험을 최소화하기 위한 설계 및 구현 활동을 위한 인원 및 조직 등에 대해 정의

② 제품 출시 이후 예상 지원 종료 일정(예 : 5년)

③ …

5.3.4 소프트웨어 구성요소 명세서 관리 활동(보유 시)
소프트웨어 구성요소 명세서(SBOM) 생성, 저장, 송수신 등의 과정을 수행해야 하는 업무, 인원 및 조직 등에 대한 내용과 SBOM 도구, SBOM 데이터 보안 방안 등에 대한 설명과 수행 주체에 대하여 정의한다.

< 관련 산출물 >
- 소프트웨어 위험관리 절차서, 소프트웨어 설계 및 개발 절차서, 소프트웨어 유효성 확인 보고서, 레거시 관리 활동 절차서, SBOM 관리 절차서 등

5.4. 전자적 침해행위 대응

< 항목 설명 > 침해행위 발생 시 신속하고 효과적인 대응을 통해 최소한의 피해를 유지하기 위한 체계 및 절차에 대해 정의한다.

< 작성 예시 >

5.4.1 침해행위 대응 업무 절차
침해행위에 대한 효과적인 대응을 위해 다음과 같은 내용을 포함한다.

① 침해행위 대응 계획, 신고, 조치 사항에 대한 업무 내용과 인원 및 조직 등에 대해 정의

② 침해행위 신고 방안, 조치 방안, 위험 관리 방안, 대응팀 현황, 연속성 보장 계획, 테스트 및 훈련 방안에 대한 대응 계획

③ 침해행위 신고 및 보고 절차

④ 침해행위 조치 방안, 재발 방지 대책 방안 절차 등에 대한 설명과 수행 주체에 대해 정의

…

< 관련 산출물 >
- 침해행위 대응 절차서, 침해행위 조치 보고서 등

5.5. 취약점 감시 및 대응

< 항목 설명 > 취약점 발견 및 조치를 위한 체계 및 절차에 대해 정의한다.

< 작성 예시 >

5.5.1 취약점 감시 및 대응 업무 절차
침해행위에 대한 효과적인 대응을 위해 다음과 같은 내용을 포함한다.

① 취약점을 지속적으로 관리하기 위한 감시, 공개 및 조치 절차에 대한 업무 내용과 인원 및 조직 등에 대해 정의

② 취약점 감시 절차, 취약점 공개 절차, 취약점 확인 후 보고 절차

③ 취약점 보고 항목(상세 내용, 심각도, 영향, 대응 방안) 정의

④ 지속적인 취약점 모니터링 방안 절차 등에 대한 설명과 수행 주체에 대해 정의

…

< 관련 산출물 >
- 취약점 감시 절차서, 취약점 공개 및 조치 보고서 등

6. 관련 문서 및 양식

관련 문서명	문서 번호	담당자	기록 보존 기간
위험관리 절차서	*QP-006*	*품질 책임자*	*제조일로부터 5년, 시판 후 2년*
설계 및 개발 절차서	*QP-001*	*품질 책임자*	*제조일로부터 5년, 시판 후 2년*
물리적/기술적 보안 지침서	*GL-SEC-001*	*보안 책임자*	*제조일로부터 5년, 시판 후 2년*
침해행위 대응 절차서	*QP-SEC-002*	*보안 책임자*	*제조일로부터 5년, 시판 후 2년*
취약점 감시 및 대응 절차서	*QP-SEC-003*	*보안 책임자*	*제조일로부터 5년, 시판 후 2년*
보안 점검 기록	*REC-SEC-001*	*제품 개발 부서*	*제조일로부터 5년, 시판 후 2년*
침해행위 조치 보고서	*REC-SEC-002*	*보안 책임자*	*제조일로부터 5년, 시판 후 2년*
취약점 조치 보고서	*REC-SEC-003*	*보안 책임자*	*제조일로부터 5년, 시판 후 2년*

※ 기록 보존 기간: 기기의 수명 주기에 상응하는 기간 동안 보유하여야 한다. 이 기간은 최소한 제조일로부터 5년 이상이어야 하며, 시판 후 2년 이상이어야 한다.

붙임 2 디지털의료기기 허가 인증 심사 첨부 자료

구분	심사 첨부 자료	비고
1	의료기기 소프트웨어 적합성 확인보고서	√ 디지털의료기기의 경우 전자적 침해행위로부터 보호 조치에 관한 자료로 **'디지털의료기기 소프트웨어 적합성 확인보고서' 는 제외함**
2	의료기기 사이버보안 요구사항 체크리스트 「의료기기의 사이버보안 허가.심사 가이드라인(민원인 안내서)」 [표 3]	√ 전자적 침해행위로부터 보호 조치(사이버보안) 요구사항에 대한 적용 여부, 적합성 입증 방법, 이를 검증한 자료명 또는 문서번호를 기재
3	'의료기기 사이버보안 요구사항'을 검증한 자료 「의료기기의 사이버보안 허가.심사 가이드라인(민원인 안내서)」 [표 2]	√ 가이드라인 [표 2]의 '의료기기 사이버보안 요구사항'의세부 요구사항을 반영하여 검증하였는지 확인하고, 미적용된항목의 경우 위험관리문서 등 근거자료를 통해 미적용 사유 기재 √ 전문기관에서 시험한 자료는 KISA의 IoT 보안인증 인증서 등을 제출할 수 있으며, 해당 기관에서 발급한 인증서 및 시험결과를 확인할 수 있는 자료(결과요약서, 시험성적서 등)를 제출할 수 있음 √ 「디지털의료제품법」에따른 디지털의료기기의 경우 「디지털의료기기 전자적 침해행위 보안지침」을 적용하여야 하며, 「의료기기의 사이버보안 허가.심사 가이드라인(민원인 안내서)」 [표 2]의 '의료기기 사이버보안 요구사항'에 따라 심사하되, 인공지능 기술이 적용된 의료기기의 경우 제12조(인공지능보안)의 요구사항을 추가 적용
4	'사용자 매뉴얼' 전자적 침해행위로부터의 보호를 위한 주의사항을 확인할 수 있는 사용자 매뉴얼	√ 신청서(사용 시 주의사항) 내 기재한 전자적 침해행위로부터의 보호를 위한 주의사항이 기재되어 있는지 검토
5	(필요 시 제출) 제조사의 위험분석을 통해 요구사항 일부를 제외하거나 수정하여 적용하는 경우 이에 대한 설정 근거(예. 위험관리문서 등)	

붙임 3 디지털의료기기 제조 및 품질관리 기준(GMP) 심사 대응 체크리스트

번호	조항	주요 점검 항목 (예시)	적용 여부
1	제2조(보안활동의 문서화)	디지털의료기기 전자적 침해행위 보안지침 대응 문서(예 : 절차서, 지침서 등)를 마련하고 각 조항에 대응하기 위한 기업의 전략이 충분히 반영되어 있는가?	
2	제3조(물리적 보안)	디지털의료기기가 운영되는 물리적 보안 환경을 분석하기 위한 점검 자료가 준비되어 있는가?	
3		물리적 보안 조치를 위한 주요 점검 사항을 의료서비스제공자에게 충분히 인지시킬 수 있는 자료가 준비되어 있는가?	
4	제4조(보안 통신)	디지털의료기기가 사용하는 네트워크 통신 구성(유·무선, 병원망/공용망 등)에 대해 정의되어 있으며, 보안 통신 방안을 마련하여 디지털의료기기에 적용하였는가?	
5		네트워크 보안을 준수하기 위한 시험 항목을 선정하여 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
6		의료서비스제공자/사용자에게 전달하기 위한 자료(보안 통신 적용을 위한 설정 정보, 안내사항 등)를 준비하였는가?	
7		하드웨어가 포함된 디지털의료기기의 경우 물리적 포트 등의 연결을 차단하기 위한 방안이 적용되어 있는가?	
8	제5조(권한 및 인증)	디지털의료기기에 접근하기 위한 통제 정책, 권한 설정 등이 적용되어 있으며 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
9		디지털의료기기의 세션 및 쿠키를 안전하게 보호하기 위한 방안이 적용되어 있으며 유효성 확보 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
10		디지털의료기기에 안전하게 접근하기 위한 인증 사용, 원격 접속 제한 조치 등이 적용되어 있으며 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	

번호	조항	주요 점검 항목 (예시)	적용 여부
11	제6조(기술적 보안)	디지털의료기기가 운영되는 기술적 보안 환경을 분석하기 위한 점검 자료가 준비되어 있는가?	
12		개인정보 또는 개인정보가 포함된 데이터를 안전하게 사용하기 위한 보호 조치가 적용되어 있고 이를 설명하기 위한 자료가 준비되어 있는가?	
13	제7조(파일 및 입력 유효성)	파일 업로드 및 다운로드 시의 유효성 및 무결성 검증 방안이 적용되어 있으며 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
14		실행 파일 업로드 방지 및 입력 정보에 대한 유효성 검증 방안이 적용되어 있으며 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
15	제8조(데이터 보안)	데이터베이스가 제품에 포함되어 있는 경우 데이터베이스 보호를 위한 조치가 적용되어 있으며 해당 조치를 이해할 수 있는 자료가 준비되어 있는가?	
16		데이터베이스가 제품에 포함되어 있진 않으나 안전한 데이터베이스 사용을 위한 보호 조치를 설명한 자료가 준비되어 있는가?	
17		데이터 비식별화 조치, 권고되는 암호화 및 해시 알고리즘이 적용되어 있으며 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
18	제9조(암호화 키 관리)	암호화 키를 사용하는 경우 암호화 키에 대한 보안 조치가 적용되어 있으며 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
19	제10조(유지관리)	업데이트 및 업데이트 실패에 대한 대응이 적용되어 있으며 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
20		제품의 주요 운영 데이터 등에 대한 비인가된 변경에 대응하기 위한 방안이 적용되어 있으며 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
21	제11조(보안 모니터링 및 대응)	불필요한 서비스(인터페이스, 포트) 등이 비활성화되어 있으며 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
22		주요 운영 데이터에 대한 백업 및 복구 방안이 마련되어 있으며 해당 방안을 이행할 수 있는 자료가 준비되어 있는가?	
23		하드웨어가 포함된 경우 안티 바이러스 소프트웨어가 같이 설치되어 있으며 업데이트(온라인/오프라인) 방안을 이행할 수 있는 자료가 준비되어 있는가?	

번호	조항	주요 점검 항목 (예시)	적용 여부
24	제12조(인공지능 보안)	데이터 공격에 대한 방어, 위변조 행위에 대한 방어, 모델 추출/회피 공격에 대한 방어 등이 적용되어 있으며 이를 확인하기 위한 자료가 준비되어 있는가?	
25		인공지능 시스템 운영 중 문제 발생 시의 조치 사항이 적용되어 있으며 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
26	제13조(위험관리 활동)	위협 모델링, 위험 식별, 평가, 조치 등 위험 관리 활동을 확인할 수 있는 자료를 보유하고 있는가?	
27	제14조(개발 및 검증 활동)	보안 요구사항을 고려한 개발 및 검증 활동을 수행하였으며 이를 확인할 수 있는 자료를 보유하고 있는가?	
28		디지털의료기기를 개발하는 데 사용한 테스트 도구에 대한 유효성을 확인하였으며, 유효성 확보를 위한 자료(유효성 확인 보고서 등)를 보유하고 있는가?	
29	제15조(레거시 디지털의료기기 관리 활동)	제품 출시 이후의 예상 지원 종료 일정과 수명 종료 이후 예상 지원 계획 등의 정보를 확인할 수 있는 자료를 보유하고 있는가?	
30		제품 내 위험 및 취약점 발견 시에 대응하기 위한 방안을 확인할 수 있는 자료를 보유하고 있는가?	
31		제품에 개인정보가 포함되는 경우, 개인정보를 안전하게 제거하기 위한 방법을 확인할 수 있는 자료를 보유하고 있는가?	
32	제16조(소프트웨어 구성요소 명세서 관리 활동)	소프트웨어 구성요소 명세서를 활용하기 위한 방안과 명세서 보유 시 생성, 저장 및 송수신 과정에서의 데이터 보안이 적용되어 있는가?	
33	제17조(침해행위 대응 계획 등)	침해행위 대응 계획을 보유하고 있고 대응 인력 및 대응 훈련 방안이 마련된 자료를 보유하고 있는가?	
34	제18조(침해행위 신고)	침해행위 인지 시 이를 알리기 위한 방안이 마련된 자료를 보유하고 있는가?	
35	제19조(침해행위 발생 이후의 조치)	침해행위 조치를 위한 문서양식을 보유하고 있으며, 침해행위가 발생한 경우, 조치 사항에 대해 기록을 보유하고 있는가?	
36	제20조(취약점 감시)	취약점 감시 활동 계획과 절차에 대해 문서화하고 있는가?	
37	제21조(취약점 공개)	취약점 공개 절차에 대해 문서화하고 있는가?	
38	제22조(취약점 조치)	취약점을 보고한 경우 이를 해결하기 위한 조치 방안을 문서화하고 있는가?	

참고 법령, 지침 및 표준 목록

1) 의료기기 사이버보안 원칙 및 실무

2) 의료기기 사이버보안 허가·심사 가이드라인

3) 레거시 의료기기의 사이버보안을 위한 원칙 및 실무

4) 의료기기 사이버보안을 위한 소프트웨어 자재명세서 원칙 및 실무

5) 스마트의료 사이버보안 가이드

6) 의료기기 보안시험 해설서

7) 소프트웨어 개발보안 가이드

8) 보안 위협에 취약한 레거시 의료기기 사이버보안 지침

9) 하드웨어 공급망 보안 검증을 위한 공통 보안 요구사항

10) 의료기기 사이버보안 요구사항

11) 의료기기 정보보호 요구사항

12) IEC/TR 60601-4-5, Medical electrical equipment - Part 4-5: Guidance and interpretation - Safety-related technical security specifications

13) IEC 81001-5-1, Health software and health IT systems safety, effectiveness and security (Part 5-1: Security – Activities in the product life cycle)

14) Principles and Practices for Medical Device Cybersecurity (IMDRF/CYBER WG/N60FINAL)

15) Principles and Practices for the Cybersecurity of Legacy Medical Devices (IMDRF/CYBER WG/N70FINAL)

16) Principles and Practices for Software Bill of Materials for Medical Device CybersecurityAUTHORING (IMDRF/CYBER WG/N73FINAL)

17) The NIST Cybersecurity Framework(CSF) 2.0

18) DIRECTIVE (EU) 2022/2555 OF THE EUROPEAN PARLIAMENT AND OF THECOUNCILof14December2022 on measures for a high common level of cybersecurity across the Union, amending Regulation(EU) No910/2014 and Directive(EU)2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive)

19) Cybersecurity Guidance, Cybersecurity in Medical Devices: Quality System Considerations and Content of Premarket Submissions

20) PostmarketManagement of Cybersecurity in Medical Devices

21) ANSI/AAMI SW96:2023, standard For Medical Device Security - Security Risk Management For Device Manufacturers

22) AAMI TIR57:2016 (R2023), Principles For Medical Device Security - Risk Management

23) AAMI TIR97:2019 (R2023), Principles For Medical Device Security - PostmarketRisk Management For Device Manufacturers

24) IEC 62443-4-1:2018, Security for industrial automation and control systems

25) ISO/IEC 29147:2018, Information technology - Security techniques - Vulnerability disclosure

26) ISO/IEC 30111:2019, Information technology - Security techniques - Vulnerability handling processes

27) 의료기관 개인정보보호 가이드라인

28) 개인정보의 기술적·관리적 보호조치 기준 해설서

29) 인공지능(AI) 개발·서비스를 위한 공개된 개인정보 처리 안내서

30) KS X ISOIEC27033-1

31) KS X ISOIEC27033-2

32) KS X ISOIEC27033-3

33) KS X ISOIEC27034-1

34) KS X ISOIEC27035

35) HITRUST CSF PDF v11.3.0

36) REGULATION (EU) 2016/679 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

37) ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements

38) ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection — Information security controls

39) ISO/IEC 27032:2023 Cybersecurity — Guidelines for Internet security

40) ISO/IEC 27037:2012 Information technology — Security techniques — Guidelines for identification, collection, acquisition and preservation of digital evidence

41) HIPAA Administrative Simplification Regulation Text 45 CFR Parts 160, 162, and 164 (Unofficial Version, as amended through March 26, 2013)

42) 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드

43) 소프트웨어 공급망 보안 가이드라인

44) 빅데이터 및 인공지능 기술이 적용된 의료기기 허가심사 가이드라인

45) 유헬스케어의료기기 허가·심사 가이드라인

46) 인공지능 의료기기의 허가·심사 가이드라인

47) 인공지능 기반 의료기기의 임상 유효성 평가 가이드라인

48) 2023 신뢰할 수 있는 인공지능 개발 (의료 분야)

49) REGULATION (EU) 2017/745 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 5 April 2017 on medical devices, amending Directive 2001/83/EC, Regulation (EC) No 178/2002 and Regulation (EC) No 1223/2009 and repealing Council Directives 90/385/EEC and 93/42/EEC

50) 암호 알고리즘 및 키 길이 이용 안내서

51) 개인정보의 안전성 확보조치 기준 안내서

52) 정보통신망연결기기등 정보보호인증기준 상세 해설서

53) NIST Publishes SP 800-131A Rev. 2

54) 암호 키 관리 안내서

55) SW 업데이트 체계 보안 가이드라인

56) 민간부문 침해사고 대응 안내서

57) 모바일 전자정부서비스 앱 소스코드 검증 가이드라인

58) NIST SP 800-53 Rev.5

59) 개인정보의 안전성 확보조치 기준

60) 디지털의료기기 전자적 침해행위 보안지침

61) 개인정보보호법

62) 개인정보보호법 시행령

디지털의료기기 전자적 침해행위 보안지침 가이드라인[민원인 안내서]

발 행 일 2025년 11월

발 행 인 식품의약품안전처 의료기기안전국장 이 남 희

편 집 위 원 장 식품의약품안전처 의료기기안전국 디지털의료제품TF팀장
손 미 정

편 집 위 원 식품의약품안전처 의료기기안전국 디지털의료제품TF
김승표, 김병관, 신근수, 황상철, 신혜현, 도미송, 양은옥

발 행 처 식품의약품안전처 의료기기안전국 디지털의료제품TF

문 의 처 전화 : 043-719-3773~3779
팩스 : 043-719-3780